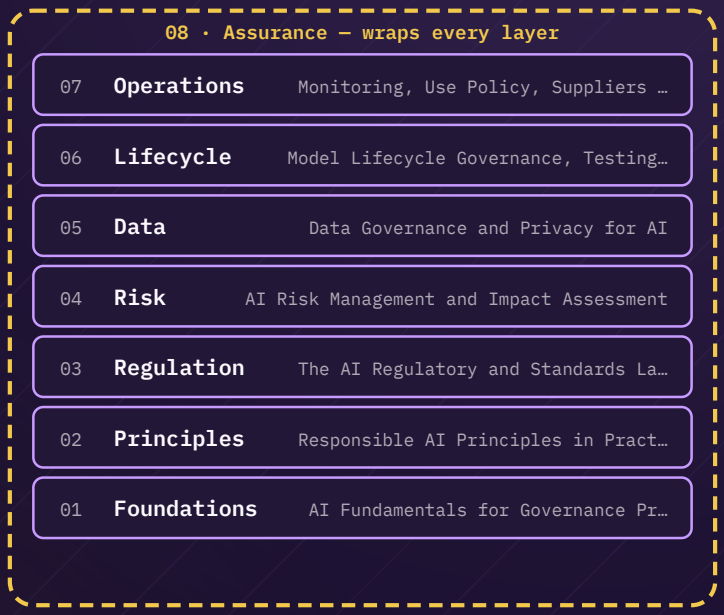
ZAIG

ZyeemZia™ AI Governance

Govern AI so people can trust it.



COURSE BOOK · WORKBOOK · EXAM PREPARATION

8 MODULES · 36 LESSONS · 60 EXAM QUESTIONS

COPYRIGHT © ZYEEMZIA

BEFORE YOU BEGIN

How to use this book

A practical professional certification track for the people who make AI safe, lawful and worth using: principles, the 2026 regulatory landscape, risk and impact assessment, data and privacy, model lifecycle controls, generative-AI policy, suppliers, incidents, audit and board reporting, organised into one governance stack you can build in any organisation.

01
Learn
Work through 36 lessons. Each ends with a knowledge check.

02
Practise
Fill in the templates, answer the scenarios and case studies, review the glossary.

03
Certify
Take the 40-question official exam at zaig.zyeemzia.com, graded on the ZyeemZia server. Pass mark 80%.

04
Get certified
Download your certificate online. Anyone can verify its credential ID at zaig.zyeemzia.com/#verify. 90%+ and the capstone earn Distinction.

Eight-week study plan

WHEN	MODULE	DO THIS	DONE
Week 1	m1 Foundations	Build an AI inventory for your capstone organisation	☐
Week 2	m2 Principles	Write an AI principles statement and a one-page policy	☐
Week 3	m3 Regulation	Regulatory applicability map and EU AI Act role analysis	☐
Week 4	m4 Risk	AI risk register and one full impact assessment	☐
Week 5	m5 Data	Data provenance record, lawful basis and retention plan	☐
Week 6	m6 Lifecycle	Stage gates, model card, bias test and explainability plan	☐
Week 7	m7 Operations	Monitoring plan, generative-AI policy, supplier review, incident playbook	☐
Week 8	m8 Assurance	Operating model, board report, practice and certification exam	☐

Learner name .....

Start date ..... Target exam date .....

ZAIG is an independent certification programme created and issued by ZyeemZia. It is not affiliated with, endorsed by, sponsored by or equivalent to any certification, standard or programme of the IAPP (including the AIGP credential), ISO, IEC, NIST, ISACA, the OECD, the European Union or any other professional body, standards body, regulator or company. References to laws, regulations and standards are summaries in our own words for education, described as of 2026; they are not legal advice and may change. Always read the official texts and take qualified legal advice for your jurisdiction. All names and trademarks belong to their respective owners.

Copyright © ZyeemZia

CONTENTS

What you will learn

01 Foundations — AI Fundamentals for Governance Professionals

1. What AI Is: A Governance Professional's View · 25 min
2. Generative AI and Large Language Models · 30 min
3. AI in the Organisation: Roles, Supply Chains and Inventory · 25 min
4. Why Govern AI: Harms, Value and the ZAIG Stack · 25 min

02 Principles — Responsible AI Principles in Practice

1. From Ethics to Operational Principles · 25 min
2. Fairness and Non-Discrimination · 30 min
3. Transparency, Explainability and Accountability · 25 min
4. Safety, Security, Robustness and Privacy · 30 min
5. Human Oversight and Turning Principles into Policy · 30 min

03 Regulation — The AI Regulatory and Standards Landscape

1. Reading the AI Regulatory Landscape · 25 min
2. The EU AI Act: Scope, Roles and Risk Tiers · 35 min
3. The EU AI Act: Obligations, Timeline and Enforcement · 35 min
4. Frameworks and Standards: NIST AI RMF, ISO/IEC 42001 and OECD · 35 min
5. South Asia and Emerging Rules Worldwide · 30 min

04 Risk — AI Risk Management and Impact Assessment

1. Identifying AI Risks · 30 min
2. Assessing and Scoring AI Risk · 30 min
3. AI Impact Assessments · 35 min
4. Treating AI Risk: Controls and Risk Appetite · 30 min
5. Use-Case Intake, Tiering and the AI Risk Register · 30 min

05 Data — Data Governance and Privacy for AI

1. Data Governance Foundations for AI · 30 min
2. Privacy Law Principles Applied to AI · 35 min
3. Privacy-Enhancing Techniques and Data Minimisation · 30 min
4. Data for Generative AI: Training, Retrieval, Rights and Retention · 35 min

06 Lifecycle — Model Lifecycle Governance, Testing and Explainability

1. Lifecycle Governance and Stage Gates · 30 min
2. Documentation: Model Cards, Datasheets and Technical Files · 30 min
3. Evaluation, Validation and Red Teaming · 35 min
4. Bias Testing and Fairness Metrics · 35 min
5. Explainability in Practice · 30 min

07 Operations — Operating AI Safely: Monitoring, Use Policy, Suppliers and Incidents

1. Monitoring, Drift and Change Control · 35 min
2. Generative-AI Policy and Acceptable Use · 35 min
3. Third-Party and Procurement Risk · 35 min
4. AI Incident Management · 35 min

08 Assurance — Audit, Assurance and the AI Governance Programme

1. AI Audit and Assurance · 35 min
2. Building the AI Governance Programme · 35 min
3. Board Reporting and Metrics · 30 min
4. Maturity, Continuous Improvement and the Road Ahead · 30 min

+ Glossary · Capstone guide · Practice exam & answers · Certificate · Notes

Copyright © ZyeemZia

THE FRAMEWORK

The ZAIG Stack

Eight layers of a working AI governance programme, from understanding the technology at the bottom to assurance and board oversight at the top. Each module builds one layer, and every layer rests on the ones below it.



01 Foundations
Understand how AI and generative AI work, where they fail and where they sit in your organisation

02 Principles
Fairness, transparency, accountability, safety, privacy and human oversight, made operational

03 Regulation
The EU AI Act, NIST AI RMF, ISO/IEC 42001, OECD principles and South Asian rules, as of 2026

04 Risk
Identify, assess, treat and track AI risks to people and the organisation

05 Data
Quality, provenance, lawful use and protection of the data that AI learns from and acts on

06 Lifecycle
Stage gates, documentation, evaluation, bias testing and explanations that hold up to scrutiny

07 Operations
Keep AI under control after launch: drift, generative-AI use, third parties and incident response

08 Assurance
Prove that governance works, organise it well and report it to the board

Copyright © ZyeemZia

01

MODULE 1 · FOUNDATIONS

AI Fundamentals for Governance Professionals

Understand how AI and generative AI work, where they fail and where they sit in your organisation

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Explain how machine-learning and generative-AI systems learn, behave and fail, in language leaders understand
- Identify the distinctive risks of generative AI and AI agents
- Map the roles an organisation plays in the AI value chain and build an AI inventory
- Describe the harms AI can cause and why governance enables rather than blocks AI
- Use the ZAIG Stack to structure an AI governance programme

LESSONS

1. What AI Is: A Governance Professional's View · 25 min
2. Generative AI and Large Language Models · 30 min
3. AI in the Organisation: Roles, Supply Chains and Inventory · 25 min
4. Why Govern AI: Harms, Value and the ZAIG Stack · 25 min

MODULE 1 · FOUNDATIONS · LESSON 1 · 25 MIN

What AI Is: A Governance Professional's View

AI, machine learning, deep learning and generative AI without the hype

- Explain what makes a system an AI system in plain language
- Distinguish machine learning, deep learning, foundation models and generative AI
- Describe how a model learns from data and why that matters for governance
- Recognise the common ways machine-learning systems fail

You do not need to build models to govern them, but you do need to understand how they behave. Most AI governance failures start with a simple misunderstanding: someone treats a statistical system as if it were ordinary software that follows fixed rules. An AI system does something different. It **infers** how to produce outputs from the data and objectives it was given, so its behaviour is shaped by patterns in that data, including patterns nobody intended.

> DEFINITION · AI SYSTEM (WORKING DEFINITION)
> A machine-based system that, for explicit or implicit objectives, **infers from the input it receives how to generate outputs** such as predictions, content, recommendations or decisions that can influence physical or virtual environments. Systems vary in how autonomous they are and in whether they keep adapting after deployment. This is the idea behind the definitions used by the OECD and the EU AI Act, expressed in our words.

The AI family, from broadest to most specific

Artificial intelligence	`Any technique that lets machines perform tasks we associate with human judgement` `Includes rule-based expert systems and search`
Machine learning	`Systems that learn patterns from data instead of being explicitly programmed` `Credit scoring, fraud detection, demand forecasting`
Deep learning	`Machine learning with many-layered neural networks` `Image recognition, speech, translation`
Foundation models	`Very large models trained on broad data and adapted to many tasks` `Large language models, vision-language models`
Generative AI	`Systems that create new text, images, audio, video or code` `Chat assistants, image generators, coding assistants`

A machine-learning model is built in two phases. In **training**, an algorithm adjusts millions or billions of internal parameters so the model's outputs match examples in a training dataset as closely as possible. In **inference**, the trained model is given new inputs and produces outputs. Governance must cover both: what the model learned from, and how it is used once deployed.

Copyright © ZyeemZia

From data to decision

01 Problem
A business objective is turned into a prediction or generation task

→

02 Data
Examples are collected, labelled and cleaned

→

03 Training
The algorithm fits parameters to the data

→

04 Evaluation
Performance is measured on data the model has not seen

→

05 Deployment
The model runs inside a product or process

→

06 Decision
A person or system acts on the output

Ways machines learn, and what each means for governance

APPROACH	HOW IT LEARNS	TYPICAL USE	GOVERNANCE QUESTION
Supervised learning	From labelled examples (input and correct answer)	Loan default prediction, spam filtering	Are the labels accurate and free of historical bias?
Unsupervised learning	Finds structure in unlabelled data	Customer segmentation, anomaly detection	Are the groups it finds meaningful and fairly used?
Reinforcement learning	Learns by trial, error and reward	Pricing, robotics, recommendation tuning	Could the reward be met in harmful ways?
Self-supervised learning	Predicts hidden parts of its own data	Pre-training large language models	What was in the vast training data, and who owns it?

INSIGHT · A MODEL IS A COMPRESSED MEMORY OF ITS DATA

Whatever is in the training data, including gaps, errors, stereotypes and personal information, can reappear in the model's behaviour. That is why data governance (Module 5) sits so low in the ZAIG Stack: weak data quietly undermines every layer above it.

Why machine-learning systems fail

- **Unrepresentative data**: the training data does not reflect the people or situations the model meets in use.
- **Proxy variables**: a harmless-looking feature such as postcode or university stands in for a protected characteristic.
- **Overfitting**: the model memorises its training data and performs poorly on new cases.
- **Distribution shift (drift)**: the world changes after training, for example a new mobile wallet changes spending patterns.
- **Feedback loops**: the model's own decisions shape the future data it learns from.
- **Wrong objective**: the model optimises a measurable target that is only loosely linked to the real goal.

Traditional software vs machine-learning systems

Traditional rules-based software

- Logic written explicitly by developers
- Same input always gives the same output
- Errors traced to a line of code
- Tested against a specification
- Changes only when code changes

Machine-learning system

- Logic inferred from data
- Outputs are probabilistic and may vary
- Errors spread across millions of parameters
- Tested statistically on samples
- Can degrade as the world changes, with no code change

Copyright © ZyeemZia

SCENARIO · DECIDE · THE 'IT IS JUST SOFTWARE' ASSUMPTION

A university in Dhaka buys a tool that predicts which first-year students are likely to drop out so advisers can contact them. The IT team plans to approve it through the normal software change process: security scan, user acceptance test, go-live. You are the new AI governance lead. What is the MOST important additional step?

(A) Ask the vendor for a faster implementation timeline so advisers can start sooner.

(B) Require evidence of how the model was trained and tested, including performance across student groups and whether the training data reflects this university's students.

(C) Block the tool because AI should not be used in education.

(D) Run the security scan twice to be safe.

Circle your choice. Answer and feedback: module answer key.

REFLECT

Pick one AI-powered tool your organisation already uses. Can you say what data it learned from, what it is optimising for and who checks its outputs? Note the gaps.

Key terms

AI system
A machine-based system that infers from inputs how to produce outputs such as predictions, content, recommendations or decisions.

Machine learning
A branch of AI in which systems learn patterns from data rather than following explicitly programmed rules.

Training data
The examples used to fit a model's parameters during training.

Inference
Running a trained model on new inputs to produce outputs.

Proxy variable
A feature that indirectly encodes another attribute, often a protected characteristic, leading to hidden discrimination.

Overfitting
When a model learns its training data too closely and generalises poorly to new data.

Distribution shift
A change between the data a model was trained on and the data it meets in use, often causing performance to fall.

Feedback loop
A cycle in which a model's outputs influence the future data used to train or evaluate it.

KNOWLEDGE CHECK

1. What most clearly distinguishes an AI system from conventional rules-based software?

(A) It always runs in a public cloud environment

(B) It cannot be tested before it is deployed

(C) It infers how to produce outputs from data and objectives rather than following explicitly written logic

(D) It is always fully autonomous and needs no human

2. A recruitment model never sees candidates' gender, yet favours men. Which failure is the most likely cause?

(A) Overfitting to the test data

(B) Reinforcement learning rewards

(C) An encryption weakness

(D) A proxy variable, such as a hobby or past employer, correlates with gender

Copyright © ZyeemZia

3. A fraud model performed well at launch, but accuracy fell after a new mobile wallet changed how customers pay. What is this called?

   (A) Overfitting
   (B) Distribution shift or drift
   (C) Hallucination
   (D) Prompt injection

4. Which learning approach is most associated with pre-training large language models?

   (A) Self-supervised learning
   (B) Rules-based expert systems
   (C) Reinforcement learning only
   (D) Unsupervised clustering

5. Why should governance cover both training and inference?

   (A) Training is the only phase regulators care about
   (B) Inference never involves personal data
   (C) Risks arise from what the model learned and from how its outputs are used in decisions
   (D) Training happens only once and needs no records

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 1 · FOUNDATIONS · LESSON 2 · 30 MIN

Generative AI and Large Language Models

What foundation models can do, how they fail and why that changes governance

- Explain in plain terms how a large language model produces an answer
- Describe the main capabilities and limits of generative AI
- Identify the distinctive failure modes of generative AI and AI agents
- Map the parts of a generative-AI application that need controls

Generative AI moved AI governance from a specialist topic to a board agenda item. Suddenly every employee could use a powerful model through a chat window, and every vendor added an assistant to their product. For governance professionals, the key shift is this: predictive models make narrow judgements inside a defined process, while generative models produce open-ended content for almost any purpose, so the **range of possible uses and harms is far wider**.

How a large language model comes to answer a question

01 Pre-training
Learns to predict the next token from a very large body of text and code

→

02 Instruction tuning
Fine-tuned on examples of following instructions

→

03 Preference tuning
Adjusted using human or AI feedback to be more helpful and less harmful

→

04 Prompt
Receives system instructions, user input and any retrieved documents

→

05 Generation
Produces the answer one token at a time, choosing likely continuations

WATCH OUT · FLUENT IS NOT THE SAME AS CORRECT

A language model generates text that is **statistically plausible**, not text that is checked against facts. It can produce a confident, well-written answer that is entirely made up, including fake citations, legal cases or policy terms. Every governance control for generative AI starts from this fact.

Capabilities and limits

GENERATIVE AI IS GOOD AT	GENERATIVE AI STRUGGLES WITH
Drafting, summarising and rewriting text	Guaranteeing factual accuracy
Translating and working across languages, including Bangla	Consistent performance in low-resource languages and dialects
Writing and explaining code	Knowing when it does not know
Extracting fields from documents	Precise arithmetic and long chains of reasoning without tools
Answering questions over supplied documents	Keeping secrets that were put into its context
Brainstorming and classification	Producing identical outputs every time

Copyright © ZyeemZia

Distinctive failure modes of generative AI

- **Confabulation (hallucination)**: confident but false content.
- **Prompt injection**: instructions hidden in user input, emails or web pages hijack the model's behaviour.
- **Data leakage**: confidential data entered in prompts is exposed, logged or reused.
- **Harmful or biased output**: stereotypes, toxic content or unsafe advice.
- **Intellectual property issues**: outputs that reproduce protected material, or unclear rights over training data.
- **Over-reliance**: people stop checking because the output looks polished.
- **Impersonation and deepfakes**: realistic synthetic voices, images and video used for fraud or disinformation.

Anatomy of a generative-AI application (top layer first)

User experience	`Chat or embedded assistant` `Disclosure that users are talking to AI` `Feedback buttons`
Guardrails and orchestration	`Input and output filters` `System prompt and policies` `Human approval steps`
Retrieval and tools	`Company documents searched for context` `Connected tools and APIs the system may call`
Foundation model	`Third-party or open-weight model` `Version, licence and provider terms`
Data and infrastructure	`Logs, prompts and outputs` `Hosting location, access control, retention`

Governance now also has to cover **AI agents**: systems that plan multi-step tasks and act through tools, such as sending emails, updating records or making payments. An agent's errors are no longer just words on a screen; they become actions. The more autonomy and the more powerful the tools, the stronger the controls must be: least-privilege permissions, human approval for consequential actions, activity logs and the ability to stop the agent.

Predictive AI vs generative AI: what changes for governance

Predictive AI

- Narrow, defined task
- Output is a score or class
- Accuracy measured against labels
- Usually built or bought for one process
- Risk concentrated in specific decisions

Generative AI

- Open-ended, many possible tasks
- Output is new content or action
- Quality judged by rubrics, tests and people
- Available to every employee
- Risk spread across many unplanned uses

EXAMPLE · A BANK'S CUSTOMER CHATBOT

A bank in Dhaka launches a Bangla-and-English chatbot to answer account questions. In testing, it invents a fee waiver that does not exist. Customers who rely on such answers may complain, and tribunals in other countries have held companies responsible for what their chatbots told customers. The bank responds by grounding answers only in approved policy documents, adding a visible AI disclosure, routing fee and complaint questions to staff and logging every conversation for review.

Copyright © ZyeemZia

SCENARIO · DECIDE · AN EAGER PILOT

The marketing team at a garment exporter wants to connect a generative-AI assistant to the shared mailbox so it can read buyer emails and reply automatically. What should the governance lead recommend FIRST?

(A) Approve it, because the vendor says the model is the most accurate on the market.

(B) Start with a draft-only mode where the assistant suggests replies and a person sends them, with permissions limited to the mailbox and logging switched on.

(C) Ban all generative AI in the company until regulation is final.

(D) Let the team run it for a month and review complaints afterwards.

Circle your choice. Answer and feedback: module answer key.

Questions to ask about any generative-AI use

☐ What decisions or actions will rely on the output?

☐ Which model and provider are used, and under what terms?

☐ What data goes into prompts, and is any of it personal or confidential?

☐ Are answers grounded in approved sources?

☐ Can the system take actions, and which need human approval?

☐ How are users told they are dealing with AI?

☐ How are outputs tested for accuracy, bias and harmful content?

☐ Who reviews logs and handles complaints?

Key terms

Generative AI
AI that creates new content such as text, images, audio, video or code in response to inputs.

Foundation model
A large model trained on broad data that can be adapted to many downstream tasks.

Prompt injection
An attack in which crafted input causes a model to ignore its instructions or take unintended actions.

Grounding
Constraining a model's answers to supplied, trusted sources such as retrieved documents.

Large language model (LLM)
A foundation model trained on vast text to predict tokens, used for generating and understanding language.

Confabulation
Generation of confident but false or unsupported content; often called hallucination.

AI agent
An AI system that plans and carries out multi-step tasks by calling tools or taking actions.

Deepfake
Synthetic audio, image or video that realistically imitates a real person or event.

KNOWLEDGE CHECK

6. Why can a large language model produce a confident answer that is false?

(A) It deliberately deceives users to save computing cost

(B) It generates statistically likely text rather than checking claims against facts

(C) It only fails when the internet connection is slow

(D) It is designed to refuse every factual question

7. A supplier email contains hidden text telling an assistant to forward all invoices to an outside address. What is this?

(A) Model drift

(B) Overfitting

(C) Prompt injection

(D) Data minimisation

Copyright © ZyeemZia

8. Which control best reduces the risk of an AI agent sending a wrong payment?

   (A) Requiring human approval for payments and limiting the agent's permissions
   (B) Using a larger model
   (C) Making the system prompt longer
   (D) Turning off logging to improve speed

9. Compared with predictive AI, generative AI is harder to govern mainly because:

   (A) It never uses personal data
   (B) It cannot be bought from vendors
   (C) It is always less accurate
   (D) It is open-ended and available to many users for uses nobody planned

10. What does grounding a chatbot in approved documents mainly reduce?

    (A) The need for any human oversight
    (B) Hosting costs
    (C) The number of languages supported
    (D) Invented answers that are not supported by company policy

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 1 · FOUNDATIONS · LESSON 3 · 25 MIN

AI in the Organisation: Roles, Supply Chains and Inventory

You cannot govern what you cannot see

- Identify the roles organisations play in the AI value chain
- Explain why the provider and deployer distinction matters
- Build and maintain an AI inventory that captures the facts governance needs

Few organisations build every AI system they use. A typical bank, hospital or university buys software with AI features, calls models through an API, fine-tunes an open-weight model for one task and lets staff use public chat assistants. Each arrangement places the organisation in a different **role**, and laws and standards attach different duties to different roles. The first practical task in AI governance is therefore to **find the AI** and record what role you play for each system.

Roles in the AI value chain

R1
Developer or provider
Builds a model or AI system, or has it built, and puts it on the market or into service under its own name.

R2
Deployer
Uses an AI system under its own authority in its operations, such as a bank using a credit-scoring tool.

R3
Importer and distributor
Brings an AI system from another jurisdiction into a market or makes it available without changing it.

R4
Data supplier
Provides datasets for training, testing or operation, and shapes quality and rights.

R5
Operator or user
The staff member who works with the system day to day and exercises oversight.

R6
Affected person
Anyone whose life, rights or opportunities are influenced by the system's outputs, whether or not they use it.

A typical AI supply chain (top layer first)

Affected people	`Customers, patients, students, workers, citizens`
Deploying organisation	`Configures, operates and oversees the system` `Owns the decision and the customer relationship`
Application provider	`Builds the product around one or more models` `Adds retrieval, tools, user interface and guardrails`
Model provider	`Trains the foundation or specialist model` `Sets usage policies and licence terms`
Data and compute	`Training data sources and labellers` `Cloud and hardware providers`

WATCH OUT · ROLES CAN CHANGE

If you substantially modify a bought system, retrain it for a new purpose or sell it under your own name, you may move from deployer to provider and inherit the provider's heavier duties. Record every significant change to an AI system and reassess the role each time.

Copyright © ZyeemZia

Shadow AI is AI used without the organisation's knowledge: staff pasting customer data into personal chat accounts, teams switching on AI features in software they already licence, or departments buying low-cost AI tools on a credit card. An inventory exercise almost always finds far more AI than leaders expected. The aim is not to punish people but to bring useful tools into a governed path.

Building an AI inventory

1. **Agree a definition** Use a working definition of an AI system and include AI features inside larger products.
2. **Search several sources** Check procurement records, expense claims, software catalogues, cloud bills, browser and network logs, and ask every department.
3. **Capture core facts** Purpose, owner, role, model and provider, data used, people affected, decisions influenced and deployment status.
4. **Assign a provisional risk tier** Use a simple triage so high-impact systems get attention first (developed in Module 4).
5. **Link to other registers** Connect to the data inventory, vendor register, records of processing and risk register.
6. **Keep it alive** Make registration a condition of procurement and go-live, and review the inventory at least quarterly.

TEMPLATE AI inventory register

Record every AI system in one place so that ownership, role and risk are visible.

SYSTEM AND PURPOSE	BUSINESS OWNER	OUR ROLE	MODEL AND PROVIDER	DATA USED	PEOPLE AFFECTED	PROVISIONAL TIER
Loan pre-screening score for nano-loans	*Head of Digital Lending*	*Deployer (vendor model, our configuration)*	*Gradient-boosted model from fintech vendor*	*Wallet transaction history, KYC data*	*Wallet customers applying for credit*	*High*
Meeting summary feature in office suite	*IT Operations*	*Deployer*	*Suite provider's built-in LLM*	*Meeting audio and transcripts*	*Staff and external attendees*	*Medium*

Is it in scope? Quick examples

EXAMPLE	IN THE AI INVENTORY?	WHY
Spreadsheet formula that flags invoices over a fixed amount	Usually no	Fixed rules written by people; no inference from data
Email spam filter trained on past messages	Yes, low tier	Learns from data, limited impact
CV-screening feature in a hiring platform	Yes, high tier	Influences access to employment

Copyright © ZyeemZia

EXAMPLE	IN THE AI INVENTORY?	WHY
Staff using a public chat assistant for drafting	Yes, as a use case	Data leakage and output-quality risks
Vendor's fraud model embedded in a payment gateway	Yes	AI inside a bought product still counts

PRO TIP · START WITH THE MONEY

Procurement and expense data are the fastest way to find AI. Search them for words such as 'AI', 'GPT', 'copilot', 'assistant', 'intelligent', 'predictive' and 'machine learning', then follow up with the budget holders.

CASE STUDY · THE INVENTORY THAT SURPRISED THE BOARD

A mobile financial services provider in Dhaka believed it ran three AI systems: a fraud model, a credit model and a customer chatbot. A two-week inventory sprint found twenty-three, including AI-based call-centre quality scoring, a recruitment screening add-on, automated translation of customer notices, a marketing tool that generated social media images, and dozens of staff using personal accounts on public chat assistants with customer complaint text.

1. Which discoveries carry the highest risk, and why?

2. What role does the company play for the recruitment add-on and the chatbot?

3. What should happen to the staff use of personal chat accounts?

Model answer: module answer key.

SCENARIO · DECIDE · WHO OWNS THIS?

An inventory review finds a translation tool used by three departments, paid for by IT, with no named owner. What is the BEST next step?

(A) Let IT own it because IT pays the licence.

(B) Remove the tool until each department justifies its use.

(C) Assign an accountable business owner for the use case, with IT as technical custodian, and record both in the inventory.

(D) Leave it unassigned because translation is low risk.

Circle your choice. Answer and feedback: module answer key.

Key terms

Provider
An organisation that develops an AI system or model, or has it developed, and places it on the market or puts it into service under its own name.

Deployer
An organisation that uses an AI system under its own authority, other than for purely personal activity.

Copyright © ZyeemZia

Affected person
Someone whose rights, opportunities or interests are influenced by an AI system's outputs.

Shadow AI
AI tools or features used in an organisation without its knowledge or approval.

Substantial modification
A significant change to an AI system that can alter its risk or purpose and may change the organisation's role and duties.

AI value chain
The linked set of organisations that supply data, models, tools and applications up to the point of use.

AI inventory
A maintained register of the AI systems an organisation develops, buys or uses, with key facts for governance.

Business owner
The named person accountable for an AI use case's purpose, outcomes and risks.

KNOWLEDGE CHECK

11. A hospital uses a vendor's AI triage tool exactly as supplied. In most frameworks the hospital is the:

(A) Provider
(B) Importer
(C) Deployer
(D) Data supplier

12. Which change is most likely to turn a deployer into a provider?

(A) Changing the colour of the user interface
(B) Adding a new user account
(C) Renewing the annual licence
(D) Retraining a bought system for a new purpose and offering it under its own brand

13. What is the fastest reliable starting point for finding AI in an organisation?

(A) Waiting for staff to self-report incidents
(B) Procurement, expense and software catalogue records
(C) Reading vendors' marketing material
(D) Checking only the data science team's projects

14. Why should an AI inventory record the people affected by each system?

(A) Impact on people drives the risk tier and the controls required
(B) It is needed to calculate licence fees
(C) It replaces the need for an impact assessment
(D) It is only needed for marketing purposes

15. What is the best response to widespread shadow AI use?

(A) Provide a governed alternative, clear use rules and awareness, then bring uses into the inventory
(B) Dismiss staff found using public tools
(C) Ignore it because it is personal productivity
(D) Block all websites with AI in the name

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 1 · FOUNDATIONS · LESSON 4 · 25 MIN

Why Govern AI: Harms, Value and the ZAIG Stack

Governance as the condition for using AI with confidence

- Classify the harms AI can cause to individuals, groups, organisations and society
- Explain how governance differs from management and compliance
- Describe the eight layers of the ZAIG Stack and how they connect
- Apply proportionality so controls match the level of risk

AI governance is the system of **direction, rules, roles and evidence** that makes sure an organisation's use of AI is lawful, ethical, safe and aligned with its goals. It is not a brake on innovation. Organisations with good governance tend to move faster, because teams know what is allowed, approvals are predictable and leaders can defend their decisions to regulators, customers and the public.

Who can be harmed by AI

LEVEL	EXAMPLES OF HARM	EXAMPLE SETTING
Individuals	Wrongful denial of a loan, job or benefit; privacy invasion; unsafe medical advice; manipulation	Credit scoring, hiring, health chatbots
Groups	Systematic disadvantage for women, ethnic or religious minorities, rural users, people with disabilities or speakers of minority languages	Face recognition, speech tools, risk scoring
Organisations	Regulatory fines, lawsuits, reputational damage, security breaches, bad decisions at scale	Any deployer or provider
Society and environment	Disinformation, erosion of trust, labour disruption, energy and water use, concentration of power	Generative AI, elections, large-scale training

Recurring patterns from real AI failures (described generally)

- A recruiting model learned to downgrade CVs that mentioned women's activities because past hiring data was male-dominated.
- Automated benefit-fraud risk scoring wrongly flagged thousands of families, with nationality and dual citizenship among the factors; the scandal contributed to a government resigning.
- A company was held responsible by a tribunal for a refund policy its website chatbot invented.
- A finance employee transferred millions after a video call in which the 'executives' were deepfakes.
- Face recognition systems misidentified people with darker skin at higher rates, contributing to wrongful arrests.

INSIGHT · THE COMMON THREAD

In almost every case, the technology did what it was built to do. The failure was in **governance**: no one asked who might be harmed, no one tested for it, no one monitored after launch, and no one had clear authority to stop the system.

Copyright © ZyeemZia

Governance, management and compliance

Governance

- Sets direction, risk appetite and accountability
- Led by the board and senior leaders
- Asks: are we doing the right things, the right way?

Management

- Plans and runs AI activities within that direction
- Led by business and technical owners
- Asks: are we doing things well?

Compliance

- Checks conformity with laws, standards and internal policy
- Led by compliance, legal and audit functions
- Asks: can we show we met our obligations?

The ZAIG Stack: eight layers of an AI governance programme (built from the bottom up)

L1
Foundations
How AI and generative AI work and fail; roles, supply chains and the AI inventory.

L2
Principles
Fairness, transparency, accountability, safety, privacy and human oversight, made operational.

L3
Regulation
EU AI Act, NIST AI RMF, ISO/IEC 42001, OECD principles, and South Asian and other national rules.

L4
Risk
Risk identification and scoring, impact assessments, treatment and the risk register.

L5
Data
Data quality and provenance, privacy, rights, minimisation and retention.

L6
Lifecycle
Stage gates, documentation, evaluation, bias testing and explainability.

L7
Operations
Monitoring and drift, generative-AI use policy, suppliers and incidents.

L8
Assurance
Audit, the governance operating model, board reporting and metrics.

Read the stack from the bottom up. You cannot write sensible principles without understanding the technology; you cannot map regulation without principles to interpret it; risk assessment applies both; data and lifecycle controls treat the risks; operations keep controls working day to day; and assurance proves to leaders and regulators that the whole programme works. Each module of this track builds one layer.

Proportionality: matching effort to risk

P1
Low risk
Register, name an owner, apply standard acceptable-use rules. Example: grammar suggestions in email.

P2
Medium risk
Add a light assessment, testing before launch and periodic review. Example: internal knowledge assistant.

P3
High risk
Full impact assessment, independent validation, human oversight, monitoring and senior sign-off. Example: credit or hiring decisions.

P4
Unacceptable
Do not build or use. Example: social scoring or manipulative techniques that exploit vulnerable people.

Copyright © ZyeemZia

DEFINITION · ABOUT THIS TRACK AND THE LAW

ZAIG describes laws, regulations and standards in our own words, as of 2026, to help you build a governance programme. **It is education, not legal advice.** Regulations change, guidance is issued, and how a rule applies depends on facts and jurisdiction. Always check the official texts and involve qualified lawyers for legal decisions.

SCENARIO · DECIDE · GOVERNANCE AS A BRAKE?

The chief executive of a fast-growing fintech in Dhaka says: 'Governance will slow us down; we will add it once we are bigger.' Which response from the AI governance lead is MOST persuasive?

(A) Explain that governance is legally required everywhere, so there is no choice.

(B) Propose proportionate governance: light rules for low-risk tools and focused controls on credit and fraud models, showing how it speeds approvals and protects partner and regulator trust.

(C) Agree, and plan to revisit governance after the next funding round.

(D) Insist that every AI use goes through the same full impact assessment.

Circle your choice. Answer and feedback: module answer key.

REFLECT

Think of one AI system in your organisation. If it went badly wrong tomorrow, who would be harmed, who would be held accountable, and what evidence would you have that you had governed it responsibly?

Key terms

AI governance
The system of direction, policies, roles, processes and evidence that ensures an organisation's AI is lawful, ethical, safe and aligned with its goals.

Proportionality
Matching the depth of governance controls to the level of risk a system poses.

Accountability
Being answerable for decisions and outcomes, with the authority and duty to act.

Trustworthy AI
AI that is lawful, ethical and technically robust, so stakeholders can reasonably rely on it.

Responsible AI
Designing, building and using AI in ways that respect people's rights and wellbeing and that can be justified to stakeholders.

Risk appetite
The amount and type of risk an organisation is willing to accept in pursuit of its objectives.

ZAIG Stack
The eight-layer model used in this track: Foundations, Principles, Regulation, Risk, Data, Lifecycle, Operations and Assurance.

KNOWLEDGE CHECK

16. Which statement best describes AI governance?

(A) A one-time legal review before launch

(B) A technical team that tunes model accuracy

(C) A ban on AI until regulation is final

(D) Direction, rules, roles and evidence that keep AI use lawful, ethical, safe and aligned with goals

Copyright © ZyeemZia

17. In many real AI failures, what was usually missing?

(A) More powerful hardware
(B) Questions about harm, testing for it, monitoring and clear authority to stop the system
(C) Larger training datasets
(D) Faster deployment pipelines

18. Which layer of the ZAIG Stack covers stage gates, documentation and bias testing?

(A) Principles
(B) Regulation
(C) Assurance
(D) Lifecycle

19. Applying proportionality means:

(A) Light controls for low-risk uses and deeper controls for high-risk uses
(B) The same process for every AI system
(C) Skipping governance for internal tools
(D) Only governing systems that a regulator names

20. Who sets AI risk appetite and overall accountability?

(A) Individual data scientists
(B) The model vendor
(C) The board and senior leadership
(D) External auditors

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 1 · FOUNDATIONS

Answer key

Knowledge checks

1. C AI systems infer their behaviour from data and objectives. Cloud hosting, testability and autonomy vary and are not defining features.

2. D Removing a protected attribute does not remove its influence if other features act as proxies for it.

3. B The data in use has moved away from the training distribution, so the model's learned patterns fit less well.

4. A Large language models are pre-trained by predicting hidden or next tokens in vast text, a form of self-supervised learning.

5. C Data and design choices made in training shape behaviour, while inference is where outputs affect people. Both need controls.

6. B LLMs predict plausible continuations. Without grounding and verification, plausibility can diverge from truth.

7. C Instructions planted in content the model processes are a classic indirect prompt injection.

8. A Least privilege and approval gates contain the impact of agent errors. Model size does not guarantee correct actions.

9. D The breadth of possible uses and users widens the risk surface beyond a single defined decision process.

10. D Grounding limits answers to trusted sources, which reduces confabulation, though it does not remove the need for testing and oversight.

11. C Using a system under its own authority makes the hospital a deployer. The vendor that built and markets the tool is the provider.

12. D Substantial modification or rebranding can shift provider duties to the organisation that made the change.

13. B Money trails reveal bought tools and features that technical teams may not know about.

14. A Who is affected, and how seriously, determines the level of scrutiny and the obligations that apply.

15. A Enforcement alone drives use underground. A safe approved path plus rules and education brings use into view.

16. D Governance is a continuing system of direction and accountability, not a single check or a technical activity.

17. B The technology often worked as designed; the failure was in governance around it.

18. D Lifecycle controls apply during design, build, testing and release of models and systems.

19. A Proportionality concentrates effort where potential harm is greatest while keeping low-risk work fast.

20. C Governance direction comes from the top; management works within it and assurance checks it.

Scenarios & case studies

Scenario · The 'it is just software' assumption
B is best. Best. A predictive model's behaviour depends on its training data and statistical performance. Testing across groups and checking data fit are governance questions the normal change process does not ask.

Scenario · An eager pilot
B is best. Best. It captures most of the value while keeping a human in control of outward actions, limits the agent's permissions and creates evidence for later review.

Case study · The inventory that surprised the board
The recruitment screening add-on and the credit model carry the highest risk because they influence access to work and to financial services, and the staff use of personal accounts is urgent because customer personal data is leaving the company's control. For the recruitment add-on the company is a deployer; for the chatbot it is a deployer of a vendor model but may become a provider if it substantially builds and brands the system. Staff use should not simply be banned: provide an approved enterprise assistant with data protections, issue an acceptable-use rule forbidding customer data in personal accounts, and run awareness sessions. Every system found should go into the inventory with an owner and provisional tier.

Scenario · Who owns this?
C is best. Best. Accountability for outcomes sits with the business, while IT manages the technology. Both roles are recorded so questions have a clear destination.

Scenario · Governance as a brake?
B is best. Best. Proportionality keeps low-risk work fast, concentrates effort where harm and liability are greatest and frames governance as an enabler of growth and partnerships.

Copyright © ZyeemZia

02

MODULE 2 · PRINCIPLES

Responsible AI Principles in Practice

Fairness, transparency, accountability, safety, privacy and human oversight, made operational

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Translate responsible-AI principles into requirements, controls and evidence
- Identify sources of bias and choose fairness approaches that match the harm
- Design transparency, explanations and accountability for different audiences
- Apply safety, security and privacy principles to AI systems
- Design meaningful human oversight and structure an AI policy framework

LESSONS

1. From Ethics to Operational Principles · 25 min
2. Fairness and Non-Discrimination · 30 min
3. Transparency, Explainability and Accountability · 25 min
4. Safety, Security, Robustness and Privacy · 30 min
5. Human Oversight and Turning Principles into Policy · 30 min

MODULE 2 · PRINCIPLES · LESSON 1 · 25 MIN

From Ethics to Operational Principles

Why principles matter and how to stop them becoming wall posters

- Explain why responsible-AI principles from different bodies converge on a common core
- Distinguish values, principles, requirements and controls
- Recognise ethics washing and the signs of principles that are not operational

Since 2016, hundreds of organisations, governments and international bodies have published AI ethics principles. Studies comparing them find a strong convergence: almost all mention fairness, transparency, accountability, safety, privacy and human oversight in some form. The hard part is not agreeing on words. It is turning those words into **decisions people can make on a Tuesday afternoon** when a product deadline is close.

The ZAIG core principles

F

Fairness

AI should not create or reinforce unjustified discrimination, and its benefits and burdens should be shared fairly.

T

Transparency

People should know when AI is used, and appropriate information about how it works should be available.

A

Accountability

Named people and organisations answer for AI outcomes and have the authority to act.

S

Safety and security

AI should work reliably as intended, resist misuse and attack, and fail safely.

P

Privacy

Personal data should be used lawfully, minimally and securely, respecting people's rights.

H

Human oversight

People should be able to understand, supervise, intervene in and override AI where it matters.

INSIGHT · PRINCIPLES ARE INTERDEPENDENT

Transparency enables accountability; accountability makes fairness enforceable; privacy limits the data that fairness testing can use; safety depends on oversight. Treat the principles as one system with tensions to balance, not six separate checkboxes.

From values to evidence (top layer first)

Evidence	`Test results, logs, sign-offs, audit reports`
Controls	`Specific checks and safeguards, e.g. a fairness test before release`
Requirements	`Measurable conditions, e.g. approval-rate ratio between groups of at least 0.8`
Principles	`Statements of what matters, e.g. 'our AI treats customers fairly'`
Values	`The organisation's purpose and ethical commitments`

Each principle must be translated downwards. 'We are fair' becomes 'credit models are tested for approval-rate gaps between men and women and between urban and rural applicants before every release', which becomes a control with an owner, a threshold and a record. If you cannot point to the evidence layer, the principle is not yet operational.

Copyright © ZyeemZia

Warning signs of ethics washing

- Principles published but no named owner for any of them.
- No process that could ever stop or change a project on ethical grounds.
- Ethics board with no access to information and no decision rights.
- Principles used in marketing but absent from procurement and engineering standards.
- No metrics, no testing, no incidents ever reported.

Common sources of AI principles

SOURCE	TYPE	WHAT IT OFFERS
OECD AI Principles (2019, updated 2024)	Intergovernmental recommendation	Widely adopted values and policy guidance; basis for many national approaches
UNESCO Recommendation on the Ethics of AI (2021)	Global ethical framework	Human rights focus, policy action areas, readiness assessments
National strategies and guidelines	Government policy	Local priorities, e.g. India's AI governance guidelines and national AI policies in South Asia
Sector regulators	Supervisory guidance	Expectations for banks, insurers, health and telecoms
Company principles	Internal policy	How one organisation interprets values for its products and customers

SCENARIO · DECIDE · PRINCIPLES ON THE WALL

A telecom operator published six AI principles two years ago. An internal review finds no team can name the owner of any principle, and none has ever changed a product decision. What should the AI governance lead propose FIRST?

(A) Rewrite the principles with stronger wording.

(B) Assign an executive owner to each principle and define two or three testable requirements and controls for each, starting with high-risk systems.

(C) Withdraw the principles to avoid accusations of ethics washing.

(D) Commission a public marketing campaign about the principles.

Circle your choice. Answer and feedback: module answer key.

Is this principle operational?

☐ It has a named executive owner

☐ It is translated into specific, testable requirements

☐ Requirements are built into gates, procurement and engineering standards

☐ There is evidence it has been applied (tests, sign-offs, records)

☐ It can change or stop a project

☐ Breaches are reported and acted upon

☐ It is reviewed at least annually

Copyright © ZyeemZia

REFLECT

Choose one of your organisation's stated values. Write one principle, one measurable requirement and one control that would make it real for an AI system you know.

Key terms

AI principles
High-level statements of what an organisation commits to when designing and using AI.

Operationalisation
Turning principles into requirements, controls, owners and evidence that shape real decisions.

Control
A safeguard or check that reduces risk or ensures a requirement is met.

Human oversight
The ability of people to understand, monitor, intervene in and override AI systems.

Ethics washing
Presenting AI ethics commitments publicly without the processes or evidence to back them.

Requirement
A specific, testable condition an AI system or process must meet.

Fairness
The principle that AI should not cause unjustified discrimination and should distribute benefits and burdens equitably.

KNOWLEDGE CHECK

1. Which set best describes the common core of responsible-AI principles?
   - A Speed, scale, cost, novelty, automation, profit
   - B Accuracy only, measured on public benchmarks
   - C Open source, cloud hosting and large models
   - D Fairness, transparency, accountability, safety, privacy, human oversight
2. 'Approval rates for women must be at least 80% of the rate for men' is an example of a:
   - A Value
   - B Principle
   - C Incident
   - D Requirement
3. Which is the clearest sign of ethics washing?
   - A A principle with a named owner
   - B A fairness test in the release gate
   - C Published principles that have never changed or stopped any project
   - D An annual review of the principles
4. Why should principles be treated as an interdependent system?
   - A They support and sometimes constrain each other, so trade-offs must be balanced
   - B They are legally identical everywhere
   - C Only one principle can apply to each system
   - D They replace the need for risk assessment
5. Where should translation of principles into controls start?
   - A With low-risk tools because they are easiest
   - B With high-risk systems where harm and liability are greatest
   - C With marketing material
   - D With systems that are being retired

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 2 · PRINCIPLES · LESSON 2 · 30 MIN

Fairness and Non-Discrimination

Where bias comes from and what fairness can mean in practice

- Identify the sources of bias across the AI lifecycle
- Compare common definitions of fairness and their trade-offs
- Decide which fairness approach suits a given use case

AI bias is rarely the result of someone intending to discriminate. It enters quietly through history, data collection, labels and design choices, and it can scale a small unfairness to millions of decisions. Fairness governance asks three questions: **who could be disadvantaged, how would we know, and what level of difference is acceptable and justified?**

Where bias enters the lifecycle

01 History — Past decisions already reflect discrimination

→

02 Sampling — Some groups are under-represented in the data

→

03 Measurement — Labels or features measure groups differently

→

04 Modelling — Design choices favour the majority pattern

→

05 Evaluation — Tests use benchmarks that miss some groups

→

06 Deployment — The system is used in a context it was not built for

Types of bias with South Asian examples

BIAS TYPE	WHAT HAPPENS	EXAMPLE
Historical bias	Data faithfully records an unfair past	Past loan approvals favoured salaried urban men, so a model learns to prefer them
Representation bias	Some groups are missing or sparse in the data	A skin-condition model trained mostly on lighter skin performs worse for darker skin
Measurement bias	The label or feature is a poor proxy	Using 'number of hospital visits' as a proxy for health need undercounts people with less access to care
Language bias	Performance varies by language or dialect	A speech system handles standard Bangla well but fails on Sylheti or Chittagonian speakers
Deployment bias	The context of use differs from design	A model built for Dhaka city applicants is used for rural agricultural loans

DEFINITION · PROTECTED CHARACTERISTICS

Attributes that law or policy protects against discrimination. Lists vary by country but commonly include sex or gender, religion, race or ethnicity, caste, disability, age and place of birth. Bangladesh's Constitution, for example, prohibits state discrimination on grounds of religion, race, caste, sex or place of birth. Check the law that applies to your sector and jurisdiction.

Copyright © ZyeemZia

Three families of fairness definitions

Group fairness

- Compare outcomes or error rates across groups
- Examples: similar approval rates; similar false-negative rates
- Easy to measure and report

Individual fairness

- Similar individuals should be treated similarly
- Requires defining 'similar' carefully
- Harder to test at scale

Procedural fairness

- Fair process: notice, explanation, the chance to contest
- Focuses on how decisions are made and challenged
- Matters even when outcomes are balanced

WATCH OUT · YOU CANNOT SATISFY EVERY FAIRNESS METRIC AT ONCE

When the true rates of an outcome differ between groups, it is mathematically impossible for a model to equalise selection rates, error rates and calibration across those groups simultaneously. Choosing a fairness definition is therefore a **values and policy decision**, not only a technical one. Document who made it and why.

Choosing a fairness approach for a use case

1. **Identify affected groups** List the groups who could be disadvantaged, including intersections such as rural women.
2. **Understand the harm** Is the main harm wrongly denying a benefit (false negatives) or wrongly accusing someone (false positives)?
3. **Select metrics that match the harm** For hiring, compare selection rates; for fraud flags, compare false-positive rates.
4. **Set thresholds and justification** Agree acceptable gaps with legal, business and affected-group input.
5. **Test, mitigate and record** Measure, adjust data or model where needed, and document the decision (Module 6).

SCENARIO · DECIDE · WHICH FAIRNESS QUESTION MATTERS MOST?

A government agency in South Asia plans an AI system to flag welfare applications for fraud investigation. Investigations delay payments for weeks. Which fairness measure should the agency prioritise?

(A) Equal overall accuracy across districts.

(B) Equal false-positive rates across groups, so honest applicants in any group are equally unlikely to be wrongly flagged.

(C) Equal numbers of investigations in each district.

(D) Maximum total fraud detected, regardless of who is flagged.

Circle your choice. Answer and feedback: module answer key.

CASE STUDY · THE SCHOLARSHIP SCREENING TOOL

A private university in Chattogram used a model to rank scholarship applicants by 'likelihood of success'. It was trained on ten years of graduation data. An internal review found students from madrasa backgrounds and from outside major cities were ranked much lower, even with similar exam marks. Historically, those students had received less financial support and had dropped out more often for financial reasons.

1. What types of bias are present?

2. Is the model 'accurate' and is it fair?

Copyright © ZyeemZia

3. What should the university do?

Model answer: module answer key.

REFLECT

For one AI system you know, which group would be most harmed by a false positive, and which by a false negative? Which error matters more, and who should decide?

Key terms

Algorithmic bias
Systematic and unjustified differences in an AI system's outputs or errors that disadvantage certain people or groups.

Representation bias
Bias caused by some groups being missing or under-represented in training or test data.

Protected characteristic
An attribute, such as sex, religion, race, caste, disability or age, that law or policy protects from discrimination.

Individual fairness
The idea that similar individuals should receive similar outcomes.

Historical bias
Bias that arises because data accurately records past unfair decisions or conditions.

Measurement bias
Bias arising when a label or feature measures the intended concept differently or poorly for some groups.

Group fairness
Fairness assessed by comparing outcomes or error rates across groups.

Intersectionality
The combined effect of belonging to several groups at once, such as rural women, which can create distinct disadvantage.

KNOWLEDGE CHECK

6. A model trained on past hiring decisions learns to prefer graduates of a few elite universities. This is mainly:
   - (A) Measurement bias in the sensors
   - (B) Overfitting to synthetic data
   - (C) Historical bias
   - (D) A prompt injection

7. Why is choosing a fairness metric partly a policy decision?
   - (A) Regulators always prescribe one metric for every system
   - (B) Different metrics conflict when base rates differ, so someone must choose which harm to prioritise
   - (C) All metrics give the same answer
   - (D) Metrics only matter for generative AI

8. For a system that flags people for fraud investigation, which error rate usually matters most for fairness?
   - (A) False-positive rate
   - (B) Training loss
   - (C) Latency
   - (D) Token count

9. A speech assistant works well in standard Bangla but poorly for regional dialects. Which bias is this?
   - (A) Historical bias in loan data
   - (B) Confirmation bias of auditors
   - (C) Automation bias
   - (D) Language or representation bias

Copyright © ZyeemZia

10. Procedural fairness focuses on:

(A) Equal selection rates only
(B) Maximising model accuracy
(C) Notice, explanation and the ability to contest decisions
(D) Reducing compute costs

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 2 · PRINCIPLES · LESSON 3 · 25 MIN

Transparency, Explainability and Accountability

Who knows what, who explains, and who answers

- Distinguish transparency, explainability and interpretability
- Design transparency appropriate to different audiences
- Build accountability through roles, decision rights, contestability and redress

Transparency is about **information**: being open that AI is used and providing appropriate facts about how. Explainability is about **reasons**: helping a person understand why a particular output was produced. Accountability is about **answerability**: someone must own the outcome, explain it, fix it and face consequences if it goes wrong. Together they make AI contestable, which is the real test of whether people are protected.

Transparency for different audiences

AUDIENCE	WHAT THEY NEED	EXAMPLE ARTEFACT
Affected individuals	That AI is involved, the main factors, how to contest	Notice in the loan decision letter with a contact for human review
Users and operators	Capabilities, limits, when not to rely on outputs	Instructions for use and training
Regulators and auditors	Design, data, testing, risk controls	Technical documentation and logs
Board and executives	Where AI is used, key risks and performance	AI portfolio report
Public	Commitments and high-level use	AI principles and public register of systems

Transparency, explainability, interpretability

Transparency

- Openness about the system's existence, purpose, data and limits
- Applies to the whole system and organisation

Explainability

- Reasons for a particular output, in terms the audience understands
- Often produced after the fact

Interpretability

- How far a human can understand the model's internal mechanics
- Higher in simple models such as scorecards

EXAMPLE · A GOOD ADVERSE-DECISION NOTICE

'Your application for a nano-loan was assessed with the help of an automated scoring system. The main factors were: irregular wallet top-ups in the last three months and a short account history. You can ask for a review by a member of our credit team within 30 days by replying to this message or visiting any branch.'

Building blocks of accountability

A1

Named owners

Every AI system has an accountable business owner and a technical owner.

A2

Decision rights

It is clear who can approve, change, pause or retire each system.

A3

Traceability

Logs and records let you reconstruct what happened and why.

Copyright © ZyeemZia

A4
Contestability
Affected people can challenge outcomes and reach a human.

A5
Redress
Errors are corrected and harm is remedied.

A6
Consequences
Breaches of policy lead to action, and lessons change practice.

WATCH OUT · THE 'THE ALGORITHM DECIDED' TRAP
No organisation can hand accountability to a model or a vendor. When a customer, court or regulator asks why a decision was made, 'the system decided' is not an answer. The deployer remains answerable for decisions made with AI in its operations.

TEMPLATE **AI accountability matrix (RACI)**

Make roles explicit for each key activity on a high-risk AI system.

ACTIVITY	RESPONSIBLE	ACCOUNTABLE	CONSULTED	INFORMED
Approve deployment of credit model	*Model risk team*	*Chief Risk Officer*	*Legal, privacy, business owner*	*Board risk committee*
Handle customer appeal of AI decision	*Credit operations reviewer*	*Head of Lending*	*Compliance*	*Customer*

SCENARIO · DECIDE · A REQUEST FOR REASONS
A job applicant rejected by an AI screening tool asks a garment company's HR team why. The vendor says the model is proprietary and cannot be explained. What should HR do?

(A) Tell the applicant the decision was made by the vendor's system and cannot be discussed.

(B) Provide the main factors available, offer a human review of the application, and press the vendor for explanation capability as a contract requirement.

(C) Delete the applicant's data to avoid further questions.

(D) Send the applicant the full model source code.

Circle your choice. Answer and feedback: module answer key.

Copyright © ZyeemZia

Practical transparency commitments

- Tell people when they are interacting with an AI system unless it is obvious.
- Label synthetic images, audio and video, especially realistic depictions of people.
- Tell individuals when AI significantly influenced a decision about them and how to contest it.
- Publish a plain-language summary of high-impact AI uses.
- Keep documentation detailed enough for an auditor to reconstruct key decisions.

REFLECT

If a customer challenged an AI-assisted decision in your organisation today, how many days would it take to explain the decision and give them a human review? What would slow you down?

Key terms

Transparency
Openness about the existence, purpose, functioning, data and limits of an AI system.

Interpretability
The degree to which a person can understand how a model works internally.

Redress
Correction of errors and remedy of harm caused by an AI-assisted decision.

RACI
A matrix that assigns who is Responsible, Accountable, Consulted and Informed for each activity.

Explainability
The ability to give reasons for a specific AI output in terms the audience can understand.

Contestability
The ability of affected people to challenge an AI-assisted decision and have it reviewed.

Traceability
The ability to reconstruct how an AI system produced an outcome using logs and records.

KNOWLEDGE CHECK

11. Which concept concerns the reasons for a specific output?
    - (A) Transparency about system existence
    - (B) Data minimisation
    - (C) Explainability
    - (D) Robustness
12. A vendor says its model is proprietary. Who remains accountable for decisions the deploying bank makes with it?
    - (A) Only the vendor
    - (B) The bank as deployer
    - (C) Nobody, because it is automated
    - (D) The customer
13. Which artefact best serves an affected individual?
    - (A) The model's full training dataset
    - (B) A technical architecture diagram
    - (C) The vendor's annual report
    - (D) A plain notice with main factors and how to request human review

Copyright © ZyeemZia

14. Contestability means:

(A) Affected people can challenge an outcome and reach a human reviewer
(B) The model can be retrained daily
(C) Auditors can access source code
(D) Vendors can bid against each other

15. Which accountability building block lets you reconstruct what happened after an incident?

(A) Traceability through logs and records
(B) Redress
(C) Marketing
(D) Procurement discounts

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 2 · PRINCIPLES · LESSON 4 · 30 MIN

Safety, Security, Robustness and Privacy

AI that works as intended, resists attack and respects personal data

- Explain what safety, robustness and security mean for AI systems
- Recognise the main attack types against AI
- Apply core privacy principles to AI use cases
- Include sustainability and wellbeing in the safety conversation

Safety means an AI system does not cause unacceptable harm, whether through error, misuse or unexpected behaviour. **Robustness** is its ability to keep performing under unusual inputs and changing conditions. **Security** is its resistance to deliberate attack. **Privacy** protects the people whose data the system learns from or processes. These principles share one idea: the system must keep working safely when reality differs from the test lab.

Attacks specific to AI systems

ATTACK	WHAT THE ATTACKER DOES	POSSIBLE IMPACT
Data poisoning	Inserts manipulated examples into training or retrieval data	Hidden backdoors or degraded behaviour
Adversarial examples	Crafts inputs with small changes that fool the model	Fraud passes detection; signs misread
Prompt injection and jailbreaks	Uses crafted text to override instructions or safety rules	Data leakage, harmful output, unauthorised actions
Model extraction	Queries the model repeatedly to copy its behaviour	Theft of intellectual property; easier attacks
Membership and data inference	Probes outputs to learn whether someone's data was used, or recover it	Privacy breach
Supply-chain compromise	Tampers with pre-trained models, libraries or datasets	Malicious code or behaviour inside trusted components

INSIGHT · AI SECURITY IS STILL SECURITY

Most AI incidents still involve ordinary weaknesses: exposed keys, excessive permissions, unpatched servers, misconfigured storage. Apply your existing security controls to AI systems first, then add AI-specific defences.

Engineering for safety and robustness

- Define the intended purpose and the conditions where the system must not be used.
- Test with edge cases, noisy data, rare groups and adversarial inputs, not only typical data.
- Design safe failure: fall back to a human or a simple rule when confidence is low.
- Limit what AI can do: rate limits, transaction caps, approval gates.
- Red-team high-risk and generative systems before launch and after major changes.
- Monitor in production and keep a tested way to switch the system off.

Copyright © ZyeemZia

Core privacy principles applied to AI

PR1
Lawfulness and fairness
Have a valid legal basis, and do not use data in ways people would not reasonably expect.

PR2
Purpose limitation
Data collected for one purpose should not be reused for incompatible AI training without a basis.

PR3
Data minimisation
Use only the data needed; more data is not automatically better.

PR4
Accuracy
Keep data and inferences correct, because AI amplifies errors.

PR5
Storage limitation
Keep prompts, logs and training data only as long as justified.

PR6
Security
Protect data across the pipeline, including model outputs and logs.

PR7
Individual rights
Support access, correction, objection and review of automated decisions where law provides.

EXAMPLE · HEALTH DATA IN A HOSPITAL PILOT

A private hospital in Dhaka pilots a generative-AI tool to draft discharge summaries. Privacy controls include: processing only within a contracted environment that does not use data for training, removing national ID numbers before prompts, limiting access to treating clinicians, keeping prompt logs for 90 days, and requiring a doctor to review every summary before it reaches the patient record.

Safety, security and privacy: different questions

Safety
- Could the system cause harm even when used as intended?
- Focus: errors, misuse, failure modes

Security
- Could someone deliberately make it misbehave or steal from it?
- Focus: attackers, vulnerabilities, access

Privacy
- Is personal data used lawfully, minimally and respectfully?
- Focus: individuals' rights and expectations

Responsible-AI principles increasingly include **sustainability and wellbeing**. Training and running large models uses significant energy and water, and AI can affect jobs, mental health and the information environment. A proportionate programme asks whether a smaller model would do, records the environmental footprint of major systems where possible and considers workforce impacts when AI changes jobs.

Copyright © ZyeemZia

SCENARIO · DECIDE · A TEMPTING DATASET

A mobile financial services provider wants to train a marketing model on customers' full transaction histories, which were collected to run payments. The data science team says 'more data means better predictions'. What should the governance lead advise?

(A) Use all the data, because customers agreed to the general terms of service.

(B) Assess compatibility of the new purpose and the legal basis, minimise to the features actually needed, and run a privacy impact assessment before training.

(C) Anonymise by removing names, then use everything.

(D) Refuse all use of transaction data for AI.

Circle your choice. Answer and feedback: module answer key.

REFLECT

Which of your AI systems would cause the most harm if an attacker manipulated it? What is the one control that would most reduce that risk?

Key terms

Robustness
An AI system's ability to maintain performance under unusual, noisy or changing conditions.

Adversarial example
An input deliberately altered, often imperceptibly, to make a model err.

Red teaming
Structured adversarial testing to find ways a system can fail or be misused.

Data minimisation
Using only the personal data that is adequate, relevant and necessary for the purpose.

Data poisoning
An attack that corrupts training or retrieval data to alter a model's behaviour.

Model extraction
Copying a model's behaviour by systematically querying it.

Purpose limitation
The privacy principle that data collected for one purpose should not be reused for incompatible purposes.

Safe failure
Designing a system so that when it fails, it does so in a way that limits harm, such as handing over to a human.

KNOWLEDGE CHECK

16. An attacker adds manipulated documents to a knowledge base so the assistant gives harmful advice. This is:

(A) Model extraction
(B) Data poisoning
(C) Overfitting
(D) Data minimisation

17. Which principle is most at stake when payment data is reused to train a marketing model?

(A) Robustness
(B) Interpretability
(C) Latency
(D) Purpose limitation

18. What does safe failure mean in practice?

(A) Falling back to a human or simple rule when the system is uncertain or breaks
(B) Never letting the system fail
(C) Hiding errors from users
(D) Restarting the server automatically

Copyright © ZyeemZia

19. Why apply ordinary security controls to AI first?

(A) AI systems are immune to ordinary attacks
(B) AI-specific attacks are illegal
(C) Many AI incidents exploit ordinary weaknesses such as exposed keys or excessive permissions
(D) Ordinary controls are cheaper to ignore

20. Removing names from detailed transaction histories:

(A) Always makes it anonymous
(B) Makes it public data
(C) Usually does not make the data anonymous
(D) Removes the need for a legal basis

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 2 · PRINCIPLES · LESSON 5 · 30 MIN

Human Oversight and Turning Principles into Policy

Meaningful human control and a policy framework that people follow

- Compare human-in-the-loop, on-the-loop and in-command oversight
- Design oversight that counters automation bias
- Structure an AI policy framework from principles to procedures

Human oversight is often added as a reassuring phrase: 'a human will review every decision'. In practice, a reviewer who approves 400 AI recommendations a day, with no time, training or authority to disagree, provides **rubber-stamp oversight**. Meaningful oversight requires competence, time, information, authority and the ability to stop the system.

Models of human oversight

Human in the loop

- A person approves each decision before it takes effect
- Use: high-impact individual decisions such as loan refusals
- Cost: slower, needs capacity

Human on the loop

- The system acts; people monitor and can intervene
- Use: high-volume decisions such as fraud blocks with fast review
- Cost: needs good alerts and quick override

Human in command

- People decide whether, when and how AI is used at all
- Use: governance of every system
- Cost: requires clear decision rights

DEFINITION · AUTOMATION BIAS

The tendency to over-trust automated recommendations, accepting them even when other information suggests they are wrong. It grows when systems are usually right, when reviewers are busy and when disagreeing requires extra effort or justification.

Designing oversight that works

- Give reviewers the information behind the output, not just a score.
- Train reviewers on the system's limits and typical errors.
- Set realistic workloads and measure override rates; near-zero overrides are a warning sign.
- Make disagreeing as easy as agreeing, with no penalty for justified overrides.
- Give named people authority to pause or stop the system.
- Occasionally insert test cases to check reviewers are genuinely reviewing.

Copyright © ZyeemZia

AI policy framework (top layer first)

Principles	`Board-approved commitments` `Short, stable, public`
AI policy	`Mandatory rules and roles` `Scope, risk tiers, approvals, prohibited uses`
Standards	`Specific requirements per topic` `Testing, documentation, generative-AI use, procurement`
Procedures and guidelines	`Step-by-step how-to` `Impact assessment process, model card template`
Records and evidence	`Inventory, assessments, approvals, logs`

What a core AI policy should contain

SECTION	CONTENT
Purpose and scope	Which AI systems, entities and people the policy covers, using a clear AI definition
Principles	Reference to the organisation's responsible-AI principles
Roles and governance	Board, AI governance committee, owners, second and third lines
Risk classification	How systems are tiered and what each tier requires
Prohibited and restricted uses	Uses the organisation will not pursue and those needing special approval
Lifecycle requirements	Inventory, assessments, testing, approval, monitoring, retirement
Third parties	Due diligence and contract requirements for AI suppliers
Incidents and reporting	How AI incidents and concerns are raised and handled
Training and literacy	Required AI literacy for staff by role
Exceptions and review	How exceptions are approved and how often the policy is reviewed

Writing and launching an AI policy

1. **Start from what exists** Reuse privacy, security, model-risk and procurement policies rather than duplicating them.
2. **Draft with the people who must follow it** Include engineering, business, legal, HR and procurement.
3. **Keep the policy short** Put detail in standards and procedures so the policy stays stable.
4. **Approve at the right level** Board or executive committee approves the policy; owners approve standards.
5. **Communicate and train** Explain what changes for each role, with examples.
6. **Measure adoption** Track inventory coverage, assessments completed and exceptions requested.

Copyright © ZyeemZia

SCENARIO · DECIDE · OVERSIGHT ON PAPER

A bank's policy states that a credit officer reviews every AI loan refusal. Data shows officers spend an average of 40 seconds per case and overturn 0.2% of refusals. What does this MOST likely indicate?

(A) The model is almost perfect, so oversight is working well.

(B) Oversight may be ineffective; review workload, information shown, training and incentives, and test with seeded cases.

(C) Remove the human review to save cost because it adds nothing.

(D) Double the number of officers without changing anything else.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE

Human oversight design record

Document how oversight will work for a specific AI system so it can be tested and audited.

SYSTEM	OVERSIGHT MODEL	WHO OVERSEES AND THEIR TRAINING	INFORMATION SHOWN TO REVIEWER	AUTHORITY TO OVERRIDE OR STOP	MEASURES OF EFFECTIVENESS
Nano-loan refusal model	*Human in the loop for refusals*	*Credit officers, 1-day course on model limits*	*Score, top factors, data quality warnings*	*Officer overrides; Head of Lending can pause*	*Override rate, review time, seeded-case accuracy*

REFLECT

Think of a 'human review' step in an AI process you know. Does the reviewer have the time, information, training and authority to disagree? What would you change first?

Key terms

Human in the loop
Oversight in which a person must approve each AI-assisted decision before it takes effect.

Human in command
People retain authority over whether and how AI is used at all.

Human on the loop
Oversight in which a system acts autonomously while people monitor and can intervene.

Automation bias
The tendency to over-rely on automated outputs, even when they are wrong.

Copyright © ZyeemZia

Override rate
The share of AI recommendations that human reviewers change or reject.

Standard (internal)
A detailed mandatory requirement supporting a policy on a specific topic.

AI policy
A mandatory organisational document setting rules, roles and requirements for AI.

Exception process
A controlled way to approve and record departures from policy, with time limits and owners.

KNOWLEDGE CHECK

21. A fraud system blocks suspicious transactions instantly while analysts monitor alerts and can reverse blocks. This is:
    - (A) Human on the loop
    - (B) Human in the loop
    - (C) No oversight
    - (D) Human in command only

22. Which signal most suggests automation bias?
    - (A) Reviewers ask for training
    - (B) Reviewers overturn almost no recommendations after very short reviews
    - (C) Override rates vary by case type
    - (D) Reviewers escalate unclear cases

23. Where should detailed testing requirements usually sit in a policy framework?
    - (A) In the board-approved principles
    - (B) In marketing material
    - (C) In standards and procedures beneath the policy
    - (D) Nowhere; teams decide alone

24. Which element is essential for meaningful oversight?
    - (A) A larger model
    - (B) A longer user manual only
    - (C) Authority and ability to override or stop the system
    - (D) Hiding the model score

25. Why reuse existing privacy, security and procurement policies?
    - (A) Because AI needs no new rules
    - (B) Because regulators forbid new policies
    - (C) To make the AI policy longer
    - (D) To avoid duplication and conflict, adding only what AI needs

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 2 · PRINCIPLES

Answer key

Knowledge checks

1. D Comparative studies show strong convergence on this core across governments, international bodies and companies.

2. D It is specific and testable, translating the fairness principle into something that can be checked.

3. C Principles that never affect decisions indicate commitments without substance.

4. A For example, privacy limits data available for fairness testing, and transparency enables accountability.

5. B Proportionality focuses limited effort where it protects people most.

6. C The data faithfully records past preferences, and the model reproduces them.

7. B Mathematical incompatibility between metrics means values must guide the choice.

8. A Wrongful flags cause the main harm to honest people, so false-positive rates should be compared across groups.

9. D Dialects under-represented in training data lead to worse performance for their speakers.

10. C Procedural fairness concerns how decisions are made and challenged, not only their statistical outcomes.

11. C Explainability gives reasons for a particular output; transparency is broader openness about the system.

12. B Deployers remain answerable for decisions made in their operations, whatever the source of the tool.

13. D Individuals need meaningful, usable information and a route to contest.

14. A It is the practical safeguard that turns transparency into protection.

15. A Without logs and records, investigation and explanation become guesswork.

16. B Corrupting the data a system learns from or retrieves is poisoning.

17. D Using data collected for one purpose for an incompatible new purpose raises purpose-limitation concerns.

18. A Safe failure accepts that systems fail and designs the failure to limit harm.

19. C Basic hygiene closes the most common paths; AI-specific defences are added on top.

20. C Rich behavioural data can often re-identify individuals even without names.

21. A The system acts first, with people monitoring and able to intervene.

22. B Very low override rates with minimal review time indicate rubber-stamping.

23. C Keeping detail in standards lets the policy stay short and stable.

24. C Without authority to act, oversight is observation only.

25. D Integration keeps the framework coherent and easier to follow.

Scenarios & case studies

Scenario · Principles on the wall
B is best. Best. Ownership plus testable requirements connects principles to real decisions and evidence, beginning where risk is greatest.

Scenario · Which fairness question matters most?
B is best. Best. The main harm is honest people being wrongly investigated and losing income, so false positives are the error to balance.

Case study · The scholarship screening tool
The model shows historical bias (it learned outcomes shaped by past lack of support) and likely proxy effects (school type and location). It may be statistically accurate at predicting past outcomes, yet unfair, because it would deny support to exactly the students whose earlier drop-out was caused by lack of support, creating a feedback loop. The university should pause automated ranking, redefine the objective (for example, potential given support), test outcomes by school type and region, involve admissions staff and student representatives in setting fairness requirements, use the model only as one input with human review, and monitor results each intake.

Scenario · A request for reasons
B is best. Best. It gives the applicant meaningful information and recourse now, and fixes the gap with the supplier for the future.

Copyright © ZyeemZia

Scenario · A tempting dataset
B is best. Best. This applies purpose limitation, minimisation and impact assessment before any data moves.

Scenario · Oversight on paper
B is best. Best. The pattern suggests rubber-stamping. Investigating the conditions of review and testing reviewers reveals whether oversight is meaningful.

Copyright © ZyeemZia

03

MODULE 3 · REGULATION

The AI Regulatory and Standards Landscape

The EU AI Act, NIST AI RMF, ISO/IEC 42001, OECD principles and South Asian rules, as of 2026

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Map which laws, regulations and frameworks apply to an AI system, and why
- Classify AI systems under the EU AI Act and summarise the obligations for each role
- Explain how the NIST AI RMF, ISO/IEC 42001 and OECD principles structure a governance programme
- Describe the direction of AI governance in South Asia and other key jurisdictions as of 2026
- Run horizon scanning so regulatory knowledge stays current

LESSONS

1. Reading the AI Regulatory Landscape · 25 min
2. The EU AI Act: Scope, Roles and Risk Tiers · 35 min
3. The EU AI Act: Obligations, Timeline and Enforcement · 35 min
4. Frameworks and Standards: NIST AI RMF, ISO/IEC 42001 and OECD · 35 min
5. South Asia and Emerging Rules Worldwide · 30 min

MODULE 3 · REGULATION · LESSON 1 · 25 MIN

Reading the AI Regulatory Landscape

Hard law, soft law and standards, and why existing law already applies to AI

- Distinguish binding law, soft law, voluntary frameworks and certifiable standards
- Explain why existing laws already govern most AI uses
- Compare the main regulatory approaches to AI around the world as of 2026

AI governance professionals work in a crowded and moving landscape. New AI-specific laws sit on top of data protection, consumer protection, anti-discrimination, product safety, employment and sector rules that already apply to AI. Alongside the law sit voluntary frameworks and international standards, which regulators and courts increasingly treat as evidence of good practice. Your job is not to memorise every rule but to know **which instruments apply to which system, and what evidence each expects**.

WATCH OUT · NOT LEGAL ADVICE

This module summarises laws, regulations and standards **in our own words, as of 2026**, for learning purposes. It is not legal advice. Rules are amended, guidance and court decisions change how they apply, and the answer always depends on the facts. Read the official texts and involve qualified legal counsel before relying on any interpretation.

The layers of AI rules (top layer first)

Organisation policy	`Your principles, AI policy and standards` `Contract terms with customers and suppliers`
Certifiable standards	`Management system standards such as ISO/IEC 42001` `Audited by accredited certification bodies`
Voluntary frameworks and guidance	`NIST AI Risk Management Framework` `Regulator guidance, codes of practice`
AI-specific law	`EU AI Act, national AI acts and rules` `Rules on deepfakes, labelling, high-impact AI`
Existing general law	`Data protection, consumer protection, equality` `Product liability, employment, sector regulation`

Existing laws that already apply to AI

AREA OF LAW	HOW IT REACHES AI	EXAMPLE QUESTION
Data protection	Personal data in training, prompts and outputs; automated decision rules	Do we have a lawful basis to train on customer data?
Consumer protection	Misleading claims, unfair practices, chatbot statements	Are our 'AI-powered' marketing claims true?
Equality and anti-discrimination	Discriminatory outcomes in hiring, lending, housing, services	Does the screening tool disadvantage women?
Product safety and liability	AI inside products and medical devices	Is the AI feature part of a regulated device?

Copyright © ZyeemZia

AREA OF LAW	HOW IT REACHES AI	EXAMPLE QUESTION
Employment law	Monitoring, hiring, dismissal, worker consultation	Must we consult workers before AI monitoring?
Intellectual property	Training data rights, ownership of outputs	Can we use generated images commercially?
Sector regulation	Banking model risk, insurance, health, telecoms	Does the central bank expect model validation?

Main regulatory approaches (as of 2026)

Comprehensive, risk-based law

- One horizontal law with tiers of obligations
- Example: the European Union's AI Act
- Also: South Korea's AI Basic Act in force from January 2026

Principles plus existing regulators

- High-level principles applied by sector regulators
- Examples: the United Kingdom; India's 2025 AI governance guidelines
- Light new legislation, more guidance

Targeted and sub-national rules

- Specific rules for specific technologies or uses
- Examples: China's rules on recommendation algorithms, deep synthesis and generative AI; US state laws on hiring tools and high-risk AI
- Patchwork that changes quickly

INSIGHT · EXTRATERRITORIAL REACH

Several AI laws apply to organisations outside their territory when the system is placed on that market or its outputs are used there. A software company in Dhaka that sells an AI hiring tool to employers in Germany can be a provider under EU rules without having any office in Europe.

Soft law that hardens

- Regulators cite voluntary frameworks when judging whether an organisation acted reasonably.
- Procurement contracts require conformity with standards such as ISO/IEC 42001.
- Harmonised standards can give a legal presumption of conformity with binding law.
- Codes of practice can become the expected way to demonstrate compliance.
- Courts and tribunals look to recognised good practice when assessing negligence.

SCENARIO · DECIDE · WHERE TO START

A private hospital group in Dhaka asks its new AI governance lead, 'Which AI law do we need to comply with?' It uses AI for radiology triage, appointment scheduling and a patient chatbot, and has a research partnership with a European university. What is the BEST first answer?

(A) 'None yet, because Bangladesh has no AI act.'

(B) 'Only the EU AI Act, because it is the strictest law.'

(C) 'Let us map each system against existing local law, sector rules and any foreign law that applies through markets or partners, then align to a recognised framework.'

(D) 'We should wait until a national AI law is passed.'

Circle your choice. Answer and feedback: module answer key.

TEMPLATE **Regulatory applicability map**

Copyright © ZyeemZia

For each AI system, record which laws, rules and frameworks apply and why.

AI SYSTEM	JURISDICTIONS TOUCHED	EXISTING LAW ENGAGED	AI-SPECIFIC RULES	FRAMEWORKS ALIGNED TO	LEGAL OWNER
Radiology triage assistant	*Bangladesh; EU research partner*	*Data protection, medical practice, cyber security*	*EU AI Act possibly if supplied or used in EU*	*ISO/IEC 42001, NIST AI RMF*	*Head of Legal*

REFLECT

List three existing laws in your country that already apply to an AI system you know. Which one would a regulator most likely use first if something went wrong?

Key terms

Hard law
Binding legislation and regulation enforced by authorities and courts.

Soft law
Non-binding instruments such as guidelines, principles and codes that still influence behaviour and expectations.

Horizontal regulation
A law that applies across sectors, such as a general AI act or data protection law.

Sectoral regulation
Rules specific to one industry, such as banking model-risk guidance.

Extraterritorial effect
When a law applies to organisations outside the jurisdiction because of where systems are sold or outputs used.

Harmonised standard
In EU law, a standard whose use can give a presumption of conformity with legal requirements.

Regulatory sandbox
A supervised environment where innovators can test products under regulator guidance.

Applicability assessment
Analysis of which legal and framework requirements apply to a specific system and why.

KNOWLEDGE CHECK

1. Bangladesh has no standalone AI act. Which statement is most accurate for an AI deployer there?

(A) No rules apply until an AI act is passed

(B) Existing laws such as data protection, consumer, cyber security and sector rules still apply

(C) Only foreign AI laws apply

(D) Only voluntary frameworks apply

Copyright © ZyeemZia

2. Which is an example of soft law?

(A) A statute passed by parliament
(B) A court judgment
(C) A criminal penalty
(D) A regulator's guidance note on AI in lending

3. Why can a Dhaka software exporter be subject to EU AI rules?

(A) Because all countries must adopt EU law
(B) Only if it opens an office in Europe
(C) Never; laws apply only within borders
(D) Because the law can apply where systems are placed on the EU market or outputs used there

4. A comprehensive, risk-based horizontal AI law is best illustrated by:

(A) The EU AI Act
(B) A bank's internal model policy
(C) A voluntary industry pledge
(D) A single city's procurement rule

5. How do voluntary frameworks 'harden' over time?

(A) They automatically become criminal law
(B) They expire after two years
(C) Regulators, contracts and courts treat them as the expected standard of care
(D) They replace data protection law

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 3 · REGULATION · LESSON 2 · 35 MIN

The EU AI Act: Scope, Roles and Risk Tiers

How the world's first comprehensive AI law classifies systems

- Explain the scope and territorial reach of the EU AI Act
- Identify the roles the Act regulates
- Classify AI systems into prohibited, high-risk, transparency and minimal-risk tiers
- Recognise where general-purpose AI models are treated separately

The EU Artificial Intelligence Act (Regulation (EU) 2024/1689) entered into force on 1 August 2024 and applies in stages. It is a **product-safety style law**: it sets requirements that AI systems must meet before and while they are on the EU market, scaled to risk. It sits alongside, not instead of, the GDPR, consumer law and sector rules. The summary below is our own description as of 2026.

WATCH OUT · NOT LEGAL ADVICE

This module summarises laws, regulations and standards **in our own words, as of 2026**, for learning purposes. It is not legal advice. Rules are amended, guidance and court decisions change how they apply, and the answer always depends on the facts. Read the official texts and involve qualified legal counsel before relying on any interpretation.

Who and what is in scope (simplified)

- **Providers** placing AI systems or general-purpose AI models on the EU market or putting them into service there, wherever they are established.
- **Deployers** of AI systems located in the EU.
- Providers and deployers outside the EU where the **output** of the system is used in the EU.
- Importers, distributors, product manufacturers and authorised representatives.
- Main exclusions: military and national security uses, scientific research and development before market placement, and purely personal non-professional use. Free and open-source components have limited exemptions that do not cover prohibited or high-risk uses.

The risk tiers (top layer = most restricted)

Unacceptable risk: prohibited	`Banned practices since 2 February 2025`
High risk	`Strict requirements before and after market placement` `Product-safety components and listed use areas`
Transparency risk	`Disclosure duties for chatbots, synthetic content, deepfakes, emotion recognition`
Minimal risk	`No new obligations; voluntary codes encouraged` `Most AI, e.g. spam filters, games, inventory optimisation`

Prohibited practices (summarised)

PRACTICE	IN PLAIN WORDS
Harmful manipulation	Subliminal, purposely manipulative or deceptive techniques that materially distort behaviour and cause significant harm

Copyright © ZyeemZia

PRACTICE	IN PLAIN WORDS
Exploiting vulnerabilities	Exploiting age, disability or social or economic situation to distort behaviour harmfully
Social scoring	Evaluating people over time on social behaviour or traits, leading to unjustified or disproportionate detrimental treatment
Individual crime prediction	Predicting a person's risk of offending based solely on profiling or personality traits
Untargeted face scraping	Building facial recognition databases by untargeted scraping of internet or CCTV images
Emotion recognition at work and school	Inferring emotions in workplaces and education, except for medical or safety reasons
Sensitive biometric categorisation	Categorising people by biometrics to infer race, political opinions, union membership, religion, sex life or sexual orientation (with narrow law-enforcement exceptions for lawfully acquired data)
Real-time remote biometric identification by police	Live facial recognition in public spaces for law enforcement, except narrowly defined, authorised cases

Two routes to high risk

HR1

Safety component of regulated products

AI that is a product, or a safety component of a product, covered by listed EU product legislation (such as medical devices, machinery, toys, lifts) and requiring third-party conformity assessment.

HR2

Listed use areas (Annex III)

Biometrics; critical infrastructure; education and vocational training; employment and worker management; access to essential private and public services (such as credit scoring, public benefits, life and health insurance pricing, emergency triage); law enforcement; migration, asylum and border control; administration of justice and democratic processes.

DEFINITION · THE HIGH-RISK FILTER

A system in a listed use area is **not** high-risk if it does not pose a significant risk of harm, for example because it performs a narrow procedural task, improves the result of work a human has already completed, detects patterns in past decisions without replacing human assessment, or does preparatory work. However, a listed system that **profiles individuals** is always high-risk. A provider relying on this filter must document its assessment.

Classify these examples

SYSTEM	LIKELY TIER	REASON
CV-ranking tool used by employers in the EU	High risk	Employment: recruitment and selection
Credit-scoring model for consumer loans in the EU	High risk	Access to essential private services (creditworthiness), unless used only for fraud detection
Customer-service chatbot for an online shop	Transparency	People must be told they are interacting with AI

Copyright © ZyeemZia

SYSTEM	LIKELY TIER	REASON
Emotion detection on call-centre staff to rate their attitude	Prohibited	Emotion recognition in the workplace without medical or safety reason
AI that sorts incoming invoices by supplier	Minimal	No listed use area, low impact
Image generator used to create marketing visuals	Transparency	Synthetic content must be machine-readably marked; deepfakes disclosed

EXAMPLE · GENERAL-PURPOSE AI MODELS: A SEPARATE TRACK

Large models that can perform a wide range of tasks (general-purpose AI models) have their own obligations, which apply to the **model provider** regardless of how the model is later used. Models trained with very large amounts of compute (a presumption threshold of 10^25 floating-point operations) or designated by the Commission are treated as having **systemic risk** and carry extra duties. A system built on such a model is then classified by its own use.

SCENARIO · DECIDE · CLASSIFY THE SYSTEM

A Bangladeshi HR-tech company sells a tool to employers in Ireland that analyses video interviews and scores candidates' 'enthusiasm' from facial expressions to rank them for shortlisting. How should the governance lead classify it under the EU AI Act?

(A) Minimal risk, because the employer makes the final hiring decision.

(B) Transparency risk only, because candidates are told AI is used.

(C) At least high-risk as a recruitment tool, and the emotion-inference element is likely to fall within the workplace emotion-recognition prohibition; seek legal advice and redesign.

(D) Out of scope, because the company is based in Bangladesh.

Circle your choice. Answer and feedback: module answer key.

Key terms

EU AI Act
Regulation (EU) 2024/1689, the European Union's horizontal, risk-based law on AI systems and general-purpose AI models.

High-risk AI system
Under the EU AI Act, an AI system that is a regulated product safety component or falls in a listed use area and poses significant risk.

General-purpose AI model
A model trained on broad data that can competently perform a wide range of distinct tasks and be integrated into many systems.

Profiling
Automated processing of personal data to evaluate or predict aspects of a person, such as performance, behaviour or reliability.

Prohibited AI practice
A use of AI banned under the EU AI Act because of unacceptable risk, such as social scoring.

Annex III
The EU AI Act's list of use areas, such as employment and credit scoring, in which AI systems are presumed high-risk.

Systemic risk (GPAI)
Under the EU AI Act, risk from the most capable general-purpose models, presumed above a training-compute threshold or designated by the Commission.

Emotion recognition system
An AI system that identifies or infers emotions or intentions from biometric data.

KNOWLEDGE CHECK

6. When did the EU AI Act's prohibitions on certain AI practices start to apply?

(A) 1 January 2024
(B) 2 August 2027
(C) 2 February 2025
(D) They have not yet applied

Copyright © ZyeemZia

7. Which use is listed as a high-risk area?
   - (A) Evaluating creditworthiness of individuals
   - (B) Filtering spam email
   - (C) Recommending songs
   - (D) Optimising warehouse stock

8. A listed-area system performs only a narrow procedural task and does not profile people. It may:
   - (A) Automatically be prohibited
   - (B) Need no documentation at all
   - (C) Fall outside high risk if the provider documents that assessment
   - (D) Become a general-purpose model

9. A company outside the EU sells an AI system whose outputs are used in the EU. The Act:
   - (A) Never applies
   - (B) Applies only to its EU customers
   - (C) Applies only if it has EU staff
   - (D) Can apply to it

10. Emotion recognition used to assess employees' attitudes at work is:
    - (A) Minimal risk
    - (B) A prohibited practice unless for medical or safety reasons
    - (C) Only a transparency issue
    - (D) Unregulated

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 3 · REGULATION · LESSON 3 · 35 MIN

The EU AI Act: Obligations, Timeline and Enforcement

What providers, deployers and model providers must actually do

- Summarise provider obligations for high-risk AI systems
- Summarise deployer obligations, including fundamental rights impact assessments
- Describe obligations for general-purpose AI models and transparency duties
- Set out the application timeline, enforcement bodies and penalty levels

Classification tells you **which** rules apply; this lesson covers **what** they require. The heaviest duties fall on providers of high-risk systems, but deployers have real obligations too, and every organisation using AI in the EU must address AI literacy. Map each obligation to an owner, a control and evidence, because that is what a market surveillance authority will ask to see.

WATCH OUT · NOT LEGAL ADVICE

This module summarises laws, regulations and standards **in our own words, as of 2026**, for learning purposes. It is not legal advice. Rules are amended, guidance and court decisions change how they apply, and the answer always depends on the facts. Read the official texts and involve qualified legal counsel before relying on any interpretation.

Provider requirements for high-risk AI systems

P1
Risk management system
A continuous, documented process to identify, evaluate and reduce risks across the lifecycle.

P2
Data and data governance
Training, validation and test data that are relevant, sufficiently representative and examined for bias.

P3
Technical documentation
Detailed documentation showing how the system meets requirements, kept up to date.

P4
Record-keeping
Automatic logging of events to support traceability and monitoring.

P5
Transparency to deployers
Clear instructions for use covering purpose, performance, limits and oversight.

P6
Human oversight
Design that allows effective oversight by people, including the ability to stop the system.

P7
Accuracy, robustness, cybersecurity
Appropriate, declared levels of performance and resilience against errors and attacks.

P8
Quality management system
Policies and procedures covering design, testing, data, post-market monitoring and incidents.

P9
Conformity and registration
Conformity assessment, EU declaration of conformity, CE marking and registration in the EU database before market placement.

P10
Post-market duties
Post-market monitoring, corrective action and reporting of serious incidents to authorities.

Copyright © ZyeemZia

Deployer obligations for high-risk systems (summarised)

OBLIGATION	WHAT IT MEANS IN PRACTICE
Use as instructed	Follow the provider's instructions for use with appropriate technical and organisational measures
Human oversight	Assign oversight to people with the competence, training, authority and support needed
Input data	Where the deployer controls input data, ensure it is relevant and sufficiently representative
Monitoring and reporting	Monitor operation, inform the provider and authorities of risks and serious incidents, and suspend use where necessary
Logs	Keep automatically generated logs under its control for at least six months, unless other law says otherwise
Workers	Inform workers' representatives and affected workers before using high-risk AI in the workplace
Affected people	Inform people when a high-risk system is used to make or assist decisions about them; individuals can request an explanation of significant decisions
Fundamental rights impact assessment	Required before first use for public bodies, private entities providing public services, and deployers of credit-scoring and life or health insurance pricing systems

> **INSIGHT · DEPLOYERS CAN BECOME PROVIDERS**
> A deployer that puts its own name or trademark on a high-risk system, makes a substantial modification, or changes the intended purpose of a system so that it becomes high-risk is treated as a provider for that system, with the full set of provider obligations.

Transparency duties for certain AI systems

- Systems that interact directly with people must tell them they are dealing with AI, unless obvious.
- Providers of systems generating synthetic audio, images, video or text must mark outputs in a machine-readable way as artificially generated.
- Deployers of emotion recognition or biometric categorisation must inform the people exposed.
- Deployers of deepfakes must disclose that content is artificially generated or manipulated.
- AI-generated text published to inform the public on matters of public interest must be disclosed, unless it has undergone human editorial review with editorial responsibility.

General-purpose AI model obligations (summarised)

ALL GPAI MODEL PROVIDERS	ADDITIONAL DUTIES FOR MODELS WITH SYSTEMIC RISK
Technical documentation for the AI Office and authorities	Model evaluation, including adversarial testing
Information and documentation for downstream providers	Assessment and mitigation of possible systemic risks
A policy to comply with EU copyright law, including rights reservations	Tracking and reporting serious incidents
A public summary of the content used for training, using the official template	Adequate cybersecurity for the model and its infrastructure

A voluntary **General-Purpose AI Code of Practice**, published in July 2025, offers model providers a way to demonstrate compliance with these duties on transparency, copyright and safety and security. Many major model

Copyright © ZyeemZia

providers signed it. For deployers, this matters in procurement: ask suppliers whether their model provider follows the code and request the documentation the Act requires them to pass downstream.

Application timeline (as legislated; check for amendments)

01
1 Aug 2024
Entry into force

→

02
2 Feb 2025
Prohibitions and AI literacy apply

→

03
2 Aug 2025
GPAI model obligations, governance bodies and penalties apply

→

04
2 Aug 2026
Most remaining provisions, including Annex III high-risk and transparency duties

→

05
2 Aug 2027
High-risk rules for AI in regulated products; deadline for GPAI models placed on the market before August 2025

WATCH OUT · DATES MAY MOVE: CHECK THE CURRENT TEXT

Because harmonised standards and guidance were running late, the European Commission proposed a 'digital omnibus' package in November 2025 that would postpone high-risk obligations, linking them to the availability of support tools, with backstop dates of December 2027 for listed use areas and August 2028 for regulated products. Always confirm which dates apply in the version of the law in force when you read this.

Enforcement and penalties (maximum levels)

BREACH	MAXIMUM FINE
Prohibited practices	EUR 35 million or 7% of worldwide annual turnover, whichever is higher
Most other obligations, including high-risk requirements and transparency	EUR 15 million or 3% of worldwide annual turnover, whichever is higher
Supplying incorrect, incomplete or misleading information to authorities	EUR 7.5 million or 1% of worldwide annual turnover, whichever is higher
Small and medium-sized enterprises and start-ups	The lower of the two amounts in each band

Who enforces

- **National market surveillance authorities** supervise AI systems in each member state.
- The **AI Office** within the European Commission supervises general-purpose AI models.
- The **European AI Board**, a scientific panel and an advisory forum support consistent application.
- Existing regulators, such as financial supervisors, often act as authorities for AI in their sector.

TEMPLATE

EU AI Act obligation map

Map each applicable obligation to an owner, a control and the evidence you will keep.

SYSTEM AND ROLE	OBLIGATION	CONTROL	OWNER	EVIDENCE	DUE DATE
Credit model, deployer	*Fundamental rights impact assessment before first use*	*FRIA procedure using assessment template*	*Head of Compliance*	*Signed FRIA and notification to authority*	*Before go-live*

Copyright © ZyeemZia

SYSTEM AND ROLE	OBLIGATION	CONTROL	OWNER	EVIDENCE	DUE DATE
Credit model, deployer	*Keep logs at least six months*	*Log retention setting and backup*	*Head of IT Operations*	*Retention configuration and quarterly check*	*Before go-live*

SCENARIO · DECIDE · A DEPLOYER'S TO-DO LIST

A bank in Lithuania will use a vendor's high-risk credit-scoring system from next quarter. The vendor has completed conformity assessment. What must the bank do before first use?

(A) Nothing, because the vendor as provider holds all the obligations.

(B) Carry out a fundamental rights impact assessment, assign trained human oversight, set up log retention and monitoring, and prepare notices for affected customers.

(C) Repeat the vendor's conformity assessment in full.

(D) Register the system as a new general-purpose AI model.

Circle your choice. Answer and feedback: module answer key.

Key terms

Conformity assessment
The process of demonstrating that a high-risk AI system meets the EU AI Act's requirements before market placement.

Fundamental rights impact assessment (FRIA)
An assessment certain deployers of high-risk AI must perform before first use to identify impacts on people's rights.

Serious incident
Under the EU AI Act, an incident leading to death or serious harm to health, serious disruption of critical infrastructure, infringement of fundamental-rights obligations or serious harm to property or the environment.

Market surveillance authority
A national authority that monitors and enforces compliance of products, including AI systems, on the market.

CE marking
The marking showing a product conforms with applicable EU requirements, including for high-risk AI systems.

Post-market monitoring
A provider's systematic collection and review of data on a system's performance after it is placed on the market.

AI Office
The European Commission body that supervises general-purpose AI models and supports implementation of the AI Act.

AI literacy
The skills, knowledge and understanding that allow people to deploy and use AI in an informed way and be aware of its risks.

KNOWLEDGE CHECK

Copyright © ZyeemZia

11. Which deployers must carry out a fundamental rights impact assessment before using a high-risk system?

(A) All companies using any chatbot
(B) Public bodies, private providers of public services, and deployers of credit-scoring or life and health insurance pricing systems
(C) Only providers of general-purpose models
(D) Only companies outside the EU

12. For how long must deployers keep automatically generated logs of a high-risk system, at minimum?

(A) At least six months, unless other law requires otherwise
(B) Seven days
(C) Ten years in every case
(D) No retention is required

13. What is the maximum fine level for prohibited practices?

(A) EUR 1 million flat
(B) 1% of EU turnover only
(C) EUR 35 million or 7% of worldwide annual turnover, whichever is higher
(D) There is no fine for prohibited practices

14. Which duty applies to all general-purpose AI model providers?

(A) Live facial recognition approval
(B) A fundamental rights impact assessment
(C) Registration as a deployer
(D) A public summary of training content and a copyright compliance policy

15. Who supervises general-purpose AI models under the Act?

(A) The AI Office in the European Commission
(B) Each company's internal auditor
(C) The OECD
(D) National data protection authorities only

16. A deployer substantially modifies a high-risk system and rebrands it. What follows?

(A) Nothing changes
(B) It is treated as a provider with provider obligations
(C) The original provider loses all duties retroactively
(D) The system becomes minimal risk

☐ Lesson complete · Date _____ · Knowledge check score ____ / 6

Copyright © ZyeemZia

MODULE 3 · REGULATION · LESSON 4 · 35 MIN

Frameworks and Standards: NIST AI RMF, ISO/IEC 42001 and OECD

Voluntary and certifiable tools that structure a governance programme

- Describe the structure of the NIST AI Risk Management Framework and its generative-AI profile
- Explain what ISO/IEC 42001 requires and what certification does and does not prove
- Summarise the OECD AI Principles and related international instruments
- Choose and combine frameworks for a given organisation

Laws tell you what outcomes are required; frameworks and standards tell you **how to organise the work**. Three instruments dominate AI governance practice in 2026: the US National Institute of Standards and Technology's AI Risk Management Framework, the international management system standard ISO/IEC 42001 and the OECD AI Principles. They overlap heavily and can be combined into one programme.

WATCH OUT · NOT LEGAL ADVICE

This module summarises laws, regulations and standards **in our own words, as of 2026**, for learning purposes. It is not legal advice. Rules are amended, guidance and court decisions change how they apply, and the answer always depends on the facts. Read the official texts and involve qualified legal counsel before relying on any interpretation.

NIST AI RMF 1.0: four functions

GV

Govern

A cross-cutting function: culture, policies, roles, accountability, workforce diversity, third-party oversight and processes for engaging affected people.

MP

Map

Establish context: intended purpose, users, affected people, laws, benefits, and the risks and impacts of the system.

MS

Measure

Analyse and track risks with quantitative and qualitative methods, test trustworthiness characteristics and gather feedback.

MG

Manage

Prioritise and treat risks, plan responses and recovery, manage third-party risks and communicate about incidents.

NIST's characteristics of trustworthy AI

- Valid and reliable (the foundation for the others)
- Safe
- Secure and resilient
- Accountable and transparent
- Explainable and interpretable
- Privacy-enhanced
- Fair, with harmful bias managed

Copyright © ZyeemZia

EXAMPLE · THE GENERATIVE-AI PROFILE

In July 2024 NIST published a profile applying the framework to generative AI. It lists risks that are new or worse with generative AI, including confabulation, harmful bias and homogenisation, information integrity, information security, intellectual property, data privacy, dangerous or violent content, obscene or abusive content, environmental impacts, human-AI configuration, value-chain and component integration, and chemical, biological, radiological and nuclear information. It then suggests actions mapped to the four functions. The framework is voluntary; US federal policy changed direction in 2025 and revisions to NIST materials have been signalled, so check the current versions.

ISO/IEC 42001:2023 at a glance (top layer first)

Improvement (clause 10)	`Nonconformity, corrective action, continual improvement`
Performance evaluation (clause 9)	`Monitoring, internal audit, management review`
Operation (clause 8)	`Operational planning, AI risk assessment and treatment, AI system impact assessment`
Support (clause 7)	`Resources, competence, awareness, communication, documented information`
Planning (clause 6)	`Risks and opportunities, AI objectives, Statement of Applicability`
Leadership and context (clauses 4–5)	`Scope, interested parties, AI policy, roles and top-management commitment`

ISO/IEC 42001 is a **management system standard**: it specifies how an organisation should establish, run and improve an AI management system (AIMS), using the same high-level structure as other management system standards such as those for information security and quality. Its Annex A lists reference control objectives and controls, covering areas such as AI policies, internal organisation, resources, impact assessment, the AI system lifecycle, data, information for interested parties, use of AI systems and third-party relationships. Organisations select controls and justify inclusions and exclusions in a **Statement of Applicability**. Companion standards cover AI risk management guidance (ISO/IEC 23894), AI system impact assessment (ISO/IEC 42005), requirements for certification bodies (ISO/IEC 42006), concepts and terminology (ISO/IEC 22989) and governance implications for boards (ISO/IEC 38507).

WATCH OUT · CERTIFICATION IS NOT COMPLIANCE

An ISO/IEC 42001 certificate shows that an accredited auditor found your management system conforms to the standard within the certified scope. It does **not** prove that every AI system is lawful, fair or safe, and it does not by itself satisfy the EU AI Act. Check the scope statement on any supplier's certificate.

Copyright © ZyeemZia

OECD AI Principles (adopted 2019, updated 2024)

01

Inclusive growth, sustainable development and well-being

AI should benefit people and the planet.

02

Human rights and democratic values, including fairness and privacy

Respect the rule of law, human rights and democratic values throughout the lifecycle.

03

Transparency and explainability

Provide meaningful information so people understand and can challenge outcomes.

04

Robustness, security and safety

Systems should function appropriately and safely, with mechanisms to override or decommission them.

05

Accountability

AI actors should be accountable for proper functioning, based on their roles and the context.

The OECD also makes five recommendations to governments: invest in AI research and development, foster an inclusive AI ecosystem, enable an interoperable governance and policy environment, build human capacity and prepare for labour-market change, and cooperate internationally. Its definition of an AI system, updated in 2023, influenced the EU AI Act. Other international instruments include UNESCO's 2021 Recommendation on the Ethics of AI, the G7 Hiroshima Process code of conduct for advanced AI developers and the Council of Europe's Framework Convention on AI, human rights, democracy and the rule of law, opened for signature in 2024 as the first binding international treaty on AI.

How the main instruments compare

INSTRUMENT	NATURE	BEST USED FOR	CAN YOU CERTIFY?
EU AI Act	Binding law (EU market)	Legal obligations by role and risk tier	Conformity assessment for high-risk systems
NIST AI RMF	Voluntary framework	Risk vocabulary, functions and practical actions	No
ISO/IEC 42001	International management system standard	Building and evidencing an organisation-wide AIMS	Yes, by accredited certification bodies
OECD AI Principles	Intergovernmental recommendation	Values, policy alignment, shared definitions	No

Copyright © ZyeemZia

SCENARIO · DECIDE · CHOOSING A BACKBONE

A South Asian software exporter builds AI features for clients in Europe and the United States. Clients increasingly ask for evidence of responsible AI in tenders. Leadership wants one approach that is recognised internationally and can be independently verified. What should the governance lead recommend?

(A) Adopt the OECD principles only, because they are the most widely endorsed.

(B) Build an AI management system aligned to ISO/IEC 42001, use NIST AI RMF practices inside it for risk work, and map EU AI Act obligations for products sold in Europe.

(C) Wait for each client to specify its own framework.

(D) Write a proprietary framework so the company is not tied to any standard.

Circle your choice. Answer and feedback: module answer key.

Key terms

NIST AI RMF
The voluntary US AI Risk Management Framework organised into Govern, Map, Measure and Manage functions.

AI management system (AIMS)
The policies, processes, roles and controls an organisation uses to direct and control its AI activities, as specified by ISO/IEC 42001.

Statement of Applicability
A document listing which controls an organisation has selected, why, and the justification for exclusions.

Profile (NIST)
An application of the AI RMF to a specific setting, technology or use case, such as generative AI.

Govern function
The cross-cutting NIST AI RMF function that sets culture, policies, roles and accountability for AI risk.

ISO/IEC 42001
The international, certifiable management system standard for AI, published in 2023.

OECD AI Principles
Intergovernmental principles for trustworthy AI adopted in 2019 and updated in 2024.

Framework Convention on AI
The Council of Europe's binding international treaty on AI, human rights, democracy and the rule of law, opened for signature in 2024.

KNOWLEDGE CHECK

17. Which NIST AI RMF function is cross-cutting and covers culture, policies and accountability?

(A) Govern
(B) Map
(C) Measure
(D) Manage

18. What does an ISO/IEC 42001 certificate demonstrate?

(A) That every AI system is legally compliant everywhere
(B) That the organisation's AI management system conforms to the standard within the certified scope
(C) That the EU AI Act no longer applies
(D) That models are free of bias

19. In which ISO/IEC 42001 document does an organisation justify the controls it selects or excludes?

(A) Statement of Applicability
(B) Model card
(C) Privacy notice
(D) Incident log

20. Which statement about the OECD AI Principles is correct?

(A) They are a binding EU regulation
(B) They can be certified by auditors
(C) They are an intergovernmental recommendation, updated in 2024
(D) They apply only to the United States

21. Which pairing gives verifiable structure plus practical risk methods?

(A) OECD principles with a marketing pledge
(B) A proprietary checklist with no audit
(C) No framework, only legal review
(D) ISO/IEC 42001 with NIST AI RMF practices

Copyright © ZyeemZia

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 3 · REGULATION · LESSON 5 · 30 MIN

South Asia and Emerging Rules Worldwide

India, Bangladesh, Pakistan, Sri Lanka, Nepal and the wider picture, as of 2026

- Summarise the direction of AI governance in South Asian countries as of 2026
- Recognise major AI rules elsewhere that affect South Asian organisations
- Run a horizon-scanning process to keep regulatory knowledge current

South Asia is moving from national AI strategies towards concrete rules, but mostly through **data protection laws, sector regulators and principles-based guidance** rather than comprehensive AI acts. Organisations in the region also feel foreign rules directly when they export software, serve foreign customers or use global model providers. The summary below reflects our understanding as of 2026; this area changes fast, so treat it as a starting map and verify current status before acting.

WATCH OUT · NOT LEGAL ADVICE

This module summarises laws, regulations and standards **in our own words, as of 2026**, for learning purposes. It is not legal advice. Rules are amended, guidance and court decisions change how they apply, and the answer always depends on the facts. Read the official texts and involve qualified legal counsel before relying on any interpretation.

South Asia: direction of travel (as of 2026)

COUNTRY	KEY INSTRUMENTS	APPROACH
India	Digital Personal Data Protection Act 2023 with Rules notified in November 2025 and phased in; India AI Governance Guidelines released in November 2025; IT intermediary rule changes on labelling synthetic content; sector frameworks such as the Reserve Bank of India's 2025 framework for responsible AI in finance	Principles-based, relying on existing laws and sector regulators rather than a standalone AI act, with new institutions to coordinate governance and AI safety
Bangladesh	Draft national AI policy documents (2024-2025); ordinances in 2025 on cyber security and on personal data protection; ICT Act 2006; Bangladesh Bank and BTRC sector rules	Building foundations: data protection and cyber security first, AI policy emerging; check gazetted texts and commencement dates
Pakistan	National AI Policy approved in 2025; personal data protection legislation under development	Strategy- and capacity-led, with data protection still pending
Sri Lanka	Personal Data Protection Act No. 9 of 2022, amended and being phased in; national AI strategy work	Data protection as the main legal hook for AI
Nepal	National AI policy adopted in 2025; Privacy Act 2018	Early-stage policy framework

INSIGHT · WHAT THIS MEANS FOR A SOUTH ASIAN ORGANISATION

Even without an AI act, you will be judged on data protection, consumer, cyber security, employment and sector rules, and on whether you followed recognised good practice. Building to international frameworks now usually satisfies most of what national rules will later require, and it opens export markets.

Copyright © ZyeemZia

Other rules that often reach South Asian organisations

JURISDICTION	INSTRUMENT (AS OF 2026)	WHY IT MATTERS
European Union	AI Act; GDPR	Applies to exporters placing AI on the EU market or whose outputs are used there
China	Rules on recommendation algorithms (2022), deep synthesis (2023), generative AI services (2023) and mandatory labelling of AI-generated content (from September 2025)	Labelling and content rules for services offered in China
South Korea	AI Basic Act, in force from January 2026	Duties for high-impact and generative AI, including transparency and, for some foreign firms, a local representative
Japan	AI Promotion Act (2025)	Promotion-oriented, light-touch law with government guidance
United Kingdom	Principles applied by existing regulators; AI Security Institute	Sector regulators expect fairness, transparency and accountability
United States	No comprehensive federal AI law; state laws such as New York City's bias-audit rule for hiring tools, Colorado's high-risk AI act (scheduled for 2026), Texas and California laws; federal moves since late 2025 to challenge state rules	Patchwork that changes quickly, especially in hiring, insurance and frontier models

Horizon scanning: keeping current

1. **Name an owner** Assign a person in legal or compliance to own AI regulatory monitoring.
2. **Define sources** Official gazettes, regulator websites, standards bodies, law-firm briefings and industry associations.
3. **Set a rhythm** Monthly scan, quarterly summary to the AI governance committee.
4. **Assess impact** For each change, record affected systems, obligations and dates in the applicability map.
5. **Plan action** Create tasks with owners and deadlines, and update policies and controls.
6. **Record decisions** Keep evidence of how the organisation interpreted and responded to each change.

TEMPLATE

Regulatory horizon-scanning log

Track AI-relevant legal and standards changes and the organisation's response.

DATE FOUND	JURISDICTION AND INSTRUMENT	STATUS	SYSTEMS AFFECTED	IMPACT SUMMARY	ACTION AND OWNER
Feb 2026	*South Korea AI Basic Act*	*In force from Jan 2026*	*Chatbot offered to Korean customers*	*Transparency notice for generative AI outputs*	*Update chatbot disclosure; Product Lead*
Nov 2025	*India DPDP Rules*	*Notified, phased commencement*	*HR analytics on Indian staff*	*Consent, notice and breach duties apply in phases*	*Gap assessment; Privacy Officer*

Copyright © ZyeemZia

DATE FOUND	JURISDICTION AND INSTRUMENT	STATUS	SYSTEMS AFFECTED	IMPACT SUMMARY	ACTION AND OWNER

CASE STUDY · THE DHAKA SOFTWARE EXPORTER

A Dhaka company builds an AI tool that scores insurance claims for fraud and sells it to insurers in Bangladesh, India and Ireland. It uses a general-purpose model from an international provider for document reading. The founders assumed that because Bangladesh has no AI act, governance could wait.

1. Which regimes are likely to touch this business?

2. What role does the company play under the EU AI Act?

3. What should it prioritise in the next six months?

Model answer: module answer key.

SCENARIO · DECIDE · A NEW RULE APPEARS

A privacy officer at a Bangladeshi mobile financial services provider reads that a new data protection ordinance has been approved. Some colleagues say nothing changes until detailed rules arrive. What should she do FIRST?

(A) Wait for the detailed rules, because ordinances need regulations to work.

(B) Obtain the official text, confirm commencement dates, assess which AI and data uses are affected, and brief the governance committee with a gap plan.

(C) Rely on a news article's summary to update the privacy policy immediately.

(D) Stop all AI projects until the law is fully understood.

Circle your choice. Answer and feedback: module answer key.

REFLECT

Which foreign AI rule is most likely to affect your organisation in the next two years, through customers, suppliers or markets? What would be the first obligation you would need to meet?

Copyright © ZyeemZia

Key terms

DPDP Act
India's Digital Personal Data Protection Act 2023, implemented through Rules notified in 2025 and phased in.

Horizon scanning
A structured, continuing process to identify and assess upcoming legal, regulatory and standards changes.

Synthetic content labelling
Requirements to mark or disclose content generated or manipulated by AI.

Sector regulator
A regulator responsible for one industry, such as a central bank or telecoms authority, that often sets AI expectations for that sector.

Ordinance (Bangladesh)
A law made by the President when Parliament is not in session, with legal force subject to later parliamentary processes.

AI Basic Act (South Korea)
South Korea's framework law on AI development and trust, in force from January 2026, with duties for high-impact and generative AI.

Principles-based regulation
An approach that sets high-level outcomes and relies on regulators and organisations to apply them in context.

KNOWLEDGE CHECK

22. Which best describes India's approach to AI governance as of 2026?
    - (A) Principles-based guidelines relying on existing laws and sector regulators, rather than a standalone AI act
    - (B) A comprehensive AI act copied from the EU
    - (C) A total ban on generative AI
    - (D) No rules of any kind

23. For most South Asian organisations today, the main legal hooks for AI are:
    - (A) Only the EU AI Act
    - (B) Only UNESCO recommendations
    - (C) Only tax law
    - (D) Data protection, cyber security, consumer and sector rules

24. Which law came into force in January 2026 with duties for high-impact and generative AI?
    - (A) Japan's AI Promotion Act
    - (B) South Korea's AI Basic Act
    - (C) The OECD AI Principles
    - (D) ISO/IEC 42001

25. What is the first step when a new AI-relevant law is announced?
    - (A) Update policies from a news summary
    - (B) Stop all AI projects
    - (C) Obtain the official text and confirm commencement dates
    - (D) Ignore it until a regulator calls

26. Why build to international frameworks even where no AI act exists?
    - (A) They exempt you from local law
    - (B) They are legally binding everywhere
    - (C) They remove the need for legal advice
    - (D) They prepare for likely future rules and support exports and tenders

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 3 · REGULATION

Answer key

Knowledge checks

1. B AI is governed by existing general and sector law even without an AI-specific statute.

2. D Guidance is non-binding but shapes expectations and enforcement.

3. D Extraterritorial scope attaches to market placement and use, not just location of the company.

4. A The EU AI Act applies across sectors with tiered obligations.

5. C Even without legal force, frameworks become benchmarks for reasonable conduct.

6. C The Act entered into force on 1 August 2024; prohibitions and AI-literacy duties applied from 2 February 2025.

7. A Credit scoring falls within access to essential private services.

8. C The filter allows non-significant-risk systems out of high risk, but the reasoning must be documented and profiling systems stay high-risk.

9. D Scope extends to providers placing systems on the EU market and to cases where outputs are used in the EU.

10. B Workplace and education emotion recognition is banned with narrow medical and safety exceptions.

11. B The FRIA duty targets specific deployer categories where rights impacts are significant.

12. A The Act sets a six-month minimum for deployers, subject to other applicable law.

13. C Prohibited practices carry the highest penalty band.

14. D GPAI providers must document their models, support downstream providers, follow copyright law and publish a training-content summary.

15. A The AI Office has supervisory responsibility for GPAI models.

16. B Rebranding or substantial modification shifts provider obligations to the modifying party.

17. A Govern underpins the other three functions.

18. B Certification evaluates the management system, not the lawfulness of every system.

19. A The Statement of Applicability records control selection and justification.

20. C The OECD principles are non-binding and widely adopted.

21. D The two instruments complement each other and are often combined.

22. A India's 2025 guidelines favour existing laws, sector regulators and new coordinating institutions.

23. D Without AI acts, general and sector laws carry most obligations, and some foreign laws apply through markets.

24. B South Korea's framework act took effect in January 2026.

25. C Accurate source text and dates are the basis for any impact assessment.

26. D International alignment is efficient preparation and a commercial asset, but does not replace local law.

Scenarios & case studies

> **Scenario · Where to start**
> **C** is best. Best. Applicability depends on each system and its context. Mapping per system, then aligning to a framework, gives a defensible basis.

> **Scenario · Classify the system**
> **C** is best. Best. Recruitment ranking is a listed high-risk use, and inferring emotions in an employment context is likely prohibited. The company, as provider, must act before selling in the EU.

> **Scenario · A deployer's to-do list**
> **B** is best. Best. These are core deployer duties for a high-risk credit system, and the FRIA is required before first use.

> **Scenario · Choosing a backbone**
> **B** is best. Best. The certifiable standard provides verifiable structure; the NIST framework adds practical risk methods; and the legal map covers binding duties.

Copyright © ZyeemZia

Case study · The Dhaka software exporter

In Bangladesh, data protection and cyber security ordinances and insurance regulation apply; in India, the DPDP Act and Rules and insurance-sector expectations apply to personal data of Indian policyholders; in Ireland, the EU AI Act and GDPR apply. Under the EU AI Act the company is the provider of the claims-scoring system. Fraud detection is generally not the listed credit-scoring use, but life and health insurance risk assessment and pricing is listed, so classification depends on exact functions, and the company must document its assessment. It is a downstream provider relying on a general-purpose model, so it should obtain the model provider's documentation. Priorities: an applicability map per market, EU AI Act classification with legal advice, data protection compliance per country, model documentation, bias and accuracy testing, and contract terms with the model provider. Alignment to ISO/IEC 42001 would support all three markets.

Scenario · A new rule appears

B is best. Best. Verifying the text and dates, then assessing impact on systems, is the disciplined horizon-scanning response.

Copyright © ZyeemZia

04

MODULE 4 · RISK

AI Risk Management and Impact Assessment

Identify, assess, treat and track AI risks to people and the organisation

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Identify AI risks using a taxonomy, lifecycle view and people-first techniques
- Score inherent and residual AI risk and avoid the traps of the risk matrix
- Conduct an integrated AI impact assessment covering privacy and fundamental rights
- Choose risk treatments, design controls and express AI risk appetite with tolerances and KRIs
- Run a proportionate intake and tiering process and maintain an AI risk register

LESSONS

1. Identifying AI Risks · 30 min
2. Assessing and Scoring AI Risk · 30 min
3. AI Impact Assessments · 35 min
4. Treating AI Risk: Controls and Risk Appetite · 30 min
5. Use-Case Intake, Tiering and the AI Risk Register · 30 min

MODULE 4 · RISK · LESSON 1 · 30 MIN

Identifying AI Risks

Sources, taxonomies and techniques for finding what could go wrong

- Define AI risk and distinguish risks to people from risks to the organisation
- Use a structured taxonomy to identify AI risks across the lifecycle
- Apply practical techniques such as pre-mortems and misuse cases

Risk is the effect of uncertainty on objectives. For AI, governance must look at two kinds of objectives at once: the **organisation's** (profit, compliance, reputation) and **people's** (rights, safety, wellbeing). A system can be profitable and still harmful, and a harm to people usually becomes a risk to the organisation later. Good AI risk identification therefore starts from the people affected, not just from the business case.

ZAIG AI risk taxonomy

CATEGORY	EXAMPLES	WHERE IT OFTEN STARTS
Performance	Inaccuracy, confabulation, poor generalisation, drift	Data, model choice, changing environment
Fairness	Discriminatory outcomes or error rates	Historical data, proxies, deployment context
Safety	Physical or psychological harm, unsafe advice	Health, transport, industrial and companion uses
Security	Poisoning, prompt injection, model theft, data leakage	Exposed interfaces, supply chain, excessive permissions
Privacy	Unlawful processing, re-identification, inference of sensitive traits	Training data, prompts, logs
Transparency and accountability	Unexplainable decisions, no route to contest, unclear ownership	Opaque models, vendor black boxes
Legal and compliance	Breach of AI, data, consumer, IP or sector law	Unassessed uses, new markets
Third party	Vendor failure, changed model, unclear terms	Procurement, API dependency
Societal and environmental	Disinformation, labour impact, energy use	Generative and large-scale systems

INSIGHT · RISKS TO PEOPLE COME FIRST

Ask 'who could be hurt, and how badly?' before 'what could this cost us?'. The first question finds risks the second misses, and regulators, courts and the public will judge you on the first.

Where risks enter the lifecycle

01 **Design** — Wrong problem, wrong objective, unsuitable use of AI

→ 02 **Data** — Bias, poor quality, unlawful collection

→ 03 **Build** — Weak evaluation, overfitting, insecure components

→ 04 **Deploy** — Misuse, poor oversight, wrong context

→ 05 **Operate** — Drift, attacks, vendor changes

→ 06 **Retire** — Orphaned data, unmanaged dependencies

Copyright © ZyeemZia

Techniques for finding AI risks

1. **Stakeholder mapping** List everyone affected, including people who never use the system, and ask how each could be harmed.
2. **Pre-mortem** Imagine it is a year later and the system has caused a public scandal. Ask the team to write the story of what happened.
3. **Misuse and abuse cases** Ask how a malicious user, a careless user or a well-meaning user in the wrong context could cause harm.
4. **Incident review** Search public AI incident databases and your own incident logs for similar systems.
5. **Consult affected groups** Talk to representatives of the people affected, such as patient groups, worker representatives or student unions.
6. **Expert challenge** Ask security, privacy, legal and domain experts to review the design.

EXAMPLE · A PRE-MORTEM AT A POWER UTILITY

A power distribution company in Bangladesh planned an AI model to predict electricity theft and prioritise inspections. In a pre-mortem, field staff wrote: 'The model sent inspectors mostly to poorer neighbourhoods where meters are older, so honest households were repeatedly inspected and fined for faulty meters.' This surfaced a fairness risk and a data-quality risk that the business case had missed.

Inherent characteristics that raise AI risk

System factors

- High autonomy or ability to act
- Opaque model
- Learns continuously in production
- Generative, open-ended outputs

Context factors

- Decisions about rights, money, health, liberty or work
- Vulnerable people affected
- Large scale
- Hard-to-reverse outcomes

SCENARIO · DECIDE · A NARROW RISK WORKSHOP

A team building an AI chatbot for a university admissions office runs a risk workshop. They list server downtime, cost overruns and slow response times. What should the governance lead add FIRST?

(A) A detailed cost-benefit analysis of the hosting options.

(B) A stakeholder-focused session on harms to applicants: wrong admission advice, unequal quality in Bangla and English, data privacy and the absence of a human contact.

(C) A penetration test of the website.

(D) A decision to cancel the chatbot because risks exist.

Circle your choice. Answer and feedback: module answer key.

Copyright © ZyeemZia

AI risk identification checklist

☐ Affected people and groups listed, including non-users
☐ Each taxonomy category considered
☐ Every lifecycle stage considered
☐ Misuse and abuse cases written
☐ Similar public incidents reviewed
☐ Affected groups or their representatives consulted for high-impact systems
☐ Third-party and supply-chain risks included
☐ Risks recorded in the AI risk register with an owner

REFLECT

Run a quick pre-mortem on an AI system you know: it is two years from now and the system is in the news for the wrong reasons. What is the headline, and which risk did everyone overlook?

Key terms

Risk
The effect of uncertainty on objectives, usually expressed through likelihood and consequence.

Pre-mortem
A technique in which a team imagines a future failure and works backwards to identify its causes.

Stakeholder mapping
Identifying everyone who affects or is affected by a system, including non-users.

Risk owner
The person accountable for managing a particular risk.

AI risk taxonomy
A structured list of AI risk categories used to identify risks consistently.

Misuse case
A scenario describing how a system could be used, deliberately or carelessly, to cause harm.

AI incident database
A public or internal collection of reported AI failures and harms used for learning.

KNOWLEDGE CHECK

1. Why should AI risk identification start from affected people?
   - (A) Because organisational risks do not matter
   - (B) It finds harms the business case misses, which later become organisational risks
   - (C) Because regulators ignore business impacts
   - (D) Because people-centred risks are always minor
2. Imagining that a project has already failed and explaining why is called:
   - (A) A pre-mortem
   - (B) A post-incident review
   - (C) A penetration test
   - (D) A conformity assessment
3. Which factor most raises the inherent risk of an AI system?
   - (A) It uses a modern programming language
   - (B) It runs on a cloud platform
   - (C) It has a friendly user interface
   - (D) It makes hard-to-reverse decisions about people's access to money or work

Copyright © ZyeemZia

4. A vendor silently updates the model behind an API. Which risk category is this?

(A) Environmental
(B) Interpretability only
(C) Third party
(D) Fairness only

5. Which technique specifically considers malicious or careless use?

(A) Cost-benefit analysis
(B) Misuse and abuse cases
(C) Load testing
(D) Annual budgeting

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 4 · RISK · LESSON 2 · 30 MIN

Assessing and Scoring AI Risk

Likelihood, impact, inherent and residual risk, and the limits of numbers

- Score AI risks using likelihood and impact scales tailored to AI harms
- Distinguish inherent and residual risk
- Use simple quantitative estimates where data allows
- Recognise the limits of risk scoring for AI

Once risks are identified, they must be compared so attention goes where it matters most. Most organisations use a **likelihood × impact** matrix, already familiar from enterprise risk management. For AI, the impact scale must capture harm to people, not just money, and must consider how many people are affected, how vulnerable they are and whether harm can be reversed.

Impact scale for AI risks (example)

SCORE	LEVEL	HARM TO PEOPLE	HARM TO ORGANISATION
1	Minimal	Minor inconvenience, easily corrected	Negligible cost, no external attention
2	Moderate	Temporary detriment to a few people, reversible	Small loss, local complaints
3	Significant	Material harm to many or serious harm to a few, reversible with effort	Regulatory inquiry, media coverage
4	Severe	Serious, hard-to-reverse harm to rights, health or livelihood	Enforcement, major loss, executive accountability
5	Critical	Loss of life, widespread or irreversible harm, especially to vulnerable groups	Existential, licence or market exit

Impact dimensions to consider

D1
Severity
How serious is the harm to each affected person?

D2
Scale
How many people could be affected?

D3
Reversibility
Can the harm be undone, and how quickly?

D4
Vulnerability
Are children, patients, low-income or marginalised people affected?

D5
Autonomy
Does the system act without human review?

D6
Detectability
Would anyone notice the harm quickly?

Useful risk formulas

MEASURE	FORMULA	WHAT IT TELLS YOU
Risk score	`Risk = Likelihood (1-5) × Impact (1-5)`	A simple ordinal score from 1 to 25 used to rank risks; treat it as a guide, not a measurement.
Residual risk (indicative)	`Residual ≈ Inherent × (1 − control effectiveness)`	Shows how much risk remains after controls; effectiveness must be evidenced, not assumed.

Copyright © ZyeemZia

MEASURE	FORMULA	WHAT IT TELLS YOU
Expected loss	`Expected loss = Probability of event × Cost if it occurs`	Converts a risk into money where data exists, e.g. for fraud models.
Annualised loss expectancy	`ALE = Annual rate of occurrence × Single loss expectancy`	Estimates yearly loss from repeated events such as chatbot errors leading to refunds.

EXAMPLE · SCORING A CHATBOT ERROR RISK

A telecom chatbot gives wrong tariff information in about 1 in 2,000 conversations. With 600,000 conversations a year, that is about 300 errors. If each costs BDT 1,500 in refunds and handling, the annualised loss expectancy is about BDT 450,000. But some errors involve vulnerable customers being charged for services they cannot afford, so the impact on people is scored 3, not 2, even though the money is modest.

Inherent vs residual risk

Inherent risk

- The level of risk before any controls
- Shows how dangerous the activity is in itself
- Drives the risk tier and the depth of assessment

Residual risk

- The level of risk remaining after controls
- Must be within risk appetite to proceed
- Changes when controls fail or conditions shift

Example heat-map placement

RISK	LIKELIHOOD	IMPACT	SCORE	PRIORITY
Credit model disadvantages rural women	4	4	16	High
Chatbot gives wrong tariff information	3	3	9	Medium
Prompt injection leaks customer records	2	5	10	High (impact-led)
Spam filter misroutes some newsletters	3	1	3	Low

WATCH OUT · DO NOT LET THE MATRIX HIDE CATASTROPHIC RISKS

Multiplying likelihood by impact can make a rare but catastrophic risk look the same as a frequent nuisance. Use an **impact override**: any risk with impact 5, or impact 4 on vulnerable people, is treated as high priority regardless of its likelihood score.

Limits of scoring AI risk

- Likelihood estimates for novel AI failures are often guesses; record the reasoning.
- Scores are ordinal: a 16 is not exactly twice as bad as an 8.
- Group biases in the scoring team can understate harms to people unlike themselves.
- Risks interact; one control failure can trigger several risks at once.
- Scores go stale as models, data and context change; rescore after significant changes.

Copyright © ZyeemZia

SCENARIO · DECIDE · TWO RISKS WITH THE SAME SCORE

A hospital AI triage tool has two risks scored 10: rare misclassification of chest pain as low urgency (likelihood 2, impact 5) and frequent minor delays in queue display (likelihood 5, impact 2). The budget allows one major mitigation this quarter. Which should get priority?

(A) Queue display delays, because they happen more often.

(B) Chest-pain misclassification, because it could cause death or irreversible harm and an impact override applies.

(C) Split the budget equally because the scores are equal.

(D) Neither, until more data is collected.

Circle your choice. Answer and feedback: module answer key.

Key terms

Likelihood
The chance that a risk event will occur within a defined period.

Impact
The consequence of a risk event for people and the organisation.

Inherent risk
The level of risk before controls are applied.

Residual risk
The level of risk remaining after controls are applied.

Heat map
A grid plotting risks by likelihood and impact to show priorities.

Impact override
A rule that treats severe-impact risks as high priority regardless of their likelihood score.

Annualised loss expectancy (ALE)
The expected yearly loss from a risk, calculated as annual rate of occurrence times single loss expectancy.

Reversibility
The degree to which a harm can be undone after it occurs.

KNOWLEDGE CHECK

6. A risk has likelihood 3 and impact 4. On a 1-25 matrix its score is:
   (A) 7 (B) 1
   (C) 12 (D) 34

7. Which risk level is used to decide whether a system can proceed within appetite?
   (A) Inherent risk (B) Gross revenue
   (C) Residual risk (D) Model size

8. An event happens about 4 times a year and costs BDT 200,000 each time. The ALE is:
   (A) BDT 800,000 (B) BDT 50,000
   (C) BDT 204,000 (D) BDT 200,000

9. Why use an impact override?
   (A) To make scores look lower for the board
   (B) So rare but catastrophic risks are not ranked as low priority
   (C) To avoid documenting likelihood
   (D) To replace control testing

10. Which dimension asks whether harm can be undone?
    (A) Scale (B) Detectability
    (C) Autonomy (D) Reversibility

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 4 · RISK · LESSON 3 · 35 MIN

AI Impact Assessments

Structured assessment of effects on people, rights and society before you deploy

- Distinguish AI impact assessments, data protection impact assessments and fundamental rights impact assessments
- Decide when an impact assessment is needed
- Conduct an AI impact assessment step by step, including stakeholder engagement

A risk register lists risks; an **impact assessment** tells the story of a specific system and its effects on people, in enough depth to support a go or no-go decision. Several kinds exist, often required by different laws or standards. A mature programme uses one integrated process that satisfies all of them, rather than making teams fill in three overlapping forms.

Types of impact assessment

ASSESSMENT	MAIN FOCUS	TYPICAL TRIGGER
AI impact assessment (AIIA)	Effects of an AI system on individuals, groups and society across all principles	Organisational policy; ISO/IEC 42001 expects AI system impact assessment
Data protection impact assessment (DPIA)	Risks to individuals from processing personal data	Data protection laws for high-risk processing, such as large-scale profiling
Fundamental rights impact assessment (FRIA)	Effects on fundamental rights of people affected by a high-risk AI system	EU AI Act for certain deployers before first use
Algorithmic impact assessment	Public-sector use of automated decision systems	Government directives in several countries
Human rights due diligence	Adverse human rights impacts across operations and value chain	Corporate responsibility frameworks and some laws

PRO TIP · ONE ASSESSMENT, MANY PURPOSES

Design a single AI impact assessment template with modules: a core section for every assessed system, a privacy module that meets DPIA requirements, and a rights module that meets FRIA requirements where the EU AI Act applies. ISO/IEC 42005 offers guidance on structuring AI system impact assessments.

When to require a full impact assessment

- The system is high-risk under law or your own tiering.
- It makes or materially influences decisions about access to work, credit, education, health, housing, benefits or justice.
- It processes sensitive personal data or profiles people at scale.
- It affects children or other vulnerable groups.
- It is novel, opaque or highly autonomous.
- It is a substantial change to a system already assessed.

Copyright © ZyeemZia

Conducting an AI impact assessment

1. **Describe the system** Purpose, intended users, affected people, data, model, outputs, decisions influenced and deployment context.
2. **Establish necessity and proportionality** Why AI? Is there a less intrusive way to achieve the goal?
3. **Engage stakeholders** Consult affected groups or their representatives, frontline staff and experts.
4. **Identify impacts** Across fairness, privacy, safety, autonomy, transparency, rights and society, both positive and negative.
5. **Evaluate severity and likelihood** Use the risk scales, with attention to vulnerable groups.
6. **Define mitigations** Design, data, testing, oversight, transparency and redress measures, with owners.
7. **Decide and sign off** Accountable owner and, for high risk, the AI governance committee approve, approve with conditions or reject.
8. **Review** Revisit after launch, after changes and at a set interval.

> **INSIGHT · NECESSITY IS THE QUESTION TEAMS SKIP**
> The most valuable question in an impact assessment is often 'should we use AI here at all?'. A well-designed form, a clear rule or better staff training sometimes achieves the goal with less risk.

TEMPLATE AI impact assessment summary

Summarise the key findings of an AI impact assessment for decision-makers.

IMPACT AREA	AFFECTED PEOPLE	POTENTIAL IMPACT	SEVERITY AND LIKELIHOOD	MITIGATION AND OWNER	RESIDUAL LEVEL
Fairness	*Female and rural loan applicants*	*Lower approval rates due to sparse credit history*	*Severe / likely*	*Alternative data review, fairness threshold, human review of refusals; Head of Credit Risk*	*Medium*
Contestability	*All refused applicants*	*No way to challenge automated refusals*	*Significant / likely*	*Refusal notice with reasons and appeal route; Head of Customer Service*	*Low*

CASE STUDY · AN EXAM-PROCTORING PROPOSAL

A university in Dhaka proposes AI-based remote exam proctoring that uses webcams to flag 'suspicious' eye movements and background noise. Students would be automatically marked for review, and repeated flags could

Copyright © ZyeemZia

lead to disciplinary hearings. Many students take exams from shared rooms in crowded homes, and some have disabilities affecting eye movement.

1. Which impacts would an impact assessment identify?

2. Is the use necessary and proportionate?

3. What decision would you recommend?

Model answer: module answer key.

SCENARIO · DECIDE · ASSESSMENT AFTER THE FACT

A bank's digital team launched an AI system that sets credit-card limits. Three months later, compliance discovers that no impact assessment was done. What should happen NOW?

(A) Shut the system down permanently.

(B) Complete an urgent impact assessment, review outcomes so far for harm, apply interim safeguards such as human review of reductions, and record the process failure.

(C) Backdate an assessment to the launch date.

(D) Do nothing, because no complaints have been received.

Circle your choice. Answer and feedback: module answer key.

REFLECT

Pick an AI system you know. In one paragraph, argue that AI is necessary and proportionate for its purpose. Then argue the opposite. Which argument is stronger?

Key terms

AI impact assessment (AIIA)
A structured evaluation of an AI system's potential effects on individuals, groups and society, used to decide whether and how to deploy it.

Necessity and proportionality
Tests of whether AI is needed to achieve a legitimate goal and whether its intrusion is justified by the benefit.

Conditional approval
Approval to deploy only if specified mitigations are implemented and verified.

Data protection impact assessment (DPIA)
An assessment of risks to individuals from processing personal data, required by many data protection laws for high-risk processing.

Stakeholder engagement
Consulting people affected by a system, or their representatives, to understand impacts and shape mitigations.

Human rights due diligence
An ongoing process to identify, prevent, mitigate and account for adverse human rights impacts.

Copyright © ZyeemZia

ISO/IEC 42005
An international standard giving guidance on AI system impact assessment.

Algorithmic impact assessment
An assessment of automated decision systems, often required for public-sector use.

KNOWLEDGE CHECK

11. Which assessment focuses on risks from processing personal data?
    - (A) FRIA
    - (B) Pre-mortem
    - (C) Statement of Applicability
    - (D) DPIA
12. What is the main benefit of an integrated impact assessment template?
    - (A) It satisfies several requirements without duplicate forms
    - (B) It removes the need for legal review
    - (C) It is shorter than any single assessment
    - (D) It avoids consulting stakeholders
13. Which question tests necessity?
    - (A) How fast is the model?
    - (B) Which cloud region is cheapest?
    - (C) Could the goal be achieved with less intrusive means than AI?
    - (D) How many features does the model use?
14. When should an impact assessment be revisited?
    - (A) After launch, after significant changes and at a set interval
    - (B) Never once signed
    - (C) Only when the vendor asks
    - (D) Only after a court case
15. A system was launched without the required assessment. What is unacceptable?
    - (A) Completing an urgent assessment
    - (B) Backdating an assessment to the launch date
    - (C) Applying interim safeguards
    - (D) Recording the process failure

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 4 · RISK · LESSON 4 · 30 MIN

Treating AI Risk: Controls and Risk Appetite

Choosing responses, designing controls and setting limits leaders can enforce

- Select risk treatment options for AI risks
- Design preventive, detective and corrective controls, technical and organisational
- Write AI risk appetite statements with measurable tolerances and key risk indicators

Assessment without treatment is paperwork. For each significant risk, the owner chooses a response and implements **controls** strong enough to bring residual risk within appetite. Controls must be specific, owned and testable; 'the team will be careful' is not a control.

Risk treatment options

AV

Avoid

Do not pursue the use, or remove the risky feature. Example: drop emotion analysis from an interview tool.

RE

Reduce

Lower likelihood or impact with controls. Example: fairness testing and human review of refusals.

TR

Transfer or share

Shift part of the financial impact through contracts or insurance. Note: legal accountability to affected people usually cannot be transferred.

AC

Accept

Consciously accept residual risk within appetite, with sign-off at the right level and review dates.

Control types with AI examples

TYPE	PURPOSE	TECHNICAL EXAMPLE	ORGANISATIONAL EXAMPLE
Preventive	Stop the risk event happening	Input filters, access limits, transaction caps	Approval gate before deployment; training
Detective	Find problems quickly	Drift and fairness monitoring, anomaly alerts	Sample reviews of outputs; complaint analysis
Corrective	Limit damage and recover	Rollback to previous model, kill switch	Incident response, customer remediation
Directive	Guide behaviour	System prompts and usage policies built into tools	AI policy, acceptable-use rules

WATCH OUT · YOU CANNOT OUTSOURCE ACCOUNTABILITY

Contracts can move costs to a supplier, but regulators and affected people will still hold the deploying organisation responsible for how it used AI. Treat contractual transfer as a complement to controls, not a replacement.

Risk appetite is the board's statement of how much risk of each kind the organisation will accept in pursuit of its goals. For AI it must be specific enough to guide decisions. 'We have a low appetite for unfair outcomes' becomes useful only when paired with **tolerances**: measurable limits that trigger action when breached, monitored through **key risk indicators (KRIs)**.

Copyright © ZyeemZia

AI risk appetite: statement, tolerance and KRI

APPETITE STATEMENT	TOLERANCE	KEY RISK INDICATOR
We have no appetite for prohibited AI practices.	Zero prohibited uses in inventory	Number of uses flagged as prohibited in reviews
We have a low appetite for unfair outcomes in customer decisions.	Approval-rate ratio between protected groups at least 0.8 for high-risk models	Monthly approval-rate ratio by group
We have a moderate appetite for productivity experiments with generative AI.	Pilots allowed with approved tools and no confidential data	Share of AI use through approved tools
We have a low appetite for unresolved AI incidents.	High-severity AI incidents contained within 24 hours	Mean time to contain AI incidents

Treatment workflow

01 Prioritise — Order risks by residual score and impact overrides →

02 Choose response — Avoid, reduce, transfer or accept →

03 Design controls — Specific, owned, testable →

04 Implement — Build controls into the system and process →

05 Verify — Test that controls work as designed →

06 Accept and monitor — Sign off residual risk; track KRIs

TEMPLATE AI risk treatment plan

Turn assessed risks into owned, testable controls.

RISK	RESPONSE	CONTROL(S)	CONTROL TYPE	OWNER	TEST OF EFFECTIVENESS	DUE
Credit model disadvantages rural women	*Reduce*	*Fairness threshold in release gate; human review of refusals*	*Preventive + corrective*	*Head of Credit Risk*	*Quarterly fairness report; review sample of 50 refusals*	*Before launch*
Vendor changes model without notice	*Reduce + transfer*	*Contract notice clause; regression test on vendor updates*	*Preventive + detective*	*Procurement Lead*	*Annual contract review; automated test suite run on each update*	*Next renewal*

Copyright © ZyeemZia

SCENARIO · DECIDE · ACCEPTING A RISK

A product manager wants to accept a residual fairness risk on a youth employment-matching app because fixing it would delay launch by a month. The risk is scored high. Who should be able to accept it?

(A) The product manager, because they own the launch date.

(B) Nobody: high risks can never be accepted.

(C) The level set in the risk acceptance rules, typically a senior executive or AI governance committee, checked against the low appetite for unfair outcomes.

(D) The data scientist who built the model.

Circle your choice. Answer and feedback: module answer key.

REFLECT

Write one AI risk appetite statement for your organisation, with a measurable tolerance and a key risk indicator. Who would be notified if it were breached?

Key terms

Risk treatment
Selecting and implementing options to modify risk: avoid, reduce, transfer or accept.

Preventive control
A control designed to stop a risk event from occurring.

Detective control
A control designed to identify a risk event or control failure quickly.

Corrective control
A control designed to limit damage and restore normal operation after an event.

Risk tolerance
A measurable limit on a risk that triggers action when exceeded.

Key risk indicator (KRI)
A metric that signals changes in the level of a risk.

Risk acceptance
A documented decision by an authorised person to retain a residual risk.

Kill switch
A tested mechanism to stop an AI system or feature quickly.

KNOWLEDGE CHECK

16. Removing emotion analysis from an interview tool because the risk is unacceptable is an example of:

(A) Avoiding the risk
(B) Transferring the risk
(C) Accepting the risk
(D) A detective control

17. Drift and fairness dashboards that alert the team are:

(A) Preventive controls
(B) Detective controls
(C) Risk appetite statements
(D) Contract clauses

18. Why can't contracts fully transfer AI risk?

(A) Contracts are illegal for AI
(B) Suppliers never pay damages
(C) Accountability to regulators and affected people usually remains with the deployer
(D) Insurance does not exist for technology

Copyright © ZyeemZia

19. A measurable limit that triggers action when exceeded is a:

(A) Principle
(B) Vision statement
(C) Model card
(D) Tolerance

20. Who should accept a high residual risk?

(A) Whoever built the model
(B) The most junior tester
(C) The vendor's sales manager
(D) An authorised senior level defined in risk acceptance rules

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 4 · RISK · LESSON 5 · 30 MIN

Use-Case Intake, Tiering and the AI Risk Register

A front door for every AI idea and one register that tracks them all

- Design an AI use-case intake process that is fast for low-risk ideas
- Apply a tiering method that routes systems to the right level of review
- Maintain an AI risk register integrated with enterprise risk management

Governance becomes real at the **front door**. If every new AI idea passes through a short intake, the organisation sees what is coming, routes it to the right level of review and avoids surprises. If the intake is slow or confusing, teams go around it. The goal is a process that takes minutes for low-risk ideas and leads to a full assessment only when needed.

AI use-case intake flow

01 **Submit** — Short form: purpose, data, users, affected people, vendor

→

02 **Screen** — Prohibited-use and legal triggers checked

→

03 **Tier** — Triage questions assign a provisional tier

→

04 **Route** — Fast track, standard review or full assessment

→

05 **Decide** — Approve, approve with conditions or reject

→

06 **Register** — Inventory and risk register updated

Triage questions that drive the tier

QUESTION	IF YES
Could it fall within a prohibited practice?	Stop and escalate to legal
Does it make or materially influence decisions about people's access to work, credit, education, health, housing, benefits or justice?	High tier
Does it process sensitive personal data or profile people at scale?	At least medium; high if combined with decisions
Does it interact with the public or generate content shown externally?	At least medium; transparency duties
Can it take actions without human approval?	Raise tier by one level
Is it internal productivity use with no personal or confidential data?	Low tier, fast track

ZAIG tiers and what each requires

T0
Prohibited
Not permitted. Recorded and closed.

T1
Low
Register, owner, approved tools, acceptable-use rules. Decision within days.

T2
Medium
Light assessment, pre-launch testing, transparency checks, annual review.

Copyright © ZyeemZia

T3

High

Full impact assessment, independent validation, human oversight design, monitoring plan, committee approval, review at least annually and after changes.

PRO TIP · MEASURE THE FRONT DOOR

Track intake cycle time by tier, the share of AI use cases registered before launch and how many systems are discovered outside the process. Fast, predictable approvals are the best way to stop shadow AI.

TEMPLATE

AI risk register

Track AI risks across systems in a format that rolls up into enterprise risk reporting.

RISK ID AND SYSTEM	RISK DESCRIPTION	INHERENT SCORE	KEY CONTROLS	RESIDUAL SCORE	OWNER	REVIEW DATE
R-014 Nano-loan model	*Lower approval rates for rural women due to sparse wallet history*	*16 (4×4)*	*Fairness gate, alternative data, human review of refusals*	*8 (2×4)*	*Head of Credit Risk*	*Quarterly*
R-022 Support chatbot	*Invented fee information leads to customer detriment*	*9 (3×3)*	*Grounding in policy documents, disclosure, escalation to staff*	*4 (2×2)*	*Head of Customer Service*	*Six-monthly*

Copyright © ZyeemZia

Where the AI risk register sits (top layer first)

Board risk committee	`Top AI risks within enterprise risk profile`
Enterprise risk register	`Aggregated AI risks, e.g. 'unfair automated decisions'`
AI risk register	`System-level AI risks, scores, controls, owners`
Impact assessments and test evidence	`Detailed analysis behind each entry`

INSIGHT · AGGREGATE, DO NOT JUST LIST

A board does not need 200 system-level risks. Group them into a handful of enterprise themes, such as 'unfair automated decisions' or 'generative-AI data leakage', each showing the number of systems affected, the trend and the worst residual score.

CASE STUDY · BUILDING THE FRONT DOOR AT A HOSPITAL GROUP

A private hospital group with five sites receives a steady stream of AI proposals: radiology triage, a nurse-rostering optimiser, a patient chatbot, transcription for doctors and a marketing image generator. Approvals currently take four months for everything because each goes through the full ethics committee.

1. How would you tier these proposals?

2. What would the intake process look like?

3. How would you know it is working?

Model answer: module answer key.

SCENARIO · DECIDE · THE FAST TRACK IS TOO FAST

After launching a fast track for low-tier AI, an audit finds a 'low-tier' marketing tool that actually scores customers' likelihood of defaulting on payments and is used to decide who receives payment-plan offers. What is the BEST fix?

(A) Abolish the fast track and send everything to full review.

(B) Retier the tool, add a triage question on decisions about people's financial access, spot-check a sample of fast-track approvals and require owners to re-register when use changes.

(C) Discipline the marketing manager and change nothing else.

(D) Ask the vendor to confirm the tool is low risk.

Circle your choice. Answer and feedback: module answer key.

Copyright © ZyeemZia

REFLECT

If your organisation had an AI intake form, what are the five questions you would put on it to catch the highest-risk ideas while keeping it under five minutes?

Key terms

Use-case intake
The process by which new AI ideas are submitted, screened and routed for review.

Fast track
A streamlined approval path for low-risk AI uses.

Enterprise risk management (ERM)
The organisation-wide framework for identifying, assessing and managing all types of risk.

Re-registration trigger
A change, such as a new purpose or data source, that requires a system to go back through intake.

Tiering
Assigning an AI system to a risk level that determines the governance it requires.

AI risk register
A record of AI risks with scores, controls, owners and review dates.

Triage
A quick initial assessment that sorts cases by urgency or risk.

KNOWLEDGE CHECK

21. What is the main purpose of AI use-case intake?
    - (A) To slow down all AI projects equally
    - (B) To replace impact assessments
    - (C) To see every AI idea early and route it to the right depth of review
    - (D) To select vendors by price

22. An internal tool that drafts meeting notes with no personal or confidential data would usually be:
    - (A) Prohibited
    - (B) Low tier
    - (C) High tier
    - (D) Exempt from registration

23. Which triage answer should raise a system's tier by one level?
    - (A) It uses a modern framework
    - (B) It can take actions without human approval
    - (C) It is hosted internally
    - (D) It has a short name

24. How should system-level AI risks be reported to the board?
    - (A) Aggregated into a few enterprise themes with counts, trends and worst residual scores
    - (B) As a list of every risk on every system
    - (C) Not at all
    - (D) Only when a regulator asks

25. What is the best evidence that the intake process is working?
    - (A) More forms submitted per week regardless of quality
    - (B) Longer review times
    - (C) Fewer approvals overall
    - (D) A rising share of AI registered before launch and fewer systems found outside it

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 4 · RISK

Answer key

Knowledge checks

1. B Harms to people drive legal, reputational and ethical consequences and are easy to overlook.

2. A The pre-mortem uses imagined failure to surface hidden risks before they occur.

3. D Impact on rights and reversibility of outcomes are key risk drivers.

4. C Dependency on a supplier's changes is a third-party risk, which may then create performance or fairness risks.

5. B Misuse cases deliberately explore harmful ways a system could be used.

6. C Risk score is likelihood multiplied by impact: 3 × 4 = 12.

7. C Residual risk, after controls, is compared with appetite.

8. A ALE = 4 × 200,000 = 800,000.

9. B Multiplication can understate severe, rare risks; the override corrects this.

10. D Reversibility addresses whether and how quickly harm can be corrected.

11. D The DPIA is the data protection law instrument for high-risk personal data processing.

12. A Modular templates meet AIIA, DPIA and FRIA needs in one process.

13. C Necessity asks whether AI is required for the goal or a less risky option exists.

14. A Impacts change with use, data and context, so assessments must be living documents.

15. B Falsifying records compounds the failure and may breach law.

16. A Eliminating the risky feature avoids the risk.

17. B They detect problems after they begin, so action can be taken.

18. C Financial impact can be shared, but responsibility for use generally stays with the deployer.

19. D Tolerances make appetite statements operational.

20. D Acceptance authority must match the risk level and be independent of the builders.

21. C Intake gives visibility and proportionate routing.

22. B It is low-impact internal productivity use but still registered.

23. B Autonomy increases the potential for unchecked harm.

24. A Aggregation makes AI risk decision-ready for the board.

25. D Coverage before launch and fewer surprises show the front door is used.

Scenarios & case studies

Scenario · A narrow risk workshop
B is best. Best. The workshop missed risks to people. Starting from affected applicants surfaces accuracy, fairness, privacy and contestability risks.

Scenario · Two risks with the same score
B is best. Best. Severity and irreversibility justify priority even at lower likelihood.

Case study · An exam-proctoring proposal
The assessment would find privacy intrusion into homes, likely unfairness to students in shared or noisy housing and to students with disabilities, risk of wrongful accusations with serious academic consequences, possible biometric processing and low accuracy of 'suspicion' signals. Necessity is doubtful: alternatives such as open-book assessment, oral checks or in-person exams may meet integrity goals with less intrusion. Note also that in jurisdictions such as the EU, AI monitoring of students during tests is a listed high-risk use. A sensible recommendation is not to deploy automated flagging as designed; if any proctoring is used, restrict it to recording for human review only on specific complaint, provide accommodations and alternatives, give students notice and appeal rights, and test for disparities before any use.

Scenario · Assessment after the fact
B is best. Best. It assesses actual impacts, protects customers while assessing, and fixes the process gap that allowed launch without assessment.

Scenario · Accepting a risk
C is best. Best. Acceptance authority should match risk level, and the decision must be checked against stated appetite. Low appetite suggests treatment, not acceptance.

Copyright © ZyeemZia

Case study · Building the front door at a hospital group

Radiology triage is high tier (health decisions, possible regulated medical device). Doctor transcription is medium to high (sensitive health data, errors in records; human review required). The patient chatbot is medium, rising to high if it gives clinical advice. The rostering optimiser is medium (affects staff working conditions; worker consultation). The marketing image generator is low, with transparency labelling. The intake should be a short online form with triage questions, a weekly triage meeting of privacy, clinical safety and IT security, fast-track approval for low tier within a week, and the ethics committee reserved for high-tier systems. Success measures: cycle time per tier, percentage of AI registered before launch, number of systems discovered outside the process and committee time spent on high-tier items.

Scenario · The fast track is too fast

B is best. Best. It corrects this case, strengthens the screening logic and adds detective controls without losing the benefit of the fast track.

Copyright © ZyeemZia

05

MODULE 5 · DATA

Data Governance and Privacy for AI

Quality, provenance, lawful use and protection of the data that AI learns from and acts on

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Govern data quality, provenance and lineage for AI datasets
- Apply lawful basis, transparency and individual rights to AI processing
- Select minimisation and privacy-enhancing techniques proportionate to the risk
- Govern training data rights, retrieval permissions, prompt logs and cross-border flows for generative AI

LESSONS

1. Data Governance Foundations for AI · 30 min
2. Privacy Law Principles Applied to AI · 35 min
3. Privacy-Enhancing Techniques and Data Minimisation · 30 min
4. Data for Generative AI: Training, Retrieval, Rights and Retention · 35 min

MODULE 5 · DATA · LESSON 1 · 30 MIN

Data Governance Foundations for AI

Quality, provenance, lineage and stewardship of the data AI learns from

- Apply data quality dimensions to AI training, test and operational data
- Record data provenance and lineage so AI decisions can be traced
- Assign data ownership and stewardship roles for AI datasets

Every AI system inherits the strengths and flaws of its data. Data governance for AI extends traditional data management in three ways: it asks whether data is **fit for a specific model purpose** (not just accurate in general), whether the organisation has the **rights** to use it for AI, and whether its **history** can be traced from source to model to decision.

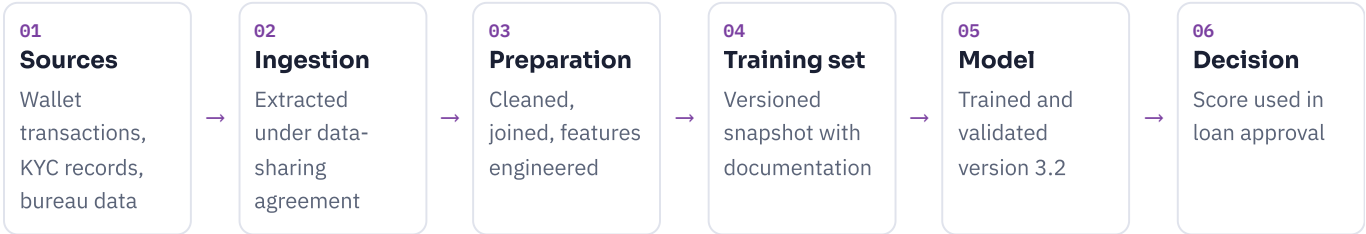
Data quality dimensions for AI

DIMENSION	QUESTION FOR AI	EXAMPLE FAILURE
Accuracy	Are values and labels correct?	Mislabelled X-rays teach a model wrong patterns
Completeness	Are key fields and groups present?	Missing income data for informal workers
Representativeness	Does the data reflect the population the model will serve?	Training only on urban customers
Timeliness	Is the data recent enough for current conditions?	Pre-pandemic travel data used for 2026 demand
Consistency	Are definitions stable across sources and time?	'Active customer' defined differently by two systems
Lawfulness and rights	Was it collected lawfully, and may it be used for this purpose?	Scraped data with prohibitive licence terms

DEFINITION · PROVENANCE AND LINEAGE

Provenance is where data came from and under what conditions it was collected, including consent and licence terms. **Lineage** is the path data takes through transformations, from source systems to training sets, features, models and outputs. Together they let you answer the auditor's question: 'Which data produced this decision, and were you allowed to use it?'

Data lineage for a credit model



Copyright © ZyeemZia

Data roles for AI

DO
Data owner
Senior business person accountable for a data domain, its use and access decisions.

DS
Data steward
Maintains definitions, quality rules and documentation day to day.

DC
Data custodian
Technical team operating storage, security and backups.

PO
Privacy officer
Advises on lawful basis, notices, rights and impact assessments.

MO
Model owner
Accountable for how data is used in a specific model and its outcomes.

Labelling and annotation governance

- Write clear labelling guidelines with examples, including edge cases.
- Measure agreement between labellers and resolve disagreements.
- Check whether labeller backgrounds or instructions introduce bias.
- Protect annotators from harmful content and pay them fairly, including through outsourcing vendors.
- Record who labelled what, when and under which guideline version.

TEMPLATE **Dataset provenance record**

Document a dataset used for AI so its origin, rights and limits are clear.

DATASET AND VERSION	SOURCE AND COLLECTION METHOD	LEGAL BASIS OR LICENCE	PERSONAL DATA INCLUDED	KNOWN GAPS AND BIASES	PERMITTED USES	OWNER
Wallet transactions 2023-2025 v4	*Internal payment platform, automated*	*Contract with customers; privacy notice updated 2024*	*Yes: wallet ID, amounts, merchant category*	*Few records for users under 21; rural agents under-represented*	*Fraud and credit risk models only*	*Head of Data, Payments*

PRO TIP · VERSION EVERYTHING
Keep immutable, versioned snapshots of training and test datasets and link each model version to the exact data versions it used. Without this, you cannot reproduce results, investigate complaints or honour a request to retrain without a person's data.

Copyright © ZyeemZia

SCENARIO · DECIDE · A DATASET WITH NO HISTORY

A data scientist finds a well-labelled dataset of customer complaints on a shared drive and wants to use it to train a classifier. Nobody knows where it came from or whether customers were told. What should happen?

(A) Use it, because it is already inside the company.

(B) Quarantine it from model training until provenance, legal basis and quality are established, and record the outcome.

(C) Delete it immediately.

(D) Use it but do not document that you did.

Circle your choice. Answer and feedback: module answer key.

REFLECT

For one AI system you know, could you trace a single decision back to the exact data version and source that influenced it? Where would the trail break?

Key terms

Data provenance
The origin of data and the conditions, such as consent or licence terms, under which it was collected.

Representativeness
The degree to which data reflects the population and conditions a model will serve.

Data owner
The senior person accountable for a data domain and decisions about its use.

Inter-annotator agreement
A measure of how consistently different labellers label the same items.

Data lineage
The record of how data moves and is transformed from source systems to models and decisions.

Data steward
The person responsible for day-to-day quality, definitions and documentation of a data domain.

Annotation
Adding labels or tags to data so it can be used for supervised learning.

Dataset versioning
Keeping identifiable, unchangeable snapshots of datasets linked to the models trained on them.

KNOWLEDGE CHECK

1. Which data quality dimension asks whether data reflects the people a model will serve?
   (A) Representativeness (B) Timeliness
   (C) Consistency (D) Encryption
2. What does data lineage let you do?
   (A) Trace how data moved from sources to models and decisions (B) Encrypt data at rest
   (C) Delete data automatically (D) Increase model accuracy directly
3. Who is accountable for decisions about the use of a data domain?
   (A) Data custodian (B) Annotator
   (C) Data owner (D) Cloud provider

Copyright © ZyeemZia

4. Why link each model version to exact dataset versions?

(A) To reduce storage costs
(B) To speed up inference
(C) To avoid documentation
(D) To reproduce results, investigate complaints and retrain without specific data

5. A labelled dataset of unknown origin should be:

(A) Used immediately
(B) Quarantined from training until provenance and rights are established
(C) Shared publicly
(D) Merged into all datasets

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 5 · DATA · LESSON 2 · 35 MIN

Privacy Law Principles Applied to AI

Lawful basis, notice, rights and automated decisions in AI systems

- Identify an appropriate lawful basis for AI processing in different contexts
- Write transparent notices for AI uses of personal data
- Handle individual rights, including rights about automated decisions, in AI systems
- Apply extra care to sensitive data and children's data

Data protection laws were not written for AI, but they apply to it with full force. The EU's GDPR, India's DPDP Act, Sri Lanka's PDPA and the newer laws across South Asia share a common core: process personal data lawfully, transparently and for specified purposes; minimise it; keep it accurate and secure; and respect people's rights. AI stresses each principle because models are hungry for data, reuse it in new ways and can infer things people never disclosed. As with all regulatory content in this track, this is general education, not legal advice.

Common lawful bases and how they fit AI

BASIS (VARIES BY LAW)	FITS WHEN	WATCH OUT FOR
Consent	People freely choose an optional AI feature, such as voice biometrics	Must be specific, informed and withdrawable; hard to honour once data is in a trained model
Contract	AI is genuinely needed to deliver the service requested	Training a general model is rarely 'necessary' for one contract
Legal obligation	Law requires the processing, such as anti-money-laundering screening	Limited to what the law requires
Legitimate interests or legitimate uses	Reasonable, expected uses balanced against individuals' rights, such as fraud prevention	Not all laws offer it in the same form; requires a documented balancing test
Public task	Public bodies performing official functions	Needs a clear legal mandate

WATCH OUT · LAWS DIFFER IN IMPORTANT WAYS

India's DPDP Act relies mainly on consent plus a defined list of 'legitimate uses', rather than the broader legitimate-interests basis of the GDPR. Other South Asian laws differ again. Map the lawful basis per jurisdiction rather than copying a European analysis.

What an AI privacy notice should explain

- That AI or automated processing is used, and for what purpose.
- What personal data is used, including data inferred about the person.
- Whether the data is used to train or improve models, and how to object where possible.
- Whether decisions are made automatically and their significance.
- How to obtain human review, correct data or complain.
- Who receives the data, including AI vendors, and where it is processed.

Copyright © ZyeemZia

Individual rights in AI systems

RT1
Access
People can learn what data is held and, under some laws, meaningful information about automated decision logic.

RT2
Correction
Wrong input data must be corrected, and decisions based on it reviewed.

RT3
Erasure
Data may need to be deleted from datasets; models may need retraining or other measures where deletion from the model is required.

RT4
Objection and opt-out
People may object to some processing, such as profiling for marketing.

RT5
Automated decisions
Some laws, such as the GDPR, restrict solely automated decisions with legal or similarly significant effects and require safeguards such as human intervention.

DEFINITION · MACHINE UNLEARNING

Techniques that aim to remove the influence of specific training data from a trained model without full retraining. They are still maturing. In practice, organisations honour erasure by deleting data from datasets, excluding it from future training cycles and, where justified by risk, retraining on schedule.

Sensitive data and children

Sensitive (special category) data

- Health, biometrics, religion, ethnicity, sexual life, political views and similar
- Stricter conditions for processing
- AI can infer sensitive traits from ordinary data, which may itself be sensitive processing

Children's data

- Many laws require parental consent and prohibit tracking or targeted advertising to children
- India's DPDP Act sets specific duties for children's data
- Design AI products used by students with these limits from the start

SCENARIO · DECIDE · A VOICE-BIOMETRICS ROLLOUT

A mobile financial services provider in Bangladesh wants to replace PIN reset by voice biometrics for all customers. The vendor says consent is unnecessary because it improves security. What is the BEST governance position?

(A) Proceed for all customers, because security is a legitimate goal.

(B) Offer voice biometrics as an optional method with clear notice and consent, keep a non-biometric alternative, assess the processing in a DPIA and check accuracy across accents and age groups.

(C) Use voice biometrics but delete recordings after one day.

(D) Cancel the project because biometrics are illegal.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE

Lawful basis register for AI processing

Record the lawful basis for each AI processing purpose in each jurisdiction.

Copyright © ZyeemZia

AI SYSTEM AND PURPOSE	PERSONAL DATA USED	JURISDICTION	LAWFUL BASIS	NOTICE LOCATION	RIGHTS HANDLING	REVIEWED BY
Fraud model: transaction monitoring	*Transactions, device data*	*Bangladesh; India*	*Legal obligation and fraud-prevention purposes per local law*	*Privacy notice section 4*	*Human review on request; correction process*	*Privacy Officer, March 2026*

REFLECT

Read your organisation's privacy notice. Would a customer understand from it that AI is used, what data it uses and how to challenge a decision? Rewrite one sentence to make it clearer.

Key terms

Lawful basis
The legal ground that permits processing of personal data, such as consent or legal obligation.

Special category data
Sensitive personal data, such as health, biometric or religious data, that receives extra legal protection.

Machine unlearning
Techniques for removing the influence of specific data from a trained model.

Data principal
Under India's DPDP Act, the individual to whom personal data relates.

Legitimate interests
Under the GDPR and similar laws, a lawful basis requiring a documented balance between the organisation's interests and individuals' rights.

Solely automated decision
A decision made without meaningful human involvement, which some laws restrict where it has significant effects.

Privacy notice
Information given to people about how their personal data is processed and their rights.

Inferred data
New personal information derived by analysis or AI, such as predicted income or health status.

KNOWLEDGE CHECK

6. Why is consent hard to rely on for training data?

(A) Withdrawal is difficult to honour once data has shaped a trained model
(B) Consent is never valid for AI
(C) Consent cannot be recorded
(D) Consent applies only to children

Copyright © ZyeemZia

7. Which statement about India's DPDP Act is most accurate?

   (A) It copies the GDPR's legitimate-interests basis exactly
   (B) It does not apply to companies
   (C) It relies mainly on consent and a defined list of legitimate uses
   (D) It has no rules on children's data

8. An AI system infers customers' religion from shopping patterns. This is:

   (A) Not personal data because it was inferred
   (B) Always lawful if the model is accurate
   (C) Processing that may itself count as sensitive data processing
   (D) Exempt because it is statistical

9. How do organisations usually honour erasure when data was used to train a model?

   (A) Ignore the request because models are exempt
   (B) Delete the entire model immediately in every case
   (C) Ask the person to pay for retraining
   (D) Delete it from datasets, exclude it from future training and retrain where justified

10. Which belongs in an AI privacy notice?

    (A) The model's source code
    (B) Whether data is used to train models and how to object where possible
    (C) Employees' salaries
    (D) The vendor's share price

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 5 · DATA · LESSON 3 · 30 MIN

Privacy-Enhancing Techniques and Data Minimisation

Using less data, and protecting the data you must use

- Distinguish anonymisation, pseudonymisation and de-identification
- Explain how privacy-enhancing technologies reduce risk in AI
- Choose proportionate minimisation and protection techniques for a use case

The best way to protect personal data in AI is not to use it. The second best is to use less of it, in a less identifiable form, with strong protection. **Privacy-enhancing technologies (PETs)** make this practical. None is a silver bullet; each reduces certain risks at a cost in accuracy, complexity or performance, so governance must choose deliberately.

Anonymised, pseudonymised and de-identified data

Anonymised

- Individuals can no longer be identified by any means reasonably likely to be used
- Usually falls outside data protection law
- Very hard to achieve with rich behavioural data

Pseudonymised

- Direct identifiers replaced with codes; a key exists elsewhere
- Still personal data under most laws
- Reduces risk and supports security

De-identified (generic term)

- Some identifiers removed or masked
- Legal status depends on residual risk
- Must be tested for re-identification

Privacy-enhancing technologies for AI

TECHNIQUE	HOW IT HELPS	TRADE-OFF
Masking and redaction	Removes names, IDs and numbers before data reaches a model or prompt	May miss context-specific identifiers
Aggregation and generalisation	Replaces precise values with ranges or groups	Loses detail that may matter for accuracy
Differential privacy	Adds calibrated noise so results reveal little about any one person	Reduced accuracy, especially for small groups
Federated learning	Trains across devices or sites without centralising raw data	Complex; model updates can still leak information
Synthetic data	Generates artificial records that mimic statistical patterns	May leak real records if poorly made; may miss rare cases
Secure enclaves and confidential computing	Processes data in protected hardware environments	Depends on hardware trust; added cost
Homomorphic encryption and secure multi-party computation	Computes on encrypted or split data	Slow and specialised for many AI tasks

Copyright © ZyeemZia

Measures of privacy protection

MEASURE	FORMULA	WHAT IT TELLS YOU
k-anonymity	`Each record shares its quasi-identifiers with at least k − 1 other records`	Larger k makes it harder to single out a person; it does not stop inference about sensitive attributes on its own.
Differential privacy (epsilon)	`P[M(D) ∈ S] ≤ e^ε × P[M(D′) ∈ S]`	For datasets D and D′ differing by one person, outputs are nearly as likely; smaller ε means stronger privacy and more noise.
Re-identification risk (simple)	`Risk ≈ 1 / size of smallest matching group`	If only 3 people share a combination of age, area and job, each has about a one-in-three risk of being identified.

EXAMPLE · FOUR DATA POINTS ARE ENOUGH

Studies of mobile and card data have shown that a handful of time-and-place points can uniquely identify most people in large datasets. A telecom's 'anonymised' location dataset for a city transport model may therefore still be personal data unless it is aggregated, for example to trips between zones per hour with small counts suppressed.

Minimisation by design for an AI project

1. **Define the purpose precisely** A precise purpose makes it easier to decide what data is truly needed.
2. **Start with the least data** Begin with aggregated or de-identified data and add detail only when testing shows it is needed.
3. **Drop direct identifiers early** Remove or pseudonymise identifiers at ingestion and keep the key separately.
4. **Test feature necessity** Remove features that add little accuracy, especially sensitive or proxy features.
5. **Limit retention** Delete raw data, prompts and intermediate files on a schedule.
6. **Review re-identification risk** Test released datasets and model outputs for re-identification and memorisation.

INSIGHT · MINIMISATION CAN IMPROVE FAIRNESS AND SECURITY

Fewer features means fewer proxies for protected traits, a smaller attack surface and less damage if a breach occurs. Minimisation is often good engineering, not only compliance.

SCENARIO · DECIDE · SHARING DATA WITH A RESEARCH PARTNER

A Dhaka hospital wants to share three years of patient records with a university to develop a diabetes-risk model. What is the MOST appropriate approach?

(A) Share the full records under a confidentiality agreement.

(B) Share pseudonymised, minimised fields needed for the research, under an agreement with security and use limits, after ethics and privacy review, and test re-identification risk.

(C) Remove names only and publish the dataset openly to help other researchers.

(D) Refuse, because health data can never be used for research.

Circle your choice. Answer and feedback: module answer key.

Copyright © ZyeemZia

PET selection checklist

☐ Purpose and minimum data defined
☐ Direct identifiers removed or pseudonymised at ingestion
☐ Re-identification risk assessed for any shared or released data
☐ Appropriate PET chosen and accuracy impact measured
☐ Small groups protected from disproportionate accuracy loss
☐ Keys and mapping tables stored separately with restricted access
☐ Retention limits set for raw data, prompts and logs
☐ Decisions and trade-offs documented

REFLECT

Which AI project in your organisation uses more personal data than it needs? What is one field you could remove or generalise without losing much value?

Key terms

Anonymisation
Processing data so individuals can no longer be identified by any reasonably likely means.

Privacy-enhancing technology (PET)
A technique that reduces privacy risk while allowing data to be used, such as differential privacy or federated learning.

Federated learning
Training a model across multiple devices or sites without centralising the raw data.

k-anonymity
A property where each record is indistinguishable from at least k – 1 others on quasi-identifiers.

Pseudonymisation
Replacing direct identifiers with codes so data cannot be linked to a person without separately held information.

Differential privacy
A mathematical framework that adds calibrated noise so outputs reveal little about any individual.

Synthetic data
Artificially generated data that mimics the statistical properties of real data.

Quasi-identifier
An attribute, such as age, area or job, that is not identifying alone but can identify people in combination.

KNOWLEDGE CHECK

11. Pseudonymised data is usually:
    - (A) Still personal data under most laws
    - (B) Outside all data protection law
    - (C) Equivalent to public data
    - (D) The same as encrypted backups

12. In differential privacy, a smaller epsilon means:
    - (A) Weaker privacy
    - (B) No effect on accuracy
    - (C) Stronger privacy and more noise
    - (D) Faster training only

13. Which technique trains across hospitals without pooling raw records?
    - (A) Masking
    - (B) k-anonymity
    - (C) Data poisoning
    - (D) Federated learning

Copyright © ZyeemZia

14. Only two people in a dataset share a combination of age, district and job. Each has roughly what re-identification risk?

A) About one in a million
B) About one in two
C) Zero
D) About one in twenty

15. Why can minimisation improve fairness?

A) It always increases accuracy
B) Fewer features means fewer proxies for protected traits
C) It removes the need to test
D) It hides results from regulators

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 5 · DATA · LESSON 4 · 35 MIN

Data for Generative AI: Training, Retrieval, Rights and Retention

Copyright, scraping, retrieval permissions, prompt logs and cross-border flows

- Assess rights and risks in data used to train or fine-tune generative models
- Govern retrieval-augmented generation so assistants only reveal what users may see
- Set retention and vendor data-use rules for prompts and outputs
- Address cross-border transfer and localisation requirements

Generative AI raises data questions at every turn. What was the model trained on, and did anyone have the right to use it? What happens to the prompts staff type? When an assistant searches company documents, does it respect who is allowed to see what? Where are the data and logs stored? Governance must answer these for every generative-AI deployment, whether the model is built in-house or accessed through a vendor.

Intellectual property and training data (as of 2026)

ISSUE	STATE OF PLAY	GOVERNANCE RESPONSE
Training on copyrighted works	Contested in courts in several countries; some decisions favour fair use or exceptions, others find infringement in specific circumstances	Know your model provider's position; prefer providers offering documentation and IP indemnities
Text and data mining opt-outs	EU law lets rights holders reserve rights; general-purpose model providers must respect reservations and summarise training content	Check providers' copyright policies and summaries
Ownership of outputs	Many jurisdictions require human authorship for copyright; purely machine-generated output may not be protected	Do not assume exclusive rights in AI-generated assets; keep human creative input records
Outputs resembling protected works	Risk of reproducing logos, characters, code or text	Output filters, human review for public-facing content, licence checks for code

WATCH OUT · SCRAPING IS NOT A FREE PASS

Data visible on the internet is not automatically free to use. Website terms, copyright, database rights and data protection law may all apply, and several data protection authorities have warned that scraping personal data for AI training needs a lawful basis and safeguards.

Retrieval-augmented generation: where data controls sit (top layer first)

Answer	`Citations to source documents` `Output filters for sensitive data`
Retrieval	`Search limited to documents the user is permitted to see` `Permission check at query time`
Index	`Only approved sources ingested` `Labels for confidentiality and personal data`
Sources	`Document owners approve inclusion` `Stale and duplicate documents removed`

Copyright © ZyeemZia

EXAMPLE · THE ASSISTANT THAT KNEW TOO MUCH

A company connected an internal assistant to its entire file-sharing system. Within a week, an intern asked about 'salary bands' and received a summary of the confidential pay review. The documents had been shared too widely years earlier; the assistant simply made the over-sharing easy to exploit. The fix was to clean up permissions, exclude HR folders from the index and enforce user-level permission checks at retrieval.

Prompt, output and log governance

- Classify what data may be entered into each approved tool (public, internal, confidential, personal, sensitive).
- Confirm in the contract whether the vendor uses prompts and outputs to train models, and opt out where needed.
- Set retention for prompts, outputs and logs that balances investigation needs with minimisation.
- Restrict access to logs, which can contain the most sensitive data in the system.
- Mask or redact personal identifiers before prompts reach external models where feasible.

Cross-border data: questions to answer

QUESTION	WHY IT MATTERS
Where is the model hosted and where are logs stored?	Determines which transfer and localisation rules apply
Does local law restrict transfers or require local copies?	Some laws and sector regulators in South Asia restrict transfers or require certain data to stay in-country
Which transfer mechanism applies?	Adequacy, contracts, consent or approved destinations depending on law
Can the vendor offer in-region hosting?	May simplify compliance for regulated sectors such as banking and health
Who can access data from abroad, including for support?	Remote access can itself be a transfer

TEMPLATE ### Generative-AI data-use assessment

Record the key data decisions for a generative-AI deployment.

TOOL AND USE CASE	DATA CLASSES ALLOWED IN PROMPTS	VENDOR TRAINING ON OUR DATA?	RETENTION OF PROMPTS AND LOGS	HOSTING LOCATION	RETRIEVAL SOURCES AND PERMISSIONS	OWNER
Enterprise assistant for policy drafting	*Public and internal; no customer personal data*	*No (contractual opt-out confirmed)*	*30 days, then deleted*	*Vendor region in Asia; transfer assessed*	*Policy library only; user permissions enforced*	*Head of Governance*

Copyright © ZyeemZia

TOOL AND USE CASE	DATA CLASSES ALLOWED IN PROMPTS	VENDOR TRAINING ON OUR DATA?	RETENTION OF PROMPTS AND LOGS	HOSTING LOCATION	RETRIEVAL SOURCES AND PERMISSIONS	OWNER

CASE STUDY · A UNIVERSITY'S RESEARCH ASSISTANT

A university in Dhaka plans a generative-AI assistant for students that searches lecture notes, past exam papers, the library catalogue and faculty research drafts. It will use an external model through an API. Students will be able to upload their own assignments for feedback.

1. What data risks arise?

2. Which controls should be in place before launch?

3. What should students be told?

Model answer: module answer key.

SCENARIO · DECIDE · THE FREE TIER

A bank's operations team wants to use the free version of a public chat assistant to summarise customer complaints because the enterprise licence is still in procurement. The free tier's terms allow the provider to use inputs to improve its models. What should the governance lead decide?

(A) Allow it, because summarising complaints is low risk.

(B) Allow it if staff remove customer names first.

(C) Do not use the free tier for customer data; speed up the enterprise procurement and, meanwhile, allow only non-customer content or an approved internal tool.

(D) Ban AI summarisation permanently.

Circle your choice. Answer and feedback: module answer key.

Key terms

Retrieval-augmented generation (RAG)
A design in which a generative model answers using documents retrieved from a knowledge source at query time.

Rights reservation (opt-out)
A rights holder's statement that their content may not be used for text and data mining or AI training.

Data localisation
A legal requirement to store or process certain data within a country's borders.

Text and data mining (TDM)
Automated analysis of large amounts of text and data, including for AI training, subject to copyright exceptions and opt-outs in some laws.

Permission-aware retrieval
Retrieval that checks a user's access rights before using documents to generate an answer.

Cross-border transfer
Moving personal data, or allowing access to it, from one country to another.

Copyright © ZyeemZia

IP indemnity
A contractual promise by a vendor to cover certain costs if its product infringes intellectual property rights.

Prompt log
A record of inputs and outputs of a generative-AI system, which may contain sensitive data.

KNOWLEDGE CHECK

16. An internal assistant reveals confidential pay data to an intern. What is the root cause most likely to be?

(A) The model is too small
(B) Over-shared documents combined with retrieval that does not enforce permissions
(C) The intern used the wrong language
(D) The output was too long

17. Which contract term matters most before staff enter personal data into a vendor's assistant?

(A) The colour scheme of the interface
(B) The vendor's office location
(C) Whether the vendor uses prompts and outputs to train its models
(D) The number of languages supported

18. Is purely machine-generated output always protected by copyright?

(A) Yes, everywhere
(B) Only in South Asia
(C) Only for images
(D) No; many jurisdictions require human authorship

19. Why can remote support access by a foreign vendor matter?

(A) Access from abroad can itself count as a cross-border transfer
(B) It never matters if data is encrypted
(C) It only matters for public data
(D) Vendors are exempt from transfer rules

20. What is the main data risk of scraping public websites for training?

(A) Public data is always free to use
(B) Terms, copyright and data protection may still apply to publicly visible data
(C) Scraped data is always accurate
(D) Scraping makes models smaller

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 5 · DATA

Answer key

Knowledge checks

1. A Representativeness checks fit between data and the target population.

2. A Lineage records the path of data, which supports audit and investigation.

3. C The owner is accountable; stewards and custodians support.

4. D Versioned links enable reproducibility and response to rights requests.

5. B Unknown provenance means unknown legality and quality.

6. A Consent must be withdrawable, which creates practical challenges after training.

7. C The DPDP Act has its own structure of consent and specified legitimate uses, including duties for children's data.

8. C Inferences about sensitive traits can be sensitive personal data.

9. D Practical measures combine dataset deletion, exclusion and proportionate retraining.

10. B People need to know about training use and their options.

11. A A key exists that allows re-linking, so the data remains personal.

12. C Epsilon bounds how much one person's data can change outputs; smaller is more private.

13. D Federated learning keeps data local and shares model updates.

14. B With a matching group of two, the simple risk is about 1/2.

15. B Removing unnecessary features can reduce proxy discrimination.

16. B The assistant surfaces whatever it can retrieve; permission hygiene and checks are the control.

17. C Training on inputs could expose data and conflicts with purpose limitation.

18. D Human authorship requirements mean protection may be absent or limited.

19. A Many laws treat access from another country as a transfer.

20. B Visibility does not equal permission to use.

Scenarios & case studies

Scenario · A dataset with no history
B is best. Best. Unknown provenance means unknown rights and quality. Establishing them first protects customers and the model.

Scenario · A voice-biometrics rollout
B is best. Best. It respects choice, applies extra care to sensitive data and tests for performance gaps that could lock out some customers.

Scenario · Sharing data with a research partner
B is best. Best. It combines minimisation, pseudonymisation, contractual and ethical controls, and a re-identification check.

Case study · A university's research assistant
Risks: unpublished research drafts and future exam papers exposed through retrieval; student assignments (personal data and intellectual property) sent to an external vendor and possibly used for training; copyright issues with library material; cross-border transfer of student data; retention of prompts revealing personal circumstances. Controls: ingest only approved sources, with exam papers and drafts excluded or permission-controlled; enforce user permissions at retrieval; a contract confirming no vendor training on prompts, defined retention and hosting region; redaction of student IDs; clear acceptable-use rules; and logs with restricted access. Students should be told that an AI assistant is used, which model provider processes their data and where, how long prompts are kept, that uploaded work is not used for training, the limits of AI feedback and how to raise concerns.

Scenario · The free tier
C is best. Best. It prevents customer data from reaching a provider that may train on it, while supporting the team's need through a governed path.

Copyright © ZyeemZia

06

MODULE 6 · LIFECYCLE

Model Lifecycle Governance, Testing and Explainability

Stage gates, documentation, evaluation, bias testing and explanations that hold up to scrutiny

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Design lifecycle stage gates with clear evidence, approvers and independent validation
- Produce and maintain model cards, datasheets and system documentation
- Specify evaluation, red-teaming and regression testing that match the harm
- Plan and interpret bias tests using group fairness metrics, and choose mitigations
- Select and test explanation methods for each audience

LESSONS

1. Lifecycle Governance and Stage Gates · 30 min
2. Documentation: Model Cards, Datasheets and Technical Files · 30 min
3. Evaluation, Validation and Red Teaming · 35 min
4. Bias Testing and Fairness Metrics · 35 min
5. Explainability in Practice · 30 min

MODULE 6 · LIFECYCLE · LESSON 1 · 30 MIN

Lifecycle Governance and Stage Gates

Building control points into how AI is designed, built, released and retired

- Describe the AI lifecycle and the governance questions at each stage
- Design stage gates with clear criteria, evidence and approvers
- Apply independent validation and effective challenge to high-risk models

Policies and risk registers mean little unless they shape what happens when a team designs, builds and releases an AI system. **Lifecycle governance** places control points, called stage gates, at the moments when decisions are cheapest to change. A design flaw caught at the idea stage costs a conversation; the same flaw caught after launch can cost a regulatory investigation.

The AI lifecycle

01 Plan	→	02 Data	→	03 Build	→	04 Validate	→	05 Deploy	→	06 Operate	→	07 Retire
Problem, purpose, success measures, risk tier		Sourcing, rights, quality, preparation		Model selection, training or configuration		Testing, bias checks, independent review		Release, oversight, transparency		Monitoring, drift, incidents, change		Decommission, data disposal, records

Stage gates and their evidence

GATE	QUESTION	EVIDENCE REQUIRED (HIGH TIER)	APPROVER
G1 Concept	Should we pursue this use of AI?	Intake form, tier, necessity statement, initial risks	Business owner + AI governance office
G2 Design and data	Is the design and data fit and lawful?	Impact assessment draft, data provenance, lawful basis, oversight design	AI governance office, privacy, security
G3 Pre-deployment	Does the system meet its requirements?	Validation report, bias and robustness tests, model card, red-team results	Independent validator + risk committee
G4 Go-live	Are we ready to operate it safely?	Monitoring plan, runbooks, user training, notices, rollback tested	Accountable executive
G5 Post-launch review	Is it working as intended in reality?	Early monitoring results, complaints, override rates	Business owner + AI governance office

PRO TIP · GATES SHOULD BE FAST WHEN THE EVIDENCE IS READY

Publish gate criteria and templates in advance so teams can prepare. A gate that holds evidence to a clear standard is quick; a gate that invents requirements at the meeting is slow and resented.

First-line testing vs independent validation

Development team testing

- Performed by the builders
- Checks the model works as they intended
- Essential but not independent

Independent validation

- Performed by people not involved in building
- Challenges assumptions, data, methods and limits
- Required for high-risk models in many sectors, such as banking model-risk practice

Copyright © ZyeemZia

DEFINITION · EFFECTIVE CHALLENGE

Critical, informed review of a model by people with the competence, independence and authority to question it and to have their concerns acted upon. It is a long-standing idea in banking model-risk management that applies well to all high-risk AI.

Retirement is a lifecycle stage too

- Decide what replaces the system's function and communicate the change.
- Archive model versions, documentation and decision logs for the required retention period.
- Dispose of training data and logs that are no longer justified.
- Revoke credentials, API keys and integrations.
- Update the AI inventory and close related risks.

SCENARIO · DECIDE · SKIPPING A GATE

A bank's data science team has a new fraud model ready. Validation is booked for three weeks' time, but the business wants to launch now because fraud losses are rising. What should the governance lead recommend?

(A) Launch now and validate later, because the losses are real.

(B) Agree a time-boxed, risk-based expedited validation of the critical tests, launch in shadow or limited mode if needed, and record the exception with an owner and expiry.

(C) Refuse any change to the validation schedule.

(D) Let the data scientists validate their own model to save time.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE **Stage-gate record**

Record each gate decision so the history of approvals is auditable.

SYSTEM AND VERSION	GATE	EVIDENCE REVIEWED	DECISION	CONDITIONS	APPROVER AND DATE
Fraud model v2.1	*G3 Pre-deployment*	*Validation report, bias test, red-team summary, model card*	*Approved with conditions*	*Shadow mode for 2 weeks; false-positive rate by region reported weekly*	*Chief Risk Officer, 12 May 2026*

Copyright © ZyeemZia

REFLECT

Which stage of the AI lifecycle receives the least governance attention in your organisation? What is one control you could add there?

Key terms

AI lifecycle
The stages an AI system passes through from planning and data to build, validation, deployment, operation and retirement.

Independent validation
Review and testing of a model by people independent of its development.

Shadow mode
Running a new model alongside the existing process without its outputs affecting decisions.

Go-live readiness
Having monitoring, runbooks, user training, notices and a tested rollback in place before a system goes live.

Stage gate
A defined decision point where evidence is reviewed before a system proceeds to the next stage.

Effective challenge
Critical review by competent, independent people with authority to have concerns addressed.

Decommissioning
The controlled retirement of an AI system, including records, data and access.

Model risk management
The discipline, long established in banking, of governing the risks of models through inventory, validation and oversight.

KNOWLEDGE CHECK

1. Why place stage gates early in the lifecycle?
   - (A) Regulators forbid late gates
   - (B) Early gates remove the need for monitoring
   - (C) Design flaws are cheapest to fix before build and launch
   - (D) Data is always perfect early on
2. Who should perform independent validation of a high-risk model?
   - (A) The model's developers
   - (B) The vendor's sales team
   - (C) The end customer
   - (D) People not involved in building it, with authority to challenge
3. Running a new model alongside the current process without affecting decisions is called:
   - (A) Red teaming
   - (B) Shadow mode
   - (C) Data poisoning
   - (D) Fine-tuning
4. Which belongs in retirement?
   - (A) Revoking keys and disposing of data no longer justified
   - (B) Doubling the training data
   - (C) Removing it from records without archive
   - (D) Raising its risk tier
5. An urgent launch needs a gate exception. What makes it controlled?
   - (A) Verbal agreement in a corridor
   - (B) No record to avoid blame
   - (C) Permanent waiver
   - (D) A documented owner, conditions and an expiry date

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 6 · LIFECYCLE · LESSON 2 · 30 MIN

Documentation: Model Cards, Datasheets and Technical Files

Writing down what a system is, what it is for and where it fails

- Explain the purpose of model cards, datasheets and system cards
- Write documentation suited to different audiences
- Keep documentation current as systems change

Documentation is how AI governance becomes **evidence**. It lets a validator test a model, a deployer use it correctly, an auditor reconstruct decisions and a regulator assess compliance. The EU AI Act requires technical documentation for high-risk systems, ISO/IEC 42001 requires documented information, and good practice across sectors expects model and dataset documentation. The trick is to document what matters, in the right depth, and keep it current.

Common documentation artefacts

ARTEFACT	DESCRIBES	MAIN AUDIENCE
Model card	A model's purpose, performance, limits, evaluation across groups and intended use	Validators, deployers, governance
Datasheet for datasets	How a dataset was created, its composition, collection process, uses and limits	Data scientists, privacy, auditors
System card	A whole AI system: models, components, safeguards, evaluations and residual risks	Deployers, risk committees, regulators
Technical documentation	Formal file demonstrating compliance with legal requirements	Regulators, notified bodies
Instructions for use	How deployers should operate, oversee and monitor the system	Deployers and operators
Decision log	Key design choices, trade-offs and approvals with reasons	Auditors, future maintainers

What a good model card contains

MC1
Overview
Name, version, owner, date, model type.

MC2
Intended use
Purpose, users, and uses that are out of scope.

MC3
Data
Training and evaluation data, with links to datasheets.

MC4
Performance
Metrics overall and by relevant groups, with confidence intervals.

MC5
Limitations and risks
Known failure modes, conditions where it should not be relied on.

MC6
Fairness and explainability
Bias tests performed, results and explanation methods available.

MC7
Oversight and monitoring
Human oversight design, monitoring metrics and thresholds.

MC8
Change history
Versions, what changed and approvals.

Copyright © ZyeemZia

WATCH OUT · DOCUMENTATION THAT NOBODY CAN USE

A 200-page technical file that a deployer never reads does not protect anyone. Layer documentation: a one-page summary for decision-makers, a model card for practitioners and the full technical file for regulators and auditors, all consistent with each other.

TEMPLATE **Model card (summary)**

Capture the essential facts about a model in a consistent format.

FIELD	CONTENT
Intended use	*Rank nano-loan applications for approval; not for setting interest rates or collections*
Performance	*AUC 0.81 overall; 0.78 for rural applicants; 0.80 for women*

Keeping documentation alive

- Generate parts automatically from pipelines: data versions, metrics, test results.
- Make documentation updates a condition of every release gate.
- Assign a named owner for each document.
- Review documentation when the model, data, use or law changes.
- Keep superseded versions for audit, clearly marked.

EXAMPLE · DOCUMENTATION FOR A BOUGHT SYSTEM

A hospital deploying a vendor's AI scheduling tool cannot write the vendor's model card, but it can and should require one in the contract, then add its own deployment record: configuration, local validation results, oversight arrangements, staff training and monitoring plan.

Provider documentation vs deployer documentation

Provider documents

- Model design, training data, evaluation
- Intended purpose and limits
- Instructions for use
- Conformity evidence where required

Deployer documents

- Why and how the system is used locally
- Local testing on own population
- Oversight roles and training
- Monitoring, incidents, impact assessment

Copyright © ZyeemZia

SCENARIO · DECIDE · A MODEL CARD WITH ONLY GOOD NEWS

A vendor's model card for a CV-screening tool reports 92% accuracy but no results by gender, age or disability and no limitations section. Your organisation is about to sign the contract. What should you do?

(A) Sign, because 92% accuracy is high.

(B) Request group-level results, limitations and intended-use details before signing, and make them a contract deliverable; plan local testing.

(C) Write the missing sections yourself from the vendor's marketing material.

(D) Reject all vendors that publish model cards.

Circle your choice. Answer and feedback: module answer key.

Documentation readiness checklist (high-risk system)

☐ Model card complete, including group-level performance and limitations

☐ Datasheets for training and evaluation data

☐ System card or architecture description including safeguards

☐ Impact assessment linked

☐ Instructions for use and oversight design

☐ Decision log of key trade-offs and approvals

☐ Version history and change records

☐ Owner named for each document

REFLECT

If an auditor asked tomorrow for the documentation of your highest-risk AI system, what could you hand over within an hour? What is missing?

Key terms

Model card
A short structured document describing a model's intended use, performance, limits and evaluation.

System card
Documentation describing a whole AI system, including models, safeguards, evaluations and residual risks.

Instructions for use
Information from a provider telling deployers how to operate, oversee and monitor a system properly.

Out-of-scope use
A use that the provider has stated the system is not designed or validated for.

Datasheet for datasets
A structured document describing a dataset's motivation, composition, collection, uses and limitations.

Technical documentation
The formal record demonstrating that an AI system meets legal and technical requirements.

Decision log
A record of significant design decisions, alternatives considered and reasons.

KNOWLEDGE CHECK

Copyright © ZyeemZia

6. Which document describes how a dataset was created and its limits?
   - A) Privacy notice
   - B) Datasheet for datasets
   - C) Board minutes
   - D) Penetration test report

7. What is the main weakness of a model card showing only overall accuracy?
   - A) It is too short to print
   - B) It uses technical terms
   - C) It includes a version number
   - D) It hides performance differences between groups and known failure modes

8. Which is a deployer, rather than provider, document?
   - A) Local validation results and oversight arrangements
   - B) Training data description
   - C) Model architecture
   - D) Conformity evidence for the model

9. How can documentation be kept current most reliably?
   - A) Update it every five years
   - B) Make updates a release-gate condition and generate parts automatically
   - C) Let anyone edit without review
   - D) Only update after incidents

10. Why layer documentation for different audiences?
    - A) To hide information from regulators
    - B) To reduce testing
    - C) So each audience gets usable information while all versions stay consistent
    - D) Because regulators require exactly three layers

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 6 · LIFECYCLE · LESSON 3 · 35 MIN

Evaluation, Validation and Red Teaming

Proving a system is fit for purpose before and after release

- Interpret core performance metrics and choose ones that match the harm
- Evaluate generative-AI systems using test sets, rubrics and human review
- Plan and govern a red-teaming exercise

Evaluation answers a simple question with a complicated answer: **is this system good enough for this purpose, for these people, in this context?** Governance professionals do not need to compute metrics, but they must know which metrics matter, what thresholds were agreed, whether the test data was representative and whether anyone tried hard to break the system.

Core classification metrics

MEASURE	FORMULA	WHAT IT TELLS YOU
Precision	`TP / (TP + FP)`	Of the cases flagged, how many were truly positive. Low precision means many false alarms.
Recall (true positive rate)	`TP / (TP + FN)`	Of the true positives, how many were found. Low recall means many misses.
False positive rate	`FP / (FP + TN)`	Of the true negatives, how many were wrongly flagged.
F1 score	`2 × Precision × Recall / (Precision + Recall)`	A single balance of precision and recall.
Accuracy	`(TP + TN) / All cases`	Share of all predictions that were correct; misleading when one class is rare.

WATCH OUT · THE ACCURACY TRAP

If 1% of transactions are fraudulent, a model that labels everything 'not fraud' is 99% accurate and useless. Always ask which errors matter and look at precision, recall and error rates, overall and by group.

Matching the metric to the harm

USE CASE	WORST ERROR	METRIC TO WATCH
Cancer screening support	Missing a cancer (false negative)	Recall / sensitivity
Fraud investigation referrals	Accusing honest customers (false positive)	Precision and false positive rate
Spam filtering of job applications	Losing a genuine application	Recall for genuine applications
Content moderation	Both over-removal and under-removal	Precision and recall by language and dialect

Copyright © ZyeemZia

Evaluating generative AI

- Build a **golden test set** of realistic prompts with expected answers or criteria, including Bangla, English and mixed-language inputs.
- Score outputs on **groundedness** (supported by sources), correctness, completeness, tone and safety.
- Use **human reviewers** with domain expertise for high-stakes content; automated judges can help at scale but must be checked.
- Test refusals: does the system decline unsafe requests and avoid refusing legitimate ones?
- Re-run the suite on every model, prompt or retrieval change (regression testing).

A red-teaming exercise

01 Scope — System, risks to probe, rules of engagement →

02 Team — Security, domain experts, diverse testers, affected-group perspectives →

03 Attack — Jailbreaks, prompt injection, harmful content, data extraction, bias probes →

04 Record — Each finding with severity and reproduction steps →

05 Fix — Mitigations assigned to owners →

06 Retest — Confirm fixes and add cases to the regression suite

INSIGHT · DIVERSE RED TEAMS FIND DIFFERENT FAILURES

Testers who speak regional dialects, use assistive technology or come from communities the system affects will find failures a homogeneous team misses. Include them deliberately, and pay them for their expertise.

Offline testing vs live evaluation

Offline (before release)

- Held-out test data and golden sets
- Controlled and repeatable
- May not reflect real users

Live (after release)

- Shadow mode, A/B tests, staged rollout
- Shows real behaviour and drift
- Needs safeguards because real people are affected

SCENARIO · DECIDE · STRONG METRICS, WEAK TEST SET

A validation report for a clinic-triage chatbot shows 95% correct triage on 500 test conversations. You notice the test conversations were all written in formal English by the development team. The chatbot will serve patients in Bangla, English and mixed language. What should you require?

(A) Accept the result; 95% on 500 cases is statistically strong.

(B) A new evaluation with realistic conversations from the intended population in Bangla, English and mixed language, reviewed by clinicians, with results by language.

(C) Double the test set using more formal English conversations.

(D) Launch and evaluate using complaints.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE **Evaluation plan**

Define how a system will be evaluated before release.

Copyright © ZyeemZia

REQUIREMENT	METRIC	THRESHOLD	TEST DATA	EVALUATOR	RESULT
Correct urgent triage	*Recall for urgent cases*	*≥ 98%*	*600 clinician-labelled conversations in Bangla, English and mixed*	*Clinical safety lead*	*97.2%: fails; retrain and retest*
Grounded answers	*Share of answers supported by approved sources*	*≥ 95%*	*Golden set of 300 policy questions*	*Independent validator*	*96.1%: passes*

REFLECT

Which single metric would you want to see first for the highest-risk AI system you know, and why that one?

Key terms

Precision
The share of positive predictions that are correct.

Recall
The share of actual positives that a model correctly identifies; also called sensitivity or true positive rate.

False positive rate
The share of actual negatives wrongly classified as positive.

Golden test set
A curated set of inputs with expected outputs or criteria used repeatedly to evaluate a system.

Groundedness
The degree to which a generative answer is supported by the provided sources.

Regression testing
Re-running tests after changes to ensure performance has not worsened.

Staged rollout
Releasing a system to a small share of users first and expanding as evidence accumulates.

Jailbreak
A prompt technique that tries to make a model ignore its safety rules.

KNOWLEDGE CHECK

11. A model has 80 true positives and 20 false positives. Its precision is:

(A) 0.20
(B) 0.25
(C) 1.00
(D) 0.80

Copyright © ZyeemZia

12. For cancer-screening support, which metric matters most?

(A) Precision only
(B) Training time
(C) Recall
(D) Token count

13. Why can accuracy be misleading for fraud detection?

(A) Accuracy is always lower than recall
(B) Fraud is rare, so predicting 'no fraud' for everything scores highly
(C) Accuracy cannot be computed for fraud
(D) Fraud models have no errors

14. What makes red teaming more effective?

(A) Diverse testers, including people from affected communities
(B) Only the original developers
(C) Testing only with typical inputs
(D) Skipping documentation of findings

15. When should a generative-AI regression suite be re-run?

(A) Once a year only
(B) Only after a complaint
(C) After every model, prompt or retrieval change
(D) Never once launched

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 6 · LIFECYCLE · LESSON 4 · 35 MIN

Bias Testing and Fairness Metrics

Measuring group differences, setting thresholds and mitigating bias

- Calculate and interpret common group fairness metrics
- Plan a bias test, including intersectional analysis and access to protected attributes
- Choose bias mitigation approaches across the pipeline

Module 2 explained why fairness is a values decision. This lesson turns that decision into **measurement**. A bias test compares how a system treats different groups, using metrics chosen for the harm at stake, against thresholds agreed in advance. The results go into the model card, the impact assessment and the release gate.

Common group fairness metrics

MEASURE	FORMULA	WHAT IT TELLS YOU
Selection rate	`Selection rate (group) = Positive outcomes in group / People in group`	The basic building block: what share of each group is approved, hired or flagged.
Demographic parity difference	`DPD = Selection rate (A) − Selection rate (B)`	Zero means equal selection rates; a common target is a small absolute gap.
Disparate impact ratio	`DIR = Selection rate (disadvantaged group) / Selection rate (advantaged group)`	A ratio below 0.8 (the 'four-fifths' rule of thumb from US employment practice) is a common warning sign.
Equal opportunity difference	`EOD = TPR (A) − TPR (B)`	Compares how often truly qualified people in each group are correctly approved.
False positive rate difference	`FPRD = FPR (A) − FPR (B)`	Compares how often people in each group are wrongly flagged; key for fraud and policing.
Equalised odds	`TPR and FPR both equal across groups`	A stricter condition requiring both error rates to match.

EXAMPLE · WORKED EXAMPLE: HIRING SCREEN

Of 400 male applicants, 120 pass an AI screen (selection rate 0.30). Of 300 female applicants, 60 pass (0.20). The disparate impact ratio is 0.20 / 0.30 = 0.67, below the 0.8 warning level, and the demographic parity difference is 0.10. This does not prove unlawful discrimination, but it requires investigation of features, labels and alternatives before release.

Copyright © ZyeemZia

Computing selection rates and the disparate impact ratio

Python notebook

```
# results: one row per applicant with 'group' and 'selected' (1 or 0)
import pandas as pd
results = pd.read_csv('screening_results.csv')
rates = results.groupby('group')['selected'].mean()
print(rates)
dir_ratio = rates.min() / rates.max()
print(f'Disparate impact ratio: {dir_ratio:.2f}')
# Flag for review if below the agreed threshold
if dir_ratio < 0.8:
    print('Below threshold: investigate before release')
```

Run the same calculation for every relevant group and intersection, and report sample sizes alongside rates.

Planning a bias test

1. **Select groups** Protected characteristics relevant to law and context, plus local factors such as region, language or disability.
2. **Include intersections** For example rural women or older applicants with disabilities, with minimum sample sizes.
3. **Choose metrics** Match metrics to the main harm, as agreed in the impact assessment.
4. **Agree thresholds in advance** Set acceptable gaps before seeing results, with justification.
5. **Obtain group data lawfully** Use voluntary self-identification, secure test environments or statistical inference, with privacy safeguards.
6. **Run, analyse, report** Include confidence intervals; small groups give unstable numbers.
7. **Decide and document** Release, mitigate or reject, with reasons recorded.

WATCH OUT · THE PROTECTED-ATTRIBUTE PARADOX

You often need data on sex, religion or ethnicity to test whether a model discriminates on those grounds, yet collecting it raises privacy concerns. Plan this deliberately with the privacy officer: lawful basis, separation from the model, restricted access and use only for testing.

Bias mitigation across the pipeline

STAGE	APPROACH	EXAMPLE
Pre-processing (data)	Improve or rebalance data	Collect more data for under-represented regions; reweight samples; fix biased labels
In-processing (model)	Add fairness constraints during training	Train with a constraint limiting the false-positive-rate gap
Post-processing (outputs)	Adjust decision thresholds or outputs	Review borderline refusals for groups with higher error rates
Process and context	Change how outputs are used	Human review of all adverse decisions; alternative evidence routes for thin-file applicants

INSIGHT · MITIGATION NEEDS LEGAL REVIEW

Some mitigation methods, such as using different thresholds for different groups, may be unlawful in certain jurisdictions or sectors even when intended to improve fairness. Agree the approach with legal counsel.

Copyright © ZyeemZia

SCENARIO · DECIDE · A FAILED BIAS TEST BEFORE LAUNCH

A credit model for small business loans in Bangladesh has a disparate impact ratio of 0.72 for women-owned businesses. Investigation shows the model relies heavily on 'years of registered trade licence', and many women-owned businesses are newer or informally registered. What is the BEST next step?

(A) Launch anyway, because the model is accurate overall.

(B) Remove the gender field from the model.

(C) Explore alternative features such as transaction history, test mitigation options with legal review, re-test, and add human review for borderline applications.

(D) Lower the approval threshold for everyone until the ratio passes.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE **Bias test report**

Report fairness results in a consistent format for the release gate.

GROUP COMPARISON	METRIC	RESULT	THRESHOLD	SAMPLE SIZES	PASS OR FAIL	ACTION
Women vs men applicants	*Disparate impact ratio*	*0.72*	*≥ 0.80*	*1,240 / 3,880*	*Fail*	*Replace licence-years feature; re-test*
Rural vs urban applicants	*Equal opportunity difference*	*−0.04*	*Within ±0.05*	*2,100 / 3,020*	*Pass*	*Monitor quarterly*

REFLECT

For one AI decision in your organisation, which two groups would you compare first, which metric would you use, and what threshold would you defend publicly?

Copyright © ZyeemZia

Key terms

Selection rate
The share of a group receiving a positive outcome, such as approval.

Disparate impact ratio
The selection rate of one group divided by that of another; values below 0.8 often trigger review.

Equal opportunity
A fairness condition in which true positive rates are equal across groups.

Reweighting
A pre-processing technique that gives different weights to training examples to reduce bias.

Demographic parity
A fairness condition in which selection rates are equal across groups.

Four-fifths rule
A rule of thumb from US employment practice that a selection-rate ratio below 80% may indicate adverse impact.

Equalised odds
A fairness condition in which both true positive and false positive rates are equal across groups.

Intersectional analysis
Testing outcomes for combinations of characteristics, not just single groups.

KNOWLEDGE CHECK

16. Group A has a selection rate of 0.50 and group B 0.35. The disparate impact ratio (B to A) is:

(A) 0.70
(B) 0.15
(C) 1.43
(D) 0.85

17. Which metric compares how often truly qualified people in each group are correctly approved?

(A) Demographic parity difference
(B) Equal opportunity difference
(C) Accuracy
(D) Latency

18. Why should fairness thresholds be agreed before seeing results?

(A) Because results are always good
(B) Because regulators set every threshold
(C) To save storage space
(D) To avoid choosing thresholds that make results look acceptable after the fact

19. Reweighting training examples is which type of mitigation?

(A) Post-processing
(B) In-processing
(C) Pre-processing
(D) Incident response

20. Why report sample sizes with fairness results?

(A) Small groups give unstable results that need cautious interpretation
(B) To make reports longer
(C) Because metrics need no context
(D) To reveal identities

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 6 · LIFECYCLE · LESSON 5 · 30 MIN

Explainability in Practice

Choosing explanation methods people can trust and use

- Distinguish global and local explanations, and interpretable versus post-hoc methods
- Select explanation methods suited to the audience and use case
- Recognise the limits of explanations, including for generative AI

Explainability serves people: a customer who wants to know why a loan was refused, a doctor deciding whether to trust a triage suggestion, a validator checking that a model relies on sensible factors, a regulator assessing compliance. Each needs a different kind of explanation. The governance task is to **decide what explanation each audience needs and verify that the method actually delivers it**.

Global vs local explanations

Global

- How the model behaves overall
- Which features matter most across all cases
- Audience: validators, risk committees, regulators

Local

- Why this particular output was produced
- Main factors for one decision
- Audience: affected individuals, case reviewers

Explanation methods

METHOD	TYPE	WHAT IT SHOWS	CAUTION
Interpretable models (scorecards, small trees, linear models)	Intrinsic	Logic visible directly	May lose some accuracy on complex tasks
Feature importance	Global, post-hoc	Which inputs influence predictions most overall	Can mislead when features are correlated
Shapley-value methods (e.g. SHAP)	Local and global, post-hoc	Contribution of each feature to a specific prediction	Computationally heavy; approximations vary
Local surrogate models (e.g. LIME)	Local, post-hoc	A simple model mimicking behaviour near one case	Results can be unstable between runs
Counterfactual explanations	Local	What would need to change for a different outcome	Must suggest feasible, lawful changes
Partial dependence plots	Global	How predictions change as one feature varies	Assumes features are independent

INSIGHT · USE AN INTERPRETABLE MODEL WHERE YOU CAN

For many high-stakes decisions on structured data, such as credit and eligibility, interpretable models perform nearly as well as complex ones. An inherently interpretable model avoids the risk that a post-hoc explanation tells a story that differs from what the model actually does.

EXAMPLE · A COUNTERFACTUAL FOR A LOAN APPLICANT

'Your application would likely have been approved if your average monthly wallet balance over the last six months had been above BDT 8,000, or if you had 12 months of regular top-ups rather than 7.' Good counterfactuals are actionable, truthful and avoid features the person cannot change, such as age.

Copyright © ZyeemZia

Explaining generative-AI outputs

- Show **citations** to the source documents used, so users can check claims.
- Explain the system's purpose, data sources and known limits in plain language.
- Do not treat a model's self-described reasoning as a faithful account of how it produced the answer.
- Log prompts, retrieved sources and outputs so investigators can reconstruct what happened.
- For decisions about people, do not rely on a generative model's free-text justification as the explanation of record.

Testing an explanation method

E1
Fidelity
Does the explanation reflect what the model actually does? Test by perturbing important features.

E2
Stability
Do similar cases receive similar explanations?

E3
Comprehensibility
Can the intended audience understand and act on it? Test with real users.

E4
Actionability
Does it tell people what they could change or how to contest?

E5
Safety
Does it avoid revealing confidential data or enabling gaming of the system?

SCENARIO · DECIDE · A BEAUTIFUL BUT UNFAITHFUL EXPLANATION

A vendor offers a dashboard that produces fluent, natural-language explanations for each insurance claim the model flags. Your validator finds the explanations often cite factors that have little effect when tested. What should you do?

(A) Use it, because customers will find the explanations reassuring.

(B) Do not rely on these explanations; require a method whose fidelity is tested, or use a more interpretable model, and confirm results with users.

(C) Add a disclaimer that explanations may not be accurate.

(D) Stop explaining decisions altogether.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE **Explanation requirements by audience**

Specify what explanation each audience needs and how it will be delivered and tested.

AUDIENCE	QUESTION THEY ASK	EXPLANATION TYPE	METHOD	DELIVERY	HOW TESTED
Refused loan applicant	*Why was I refused and what can I do?*	*Local, counterfactual*	*Reason codes from scorecard plus counterfactual*	*SMS and letter with appeal route*	*User testing with 20 customers; fidelity checked by validator*

Copyright © ZyeemZia

AUDIENCE	QUESTION THEY ASK	EXPLANATION TYPE	METHOD	DELIVERY	HOW TESTED

REFLECT

Think of an AI-assisted decision about you, such as a credit limit or a content recommendation. What explanation would you actually want, and would the organisation be able to give it?

Key terms

Global explanation
A description of how a model behaves across all cases, such as which features matter most.

Local explanation
The reasons for one specific prediction or decision.

Post-hoc explanation
An explanation produced after a model is trained, by analysing its behaviour.

Shapley values
A method from game theory that attributes a prediction to each input feature's contribution.

Counterfactual explanation
A statement of what would need to change in the input for the outcome to differ.

Fidelity
How accurately an explanation reflects the model's actual behaviour.

Reason codes
Short standardised statements of the main factors behind a decision, common in credit scoring.

Interpretable model
A model whose logic people can follow directly, such as a scorecard or small decision tree.

KNOWLEDGE CHECK

21. A customer asks why her claim was flagged. Which type of explanation does she need?
    - (A) Global
    - (B) Local
    - (C) Architectural
    - (D) Financial

22. Which property asks whether an explanation reflects what the model actually does?
    - (A) Comprehensibility
    - (B) Brevity
    - (C) Latency
    - (D) Fidelity

23. Why prefer interpretable models for many structured high-stakes decisions?
    - (A) They are always more accurate
    - (B) Regulators ban complex models
    - (C) They often perform nearly as well and avoid unfaithful post-hoc stories
    - (D) They need no testing

24. Which is a good counterfactual explanation?
    - (A) Approval was likely with six more months of regular top-ups
    - (B) You would be approved if you were younger
    - (C) The model weights are confidential
    - (D) Our AI decided

Copyright © ZyeemZia

25. How should a generative model's self-described reasoning be treated?

(A) As legal proof of its process
(B) As identical to Shapley values
(C) Not as a faithful account of how it produced the answer
(D) As unnecessary to log

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 6 · LIFECYCLE

Answer key

Knowledge checks

1. C Early decisions are easier and cheaper to change.

2. D Independence is the essential feature of validation.

3. B Shadow mode compares outputs safely before go-live.

4. A Retirement closes access, archives records and disposes of unneeded data.

5. D Exceptions must be recorded, conditional and time-limited.

6. B Datasheets record dataset motivation, composition, collection and limits.

7. D Group-level results and limitations are essential for judging fairness and fitness.

8. A Deployers document how they use and oversee the system locally.

9. B Linking documentation to releases and pipelines keeps it accurate.

10. C Layering makes documentation usable without losing completeness.

11. D Precision = TP / (TP + FP) = 80 / 100 = 0.80.

12. C Missing cancers (false negatives) is the worst error, so recall is critical.

13. B Class imbalance makes accuracy a poor guide.

14. A Diverse perspectives find failures homogeneous teams miss.

15. C Small changes can alter behaviour unexpectedly.

16. A 0.35 / 0.50 = 0.70, which is below the 0.8 warning level.

17. B Equal opportunity compares true positive rates.

18. D Pre-agreement prevents motivated reasoning.

19. C It changes the data before training.

20. A Statistical uncertainty is high for small samples.

21. B She needs reasons for her specific case.

22. D Fidelity tests the faithfulness of an explanation.

23. C Interpretable models make the real logic visible.

24. A Good counterfactuals are actionable and avoid unchangeable traits.

25. C Self-reports can diverge from the actual computation.

Scenarios & case studies

> **Scenario · Skipping a gate**
> **B** is best. Best. It responds to the business need while keeping essential checks, limits exposure and documents a controlled exception.

> **Scenario · A model card with only good news**
> **B** is best. Best. Missing group results and limitations are red flags for a high-risk hiring tool. Making them contractual and testing locally protects candidates and the organisation.

> **Scenario · Strong metrics, weak test set**
> **B** is best. Best. Validation must reflect the real population and context, and clinicians must judge triage correctness.

> **Scenario · A failed bias test before launch**
> **C** is best. Best. It addresses the cause, keeps the solution lawful, verifies the effect and adds a safeguard.

> **Scenario · A beautiful but unfaithful explanation**
> **B** is best. Best. Fidelity is essential. An explanation that does not reflect the model is worse than none.

Copyright © ZyeemZia

07

MODULE 7 · OPERATIONS

Operating AI Safely: Monitoring, Use Policy, Suppliers and Incidents

Keep AI under control after launch: drift, generative-AI use, third parties and incident response

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Design monitoring for performance, fairness, data drift and human oversight, with thresholds and owners
- Govern model changes, retraining and vendor updates through change control
- Write and roll out a generative-AI acceptable-use policy supported by AI literacy
- Manage AI supplier risk through due diligence, contract terms and ongoing oversight
- Run AI incident response, including severity, containment, reporting duties and learning

LESSONS

1. Monitoring, Drift and Change Control · 35 min
2. Generative-AI Policy and Acceptable Use · 35 min
3. Third-Party and Procurement Risk · 35 min
4. AI Incident Management · 35 min

MODULE 7 · OPERATIONS · LESSON 1 · 35 MIN

Monitoring, Drift and Change Control

Keeping AI systems safe and effective after launch

- Distinguish data drift, concept drift and other changes that degrade AI systems
- Design a monitoring plan with metrics, thresholds, owners and actions
- Govern model changes, retraining and vendor updates

Launch is the start of an AI system's riskiest period, not the end. Real users behave differently from test data, the world changes, attackers probe the system, and vendors update models behind their APIs. **Monitoring** detects when performance, fairness or safety slips; **change control** makes sure fixes and updates do not create new problems.

Types of drift

Data drift

- The distribution of inputs changes
- Example: a new mobile wallet changes transaction patterns
- Detectable without labels

Concept drift

- The relationship between inputs and outcome changes
- Example: fraudsters adopt a new technique, so old signals no longer predict fraud
- Usually needs outcome labels to confirm

Upstream and vendor change

- A source system, feature definition or third-party model changes
- Example: a provider silently updates its language model
- Detect with contracts, version checks and regression tests

Drift and monitoring measures

MEASURE	FORMULA	WHAT IT TELLS YOU
Population stability index	`PSI = Σ (A_i − E_i) × ln(A_i / E_i)`	Compares the share of cases in each bin now (A) with the baseline (E). A common rule of thumb: below 0.1 little shift, 0.1 to 0.25 moderate, above 0.25 significant.
Performance change	`Δ = Metric (current window) − Metric (validation baseline)`	Tracks whether recall, precision or error rates have fallen since approval.
Override rate	`Overrides / Total reviewed recommendations`	Rising rates may signal declining quality; near-zero may signal automation bias.

What to monitor

AREA	EXAMPLE METRICS	EXAMPLE THRESHOLD AND ACTION
Performance	Precision, recall, groundedness score	Recall below 0.90 for two weeks: alert model owner, review
Fairness	Disparate impact ratio, error-rate gaps	Ratio below 0.8: escalate to AI governance office within 5 days
Data quality	Missing values, out-of-range inputs, PSI	PSI above 0.25 on a key feature: investigate before next release
Safety and security	Blocked prompts, jailbreak attempts, harmful-output reports	Spike above baseline: security review same day

Copyright © ZyeemZia

AREA	EXAMPLE METRICS	EXAMPLE THRESHOLD AND ACTION
Human oversight	Override rate, review time	Override rate under 1% with review time under 30 seconds: check reviewer engagement
Outcomes and complaints	Complaints, appeals upheld, customer satisfaction	Upheld appeals double: root-cause review

PRO TIP · MONITOR OUTCOMES, NOT JUST MODELS

Model metrics can look healthy while real-world outcomes worsen. Pair technical monitoring with business and human signals: complaints, appeals, frontline feedback and audits of samples of decisions.

From alert to action

01 Detect — Automated alert or human report →
02 Triage — Is it noise, drift, a bug or an incident? →
03 Decide — Accept, adjust threshold, retrain, roll back or pause →
04 Change — Through change control with testing →
05 Verify — Confirm the fix with monitoring →
06 Record — Update model card, risk register and logs

Classifying changes

CHANGE TYPE	EXAMPLES	GOVERNANCE REQUIRED
Minor	Retraining on new data with unchanged features and design; threshold tweak within approved range	Automated regression tests, owner approval, record
Significant	New features, new data source, new model architecture, new vendor model version	Re-validation, bias tests, gate approval
Substantial (purpose or risk change)	New use, new population, new market, change that raises the tier	Back through intake and impact assessment; possible change of legal role

WATCH OUT · SILENT VENDOR UPDATES

Many generative-AI services update underlying models without notice or with short notice. Pin model versions where possible, require advance notification in contracts, and run your regression suite against new versions before switching.

SCENARIO · DECIDE · DRIFT ALERT ON A CREDIT MODEL

A nano-loan model's PSI on 'average monthly top-up' rises to 0.31 after a new government stipend begins paying many rural households through mobile wallets. Approval rates in rural areas rise sharply. What should the model owner do FIRST?

(A) Retrain immediately on the latest month of data.

(B) Triage the alert: analyse whether stipend income changes repayment risk, check default early indicators and fairness metrics, and decide on adjustment through change control.

(C) Ignore it, because higher approvals are good for business.

(D) Shut the model down until the stipend programme ends.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE **Monitoring plan**

Copyright © ZyeemZia

Define what will be monitored for an AI system, how often, by whom and with what response.

METRIC	DATA SOURCE	FREQUENCY	THRESHOLD	OWNER	ACTION WHEN BREACHED
Recall on confirmed fraud	*Case management outcomes*	*Weekly*	*Below 0.85 for 2 weeks*	*Fraud model owner*	*Root-cause review; retrain via change control*
False positive rate gap by region	*Alerts and outcomes by district*	*Monthly*	*Gap above 3 percentage points*	*AI governance office*	*Escalate; fairness review within 10 days*

REFLECT

For one AI system you know, what would be the first sign that it had started to fail, and who would notice? How long might it run unnoticed?

Key terms

Data drift
A change in the distribution of input data compared with the data the model was trained or validated on.

Population stability index (PSI)
A measure of how much a variable's distribution has shifted from a baseline.

Model version pinning
Fixing an application to a specific model version so it does not change without deliberate action.

Monitoring threshold
A pre-agreed value of a metric that triggers review or action when crossed.

Concept drift
A change in the relationship between inputs and the outcome a model predicts.

Change control
A process for assessing, testing, approving and recording changes to a system.

Rollback
Returning a system to a previous, known-good version.

Alert fatigue
Reduced responsiveness when monitoring produces so many alerts that real problems are missed.

KNOWLEDGE CHECK

Copyright © ZyeemZia

1. Fraudsters adopt a new technique so old signals stop predicting fraud. This is:

   (A) Data minimisation
   (B) Pseudonymisation
   (C) Prompt injection
   (D) Concept drift

2. A PSI of 0.31 on a key feature usually indicates:

   (A) No change at all
   (B) A perfect model
   (C) A significant shift needing investigation
   (D) An encryption failure

3. Which change should go back through intake and impact assessment?

   (A) Using the model for a new population or purpose
   (B) Routine retraining with unchanged design
   (C) Fixing a typo in a dashboard
   (D) Rotating an API key

4. Why pair model metrics with complaints and appeals?

   (A) Complaints replace all metrics
   (B) Real-world outcomes can worsen while model metrics look healthy
   (C) Model metrics are illegal
   (D) Appeals are always wrong

5. What is the best defence against silent vendor model updates?

   (A) Version pinning, notice clauses and regression testing before switching
   (B) Trusting the vendor
   (C) Turning off monitoring
   (D) Using shorter prompts

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 7 · OPERATIONS · LESSON 2 · 35 MIN

Generative-AI Policy and Acceptable Use

Rules that let people use generative AI productively and safely

- Structure a generative-AI acceptable-use policy
- Define which data may be used with which tools
- Set rules for human review, disclosure and prohibited uses
- Plan AI literacy so the policy is understood and followed

Generative AI is the first AI technology that almost every employee uses directly. That makes an **acceptable-use policy** one of the most visible governance documents in the organisation. A good one is short, specific and enabling: it tells people which tools they may use, with which data, for which tasks, and what they must check before relying on or sharing the output.

Elements of a generative-AI acceptable-use policy

U1
Approved tools
List of approved tools and how to request new ones; personal accounts not used for work data.

U2
Data rules
Which classes of data may be entered into which tools.

U3
Permitted and prohibited uses
Clear examples of encouraged, restricted and banned uses.

U4
Human review
Outputs checked by a competent person before use, in proportion to impact.

U5
Disclosure and labelling
When to tell customers, colleagues or the public that content is AI-generated.

U6
Intellectual property
Rules on copyrighted inputs, code licences and ownership of outputs.

U7
Accountability
The person using AI remains responsible for the work product.

U8
Reporting
How to report errors, harmful outputs or suspected data leaks.

Data and tool matrix (example)

DATA CLASS	PUBLIC CHAT ASSISTANT (PERSONAL ACCOUNT)	APPROVED ENTERPRISE ASSISTANT	INTERNAL ASSISTANT ON COMPANY DATA
Public information	Allowed	Allowed	Allowed
Internal (non-confidential)	Not allowed	Allowed	Allowed
Confidential business data	Not allowed	Allowed with care	Allowed per permissions
Customer personal data	Not allowed	Only for approved use cases	Only for approved use cases
Sensitive personal data (health, biometrics)	Not allowed	Not allowed unless specifically approved	Only for specifically approved use cases
Secrets (passwords, keys, source code under restriction)	Never	Never	Never

Copyright © ZyeemZia

Encouraged, restricted and prohibited uses (example)

Encouraged

- Drafting and editing internal documents
- Summarising public research
- Brainstorming and translation of non-confidential text
- Coding help on non-restricted code

Restricted (approval or review needed)

- Customer-facing content
- Analysis of personal data
- Decisions about employees or customers
- Legal, medical or financial advice

Prohibited

- Generating deceptive deepfakes of real people
- Entering secrets or credentials
- Uses that breach law or the prohibited-practices list
- Bypassing safety controls

WATCH OUT · ACCOUNTABILITY DOES NOT MOVE TO THE TOOL

'The AI wrote it' is never a defence. If a lawyer files a brief with invented cases, a doctor signs an AI-drafted report with an error, or a marketer publishes infringing images, the person and the organisation remain responsible. Courts in several countries have sanctioned lawyers for citing non-existent cases generated by AI.

Human review in proportion to impact

- **Low impact** (internal drafts): author reads and edits before sharing.
- **Medium impact** (external communications): author verifies facts, figures and tone; manager review for sensitive topics.
- **High impact** (advice, decisions, regulated content): qualified professional verifies against sources; record that review took place.
- Never rely on AI output for facts, citations, figures or legal or medical statements without checking the source.

Rolling out the policy with AI literacy

1. **Explain why** Short sessions on what generative AI is, how it fails and why the rules exist.
2. **Role-based training** Extra modules for lawyers, clinicians, engineers, HR and customer-facing staff.
3. **Provide good tools** Approved tools that are as easy as public ones remove the reason to break rules.
4. **Share examples** A library of good prompts and real near-misses.
5. **Make reporting easy** A simple channel for questions, errors and incidents, with no blame for honest reports.
6. **Measure and refresh** Track training completion, approved-tool usage and incidents; update the policy every six to twelve months.

DEFINITION · AI LITERACY

The knowledge and skills that let people use AI in an informed way and understand its opportunities, risks and possible harms. The EU AI Act has required providers and deployers to take measures to ensure sufficient AI literacy of their staff since February 2025; it is good practice everywhere.

Copyright © ZyeemZia

SCENARIO · DECIDE · A LAWYER'S SHORTCUT

A junior associate at a Dhaka law firm uses an approved enterprise assistant to draft a court submission and includes three case citations from the output without checking them. A senior partner notices one citation looks unfamiliar. What should the firm do?

(A) Submit as drafted, because the tool is approved.

(B) Verify every citation against authoritative sources before filing, correct the submission, and reinforce the rule that legal authorities must always be checked, with no-blame learning for the associate.

(C) Ban the associate from using AI permanently.

(D) Ask the assistant whether the citations are real.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE

Generative-AI use-case register (team level)

Record approved team uses of generative AI and the conditions that apply.

TEAM AND USE CASE	TOOL	DATA ALLOWED	REVIEW REQUIRED	DISCLOSURE	APPROVED BY
Customer service: draft email replies	*Enterprise assistant*	*Customer name and complaint text*	*Agent reviews and edits every reply*	*Not required for agent-sent emails; chatbot replies labelled*	*Head of Customer Service*
Marketing: social media images	*Approved image generator*	*Public brand assets only*	*Brand manager approves*	*Label synthetic images showing people*	*Head of Marketing*

REFLECT

Write the three rules from a generative-AI policy that you think would prevent the most harm in your organisation. Are they currently written down, and do people follow them?

Key terms

Acceptable-use policy
Rules stating how employees may and may not use a technology, such as generative AI.

Approved tool
A generative-AI tool assessed and authorised for work use under defined conditions.

Copyright © ZyeemZia

Data classification
A scheme that labels data by sensitivity, such as public, internal, confidential and restricted.

AI-generated content label
A notice or mark indicating that content was created or altered by AI.

Prompt hygiene
Practices for writing prompts that exclude unnecessary sensitive data and give clear, checkable instructions.

Human review
Checking AI output by a competent person before it is relied on or shared.

Near-miss
An event that could have caused harm but was caught in time; valuable for learning.

KNOWLEDGE CHECK

6. Which data should never be entered into any generative-AI tool?
   - (A) Public press releases
   - (B) Internal meeting agendas
   - (C) Passwords, keys and other secrets
   - (D) Published research
7. Who is responsible for a report drafted with AI and sent to a client?
   - (A) The person who sent it and their organisation
   - (B) The AI vendor alone
   - (C) Nobody
   - (D) The model itself
8. Why provide approved tools that are easy to use?
   - (A) To increase licence costs
   - (B) Good approved tools remove the reason to use unapproved ones
   - (C) To avoid training
   - (D) Because personal accounts are faster
9. Since when has the EU AI Act required measures for staff AI literacy?
   - (A) January 2030
   - (B) It never has
   - (C) Only from 2028
   - (D) February 2025
10. What is the correct way to check an AI-generated legal citation?
    - (A) Ask the same assistant
    - (B) Check that it is formatted correctly
    - (C) Look it up in an authoritative legal source
    - (D) Assume it is right if the tool is approved

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 7 · OPERATIONS · LESSON 3 · 35 MIN

Third-Party and Procurement Risk

Buying AI safely: due diligence, contracts and ongoing oversight of suppliers

- Identify AI-specific risks in buying products, APIs and models
- Run proportionate due diligence on AI suppliers
- Negotiate contract terms that protect the organisation and the people affected
- Monitor suppliers through the life of the contract

Most organisations will buy far more AI than they build. Every purchase brings the supplier's design choices, data practices and weaknesses into your operations, while accountability to customers and regulators stays with you. **Third-party AI risk management** extends normal vendor management with questions about models, data, testing and change, and it starts before the contract is signed.

AI-specific supplier risks

RISK	EXAMPLE	CONTROL
Opaque model and data	Vendor cannot say what data trained the model	Documentation requirements, model and system cards
Use of your data	Prompts or customer data used to train vendor models	Contractual prohibition and technical opt-out
Unannounced change	Model updated; behaviour shifts	Change notification, version pinning, regression testing
Fourth parties	Vendor relies on another company's foundation model	Disclosure of sub-processors and model providers
Concentration	Many critical processes depend on one model provider	Exit plans, multi-provider architecture
Intellectual property	Outputs infringe third-party rights	IP warranties and indemnity, output filters
Regulatory role confusion	Unclear who is provider and who is deployer	Contract allocates roles and compliance duties

AI procurement process

01 **Need** — Business case and intake tier → 02 **Market scan** — Shortlist, including open-weight options → 03 **Due diligence** — Questionnaire, evidence, demos, testing → 04 **Local testing** — Pilot on own data and population → 05 **Contract** — AI-specific clauses negotiated → 06 **Onboard** — Inventory, monitoring, owner assigned → 07 **Oversee** — Reviews, renewals, exit

Copyright © ZyeemZia

Core due-diligence questions

- What is the intended purpose, and which uses are out of scope?
- Which models are used, who provides them and where are they hosted?
- What data trained the model, and do you have rights to it?
- How was the system tested for accuracy, bias and robustness, and can we see results by group?
- Will our data be used to train or improve your models?
- How do you notify customers of model changes, and can we pin versions?
- What security testing and certifications do you hold, and what is their scope?
- How do you handle and notify incidents?
- What support do you provide for explanations, logs and individuals' rights?
- How do you help us meet our legal obligations, such as under the EU AI Act?

Key AI contract clauses

CLAUSE	PURPOSE
Data use and confidentiality	Prohibit use of customer data for training without explicit agreement; define retention and deletion
Documentation and transparency	Deliver model cards, instructions for use and evidence needed for compliance
Change notification	Advance notice of material model or data changes; right to test before switching
Performance and fairness warranties	Commit to agreed metrics, including by group, with remedies
Audit and information rights	Allow assessments, questionnaires or independent audit reports
Incident notification	Notify within a defined period and cooperate in investigations
Intellectual property	Warranties and indemnity for infringement by the system or its outputs
Regulatory roles and cooperation	Allocate provider and deployer duties; support regulator requests
Exit and transition	Data return, deletion certificates, transition help

INSIGHT · OPEN-WEIGHT MODELS ARE THIRD-PARTY RISK TOO

Downloading an open-weight model avoids an API contract but not supplier risk. Check the licence (some restrict commercial use or certain applications), the documentation, known vulnerabilities and the provenance of the files, and remember that you take on more of the provider-style responsibilities when you deploy and modify it.

TEMPLATE ### AI supplier due-diligence summary

Summarise due diligence on an AI supplier for the approval decision.

SUPPLIER AND PRODUCT	USE CASE AND TIER	KEY EVIDENCE RECEIVED	GAPS FOUND	CONTRACT MITIGATIONS	DECISION
HR-tech vendor: CV screening	*Shortlisting graduates; high*	*Model card, ISO/IEC 27001 certificate, security test summary*	*No group-level results; no change notice; vendor trains on client data*	*Group results and annual bias audit as deliverables; 60-day change notice; no training on our data*	*Approve after local bias test passes*

Copyright © ZyeemZia

SUPPLIER AND PRODUCT	USE CASE AND TIER	KEY EVIDENCE RECEIVED	GAPS FOUND	CONTRACT MITIGATIONS	DECISION

CASE STUDY · THE CALL-CENTRE ANALYTICS CONTRACT

A Bangladeshi telecom operator is buying a cloud service that transcribes customer calls in Bangla and English, scores agent performance and flags 'at-risk' customers for retention offers. The vendor's standard contract allows it to use recordings to improve its models, gives 7 days' notice of changes and limits its liability to one month's fees. The vendor relies on a foundation model from another company.

1. Which risks are most significant?

2. Which contract changes would you negotiate?

3. What would you check before go-live?

Model answer: module answer key.

SCENARIO · DECIDE · RENEWAL WITHOUT REVIEW

A three-year contract for an AI credit-decisioning platform is up for automatic renewal next month. Since signing, the vendor has changed its underlying model twice and moved hosting to another country. Nobody has reviewed the supplier since onboarding. What should the governance lead do?

(A) Let it renew; the platform still works.

(B) Trigger a renewal review: reassess due diligence for the model changes and hosting move, test current performance and fairness, and renegotiate gaps before renewing.

(C) Cancel the contract immediately.

(D) Ask the vendor to confirm in an email that nothing important has changed.

Circle your choice. Answer and feedback: module answer key.

Copyright © ZyeemZia

REFLECT

Which AI supplier would hurt your organisation most if it failed, changed its model or misused your data tomorrow? What contractual or technical protection do you have today?

Key terms

Third-party risk management
Identifying, assessing and controlling risks arising from suppliers and partners.

Fourth party
A supplier's own supplier, such as the foundation-model provider behind an AI product.

Change notification clause
A contract term requiring advance notice of material changes to a product or service.

Exit plan
A plan for moving away from a supplier, covering data, transition and continuity.

Due diligence
Investigation of a supplier before contracting to assess its capability, controls and risks.

Concentration risk
Exposure from relying heavily on a single supplier or technology.

Open-weight model
A model whose trained parameters are published for others to download and run, under a licence.

Right to audit
A contract term allowing the customer, or an independent party, to assess the supplier's compliance.

KNOWLEDGE CHECK

11. A vendor's AI product relies on another company's foundation model. That company is a:
    - (A) Fourth party
    - (B) Deployer
    - (C) Data subject
    - (D) Regulator
12. Which clause most directly prevents your customer data from improving a vendor's models?
    - (A) Exit clause
    - (B) Data use clause prohibiting training on customer data
    - (C) Payment terms
    - (D) Governing law
13. Why is contract renewal an important control point?
    - (A) It is when the organisation has most leverage to fix gaps
    - (B) Renewals are legally required to be reviewed by regulators
    - (C) Vendors cannot change products before renewal
    - (D) Risks disappear after three years
14. What is the main risk of relying on one model provider for many critical processes?
    - (A) Data minimisation
    - (B) Interpretability
    - (C) Concentration risk
    - (D) Overfitting
15. What should you check before deploying an open-weight model?
    - (A) Nothing, because it is free
    - (B) Only its download speed
    - (C) Only its popularity
    - (D) Licence terms, documentation, vulnerabilities and file provenance

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 7 · OPERATIONS · LESSON 4 · 35 MIN

AI Incident Management

Detecting, containing, reporting and learning from AI failures

- Define AI incidents and classify their severity
- Run the AI incident response lifecycle from detection to lessons learned
- Identify legal reporting duties that may apply to AI incidents
- Prepare playbooks for common generative-AI incidents

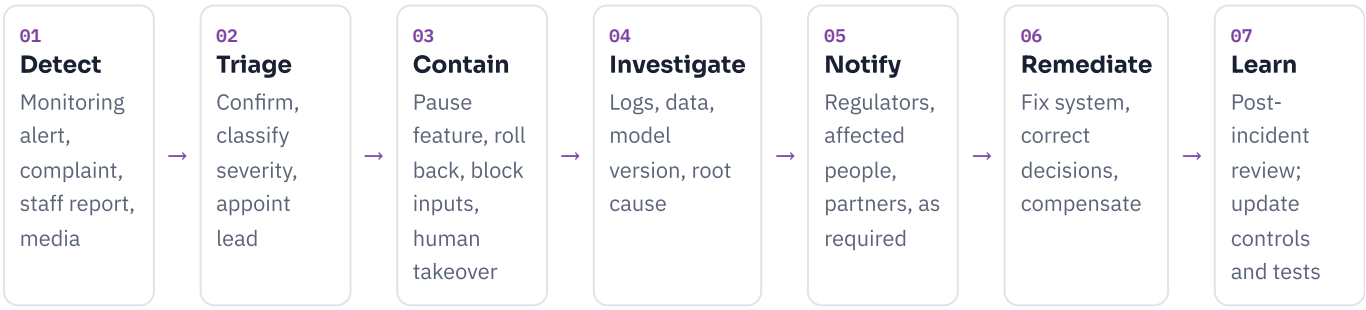
Every organisation that uses AI will have AI incidents. The difference between a manageable event and a crisis is usually preparation: knowing what counts as an incident, who decides, how to stop harm quickly, who must be told and by when, and how to learn. AI incidents need the same discipline as security incidents, plus attention to harms that are not security breaches at all, such as discriminatory outcomes or dangerous advice.

> DEFINITION · AI INCIDENT
> An event in which the development, use or malfunction of an AI system results in, or could plausibly result in, harm to people, property, the environment, rights or the organisation. A **near-miss** is an event that could have caused harm but did not. Both should be recorded.

Severity levels (example)

LEVEL	DESCRIPTION	EXAMPLE	RESPONSE
SEV1 Critical	Serious harm to people or rights at scale, legal reporting likely, major public exposure	Credit model wrongly refuses thousands; deepfake fraud succeeds	Executive incident lead within 1 hour; consider pausing system
SEV2 High	Material harm to some people or significant legal or reputational risk	Chatbot gives dangerous health advice to several users	Incident lead within 4 hours; containment same day
SEV3 Medium	Limited harm, contained, no reporting expected	Assistant reveals internal-only document to staff	Owner investigates within 2 working days
SEV4 Low	Near-miss or minor quality issue	Reviewer catches fabricated citation	Log, learn, trend

AI incident response lifecycle



Reporting duties that may apply (summarised, as of 2026)

REGIME	TRIGGER	TIMING (SIMPLIFIED)
EU AI Act: providers of high-risk systems	Serious incident linked to the system	Immediately after establishing a likely link, and no later than 15 days; 2 days for widespread infringements or critical-infrastructure disruption; 10 days in case of death

Copyright © ZyeemZia

REGIME	TRIGGER	TIMING (SIMPLIFIED)
EU AI Act: deployers	Serious incident identified by deployer	Inform the provider immediately, then importer or distributor and authorities
GDPR and similar data laws	Personal data breach, including via AI	Regulator within 72 hours where required; individuals without undue delay if high risk
India's DPDP Act and Rules	Personal data breach	Notify the Data Protection Board and affected individuals as the Rules prescribe
Sector regulators	Operational incidents in banking, telecoms, health	As set by the regulator, often within hours for critical incidents
Contracts	Incidents affecting customers or partners	As agreed, often 24 to 72 hours

WATCH OUT · CHECK THE CLOCK BEFORE YOU NEED IT

Reporting deadlines can start when you become aware of an incident, not when you finish investigating. Map every applicable duty for each high-risk system in advance, with the contact point and template, so the incident team does not lose days working it out. This summary is not legal advice; confirm duties with counsel.

Playbooks for common generative-AI incidents

PB1

Data leakage

Disable the leaking feature or source, identify exposed data and users, assess breach-notification duties, fix permissions.

PB2

Harmful or dangerous output

Block the pattern, contact affected users where possible, review guardrails, add to red-team suite.

PB3

Prompt injection or jailbreak

Contain tool permissions, review logs for actions taken, patch input handling, retest.

PB4

Fabricated information relied upon

Correct the record with affected parties, review human-review controls, strengthen grounding.

PB5

Deepfake impersonation

Verify through independent channels, stop transactions, warn staff and customers, report fraud, issue clarifications.

EXAMPLE · A DEEPFAKE CALL TO A FINANCE TEAM

An accountant at a Chattogram exporter receives a video call from someone who looks and sounds like the managing director, urgently requesting a supplier payment. Because the company's playbook requires call-back verification on a known number for any unusual payment, the accountant calls the director, who knows nothing about it. The near-miss is logged, staff are alerted and the bank is informed.

Copyright © ZyeemZia

SCENARIO · DECIDE · THE WEEKEND DISCOVERY

On a Saturday, a customer posts on social media that a bank's AI chatbot showed her another customer's account balance. The post is gaining attention. The chatbot product owner is on leave. What should happen FIRST?

(A) Wait until Monday when the product owner returns.

(B) Activate the incident process: the on-call lead classifies it as high severity, disables the affected feature, preserves logs and engages privacy and communications teams to assess notification duties.

(C) Delete the social media post's screenshot from internal systems.

(D) Publicly deny the issue until the investigation is complete.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE

AI incident record

Capture the facts and decisions for each AI incident or near-miss.

INCIDENT ID AND DATE	SYSTEM AND VERSION	WHAT HAPPENED AND WHO WAS AFFECTED	SEVERITY	CONTAINMENT AND REMEDIATION	NOTIFICATIONS MADE	ROOT CAUSE AND LESSONS
AI-2026-014, 7 Jun 2026	*Support chatbot v3.4*	*Displayed another customer's balance to 3 users after a retrieval change*	*SEV2*	*Feature disabled in 40 minutes; retrieval permissions fixed; affected customers contacted*	*Data protection regulator within statutory time; bank's board risk committee*	*Change released without permission regression test; test added to release gate*

AI incident readiness checklist

☐ AI incident definition and severity levels agreed

☐ AI incidents included in the enterprise incident process

☐ On-call incident lead and deputies named

☐ Kill switch or rollback tested for each high-risk system

☐ Logs retained and accessible for investigation

☐ Reporting duties mapped per system and jurisdiction

☐ Playbooks for common generative-AI incidents written and rehearsed

☐ Post-incident reviews feed tests, controls and training

Copyright © ZyeemZia

REFLECT

If your highest-risk AI system caused serious harm on a Friday night, who would be called, how would the system be stopped and which authority would need to be told by when?

Key terms

AI incident
An event in which an AI system's development, use or malfunction results in, or could plausibly result in, harm.

Containment
Actions that stop or limit the spread of harm during an incident.

Post-incident review
A structured, blame-free review after an incident to identify lessons and improvements.

Notification duty
A legal or contractual obligation to inform regulators, individuals or partners about an incident within a set time.

Severity level
A classification of an incident's seriousness that sets the speed and level of response.

Root cause analysis
Investigation to find the underlying causes of an incident, not just its symptoms.

Playbook
A pre-written set of steps for responding to a specific type of incident.

Call-back verification
Confirming an unusual request by contacting the requester through a known, independent channel.

KNOWLEDGE CHECK

16. A reviewer catches a fabricated citation before a document is sent. This should be:
    - (A) Recorded as a near-miss for learning
    - (B) Ignored because no harm occurred
    - (C) Reported to the police
    - (D) Treated as a SEV1 incident

17. Under the EU AI Act, what is the outer limit for a provider to report most serious incidents?
    - (A) One year
    - (B) 15 days after becoming aware
    - (C) No limit
    - (D) 90 days

18. Which step comes first after confirming a serious AI incident?
    - (A) Writing the annual report
    - (B) Retraining the model on new data
    - (C) Publishing a press release blaming the vendor
    - (D) Containment to stop further harm

19. Why map reporting duties before incidents happen?
    - (A) Regulators require maps to be published
    - (B) Maps replace containment
    - (C) Deadlines may start on awareness, leaving little time to research during a crisis
    - (D) Duties never change

20. What is the best control against deepfake payment fraud?
    - (A) Call-back verification through a known independent channel
    - (B) Better video quality
    - (C) Longer meetings
    - (D) Faster payment processing

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 7 · OPERATIONS

Answer key

Knowledge checks

1. D The relationship between inputs and outcome has changed.

2. C Above 0.25 is commonly treated as significant.

3. A A change in purpose or population can change risk and legal role.

4. B Outcome signals catch problems metrics miss.

5. A Contractual and technical controls make changes deliberate.

6. C Secrets must never be placed in prompts, whatever the tool.

7. A Accountability stays with the human user and organisation.

8. B Usability is a control against shadow AI.

9. D The AI literacy duty applied from 2 February 2025.

10. C Only authoritative sources confirm whether a citation exists and says what is claimed.

11. A A supplier's supplier is a fourth party, and its risks flow through to you.

12. B Data use terms control training on your data.

13. A Leverage peaks before renewal, so reassessment is most effective then.

14. C Failure or change at one provider affects everything that depends on it.

15. D Open-weight models carry supplier-type risks and licence conditions.

16. A Near-misses reveal weaknesses before they cause harm.

17. B The general deadline is 15 days, with shorter limits for the most serious cases.

18. D Containment limits harm while investigation proceeds.

19. C Preparation avoids missing short statutory deadlines.

20. A Independent verification defeats convincing impersonation.

Scenarios & case studies

Scenario · Drift alert on a credit model
B is best. Best. A significant shift needs understanding before action. The change may be benign or risky, and any fix should go through tested change control.

Scenario · A lawyer's shortcut
B is best. Best. It prevents harm to the client and court, applies the human-review rule and turns a near-miss into learning.

Case study · The call-centre analytics contract
Significant risks: customer voice data (personal and possibly sensitive) used for vendor training; cross-border processing; unfair agent performance scoring affecting jobs (worker monitoring, possibly high-risk in some jurisdictions); customer profiling for offers; transcription accuracy gaps for dialects; dependency on an undisclosed fourth-party model; and weak remedies. Negotiate: no training on recordings without explicit agreement; defined retention and deletion; disclosure of the foundation-model provider and hosting locations; at least 60 to 90 days' notice of material changes with the right to test; accuracy and fairness warranties by language and dialect; incident notification within 24 to 72 hours; audit rights; liability proportionate to risk; and exit support. Before go-live: local accuracy test across dialects, a bias test of agent scoring, worker consultation, privacy notices to customers, a DPIA, a monitoring plan and registration in the AI inventory.

Scenario · Renewal without review
B is best. Best. It uses renewal as a control point to bring oversight up to date and fix gaps while leverage exists.

Scenario · The weekend discovery
B is best. Best. It contains harm, preserves evidence and starts the legal assessment promptly, regardless of who is on leave.

Copyright © ZyeemZia

08

MODULE 8 · ASSURANCE

Audit, Assurance and the AI Governance Programme

Prove that governance works, organise it well and report it to the board

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Plan and evaluate AI audits and other forms of AI assurance
- Design an AI governance operating model with clear roles, forums and decision rights
- Report AI value, risk and control health to the board with balanced metrics
- Assess programme maturity by layer and drive continuous improvement
- Integrate all eight layers of the ZAIG Stack into one working programme

LESSONS

1. AI Audit and Assurance · 35 min
2. Building the AI Governance Programme · 35 min
3. Board Reporting and Metrics · 30 min
4. Maturity, Continuous Improvement and the Road Ahead · 30 min

MODULE 8 · ASSURANCE · LESSON 1 · 35 MIN

AI Audit and Assurance

Independent evidence that AI governance works as claimed

- Explain the three lines model and where AI assurance fits
- Compare internal audit, external audit, certification, bias audits and conformity assessment
- Plan an AI audit with clear criteria, evidence and testing

Leaders, regulators, customers and the public increasingly ask the same question: **how do you know your AI governance actually works?** Assurance answers it with independent, evidence-based conclusions. It does not replace good management; it tests it. A programme that cannot be audited is a programme that cannot be trusted.

The three lines model applied to AI (top layer first)

Governing body	`Board sets AI risk appetite and oversees the programme` `Receives independent assurance`
Third line: internal audit	`Independent assurance on AI governance, risk and controls` `Reports to the board or audit committee`
Second line: risk, compliance, privacy, AI governance office	`Sets policy and standards, challenges first line, monitors risk`
First line: business and technical owners	`Own AI systems and their risks` `Operate controls day to day`

Types of AI assurance

TYPE	WHO PERFORMS IT	WHAT IT CONCLUDES	EXAMPLE
Second-line review	AI governance office, model risk, compliance	Whether first-line controls meet policy	Quarterly review of high-risk model monitoring
Internal audit	Internal audit function	Whether governance and controls are designed and operating effectively	Audit of the AI use-case intake and inventory process
External audit or assurance engagement	Independent firm	An opinion against defined criteria	Assurance report on AI controls for a client
Certification	Accredited certification body	Conformity of a management system with a standard	ISO/IEC 42001 certification
Bias audit	Independent auditor	Selection-rate or impact differences for a tool	Bias audits of automated hiring tools required in New York City
Conformity assessment	Provider, or a notified body where required	Conformity of a high-risk system with EU AI Act requirements	Technical documentation reviewed before CE marking

Copyright © ZyeemZia

Planning and performing an AI audit

01 Scope — Systems, processes, period, entities →
02 Criteria — Policy, law, standards, frameworks →
03 Risk assessment — Focus on high-risk areas →
04 Evidence — Documents, logs, interviews, re-performance →
05 Testing — Design and operating effectiveness →
06 Report — Findings, ratings, owners, dates →
07 Follow-up — Verify remediation

Sources of audit criteria

- The organisation's own AI policy, standards and risk appetite.
- Applicable law, such as the EU AI Act or data protection law.
- Management system standards, such as ISO/IEC 42001.
- Frameworks, such as the NIST AI RMF, used as reference good practice.
- Sector regulator expectations, such as banking model-risk guidance.
- Contract commitments to customers.

Evidence for common AI controls

CONTROL	EVIDENCE AN AUDITOR WOULD SEEK	TEST
AI inventory complete	Inventory, procurement and expense data, network logs	Reconcile purchases and traffic to inventory entries
Impact assessment before launch	Signed assessments with dates, gate records	Sample high-tier systems; compare assessment and launch dates
Bias testing at release	Bias reports, thresholds, approvals	Re-perform a calculation on a sample of data
Human oversight effective	Override rates, review times, training records	Observe reviews; insert seeded cases
Monitoring and response	Dashboards, alerts, tickets	Trace alerts to actions and closure
Supplier oversight	Due diligence files, contract clauses, review records	Check high-risk suppliers against policy requirements

WATCH OUT · AUDITING AI NEEDS NEW SKILLS

Auditors must be able to question data scientists, read model documentation, understand metrics and recognise when a test set is unrepresentative. Build skills through training, co-sourcing specialists and pairing auditors with independent technical experts. Independence still matters: experts who built a system should not audit it.

CASE STUDY · AUDITING THE INTAKE PROCESS

Internal audit at a Dhaka-based mobile financial services provider audits the AI intake and inventory process one year after launch. The inventory lists 31 systems. Auditors reconcile software purchases, cloud invoices and network traffic to AI services and find 12 more AI uses, including two that influence customer credit limits. Of the 9 high-tier systems in the inventory, 6 have impact assessments dated before launch, 2 dated after launch and 1 missing.

1. What are the main findings?

Copyright © ZyeemZia

2. How should they be rated?

3. What actions should management take?

Model answer: module answer key.

SCENARIO · DECIDE · THE AUDIT SCOPE REQUEST

The head of data science asks internal audit to limit its AI audit to model accuracy, saying governance processes are 'just paperwork'. What should the chief audit executive do?

(A) Agree, because data scientists know the models best.

(B) Set scope based on risk, covering governance, intake, assessments, fairness, oversight, monitoring and suppliers, while drawing on data-science expertise for technical testing.

(C) Cancel the audit to avoid conflict.

(D) Let the vendor audit its own models instead.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE **AI audit finding**

Record an audit finding in a consistent, actionable format.

FINDING	CRITERIA	CONDITION FOUND	RISK AND IMPACT	RATING	MANAGEMENT ACTION AND OWNER	DUE DATE
Impact assessments not completed before launch	*AI policy section 6: high-tier systems require approved assessment before go-live*	*3 of 9 high-tier systems launched without timely assessment*	*Unassessed harm to customers; regulatory breach*	*High*	*Gate made system-enforced in deployment pipeline; Head of AI Governance*	*30 Sep 2026*

Copyright © ZyeemZia

REFLECT

If an independent auditor examined your organisation's AI governance next month, which control would they most likely find not operating as described? What evidence would they ask for?

Key terms

Assurance
An independent, evidence-based conclusion about whether something meets defined criteria.

Audit criteria
The requirements, such as policies, laws or standards, against which evidence is assessed.

Operating effectiveness
Whether a control actually operated as designed throughout the period.

Bias audit
An independent assessment of whether an AI tool produces different outcomes for different groups.

Three lines model
A model distinguishing first-line management, second-line risk and compliance functions, and third-line internal audit, under a governing body.

Design effectiveness
Whether a control, as designed, would address the risk if operated correctly.

Re-performance
An audit technique in which the auditor repeats a control or calculation to verify it.

Co-sourcing
Supplementing an internal audit team with external specialists while keeping ownership of the audit.

KNOWLEDGE CHECK

1. In the three lines model, who provides independent assurance to the board?
   - (A) Model developers
   - (B) The AI vendor
   - (C) Internal audit
   - (D) The marketing team
2. An auditor recalculates a disparate impact ratio from raw data. This technique is:
   - (A) Inquiry only
   - (B) Observation of a meeting
   - (C) Management representation
   - (D) Re-performance
3. What does ISO/IEC 42001 certification conclude?
   - (A) A management system conforms to the standard within scope
   - (B) Each model is accurate
   - (C) The organisation can ignore law
   - (D) All suppliers are compliant
4. A control is well designed but often skipped. It lacks:
   - (A) Design effectiveness
   - (B) Operating effectiveness
   - (C) Documentation only
   - (D) Independence
5. Who should set the scope of an internal AI audit?
   - (A) The team being audited
   - (B) The vendor
   - (C) Whoever has the largest budget
   - (D) Internal audit, based on risk

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 8 · ASSURANCE · LESSON 2 · 35 MIN

Building the AI Governance Programme

Operating models, roles, committees and the first year

- Choose an AI governance operating model that fits the organisation
- Define roles, committees and decision rights
- Integrate AI governance with existing risk, privacy, security and procurement functions
- Plan the first 90 days and first year of a programme

All the layers of the ZAIG Stack must be brought together into a **programme**: people with clear roles, forums that make decisions, processes that connect, tools that support them and a plan that delivers. Few organisations can start from scratch. The fastest route usually builds on what already works, such as privacy, information security, model risk and procurement, and adds the AI-specific pieces.

AI governance operating models

Centralised

- One central team reviews and approves all AI
- Strong consistency and expertise
- Risk: bottleneck as AI use grows

Federated

- Business units govern their own AI under common policy
- Close to the work, scales well
- Risk: inconsistency and weak challenge

Hub and spoke

- Central hub sets policy, standards and tools; trained champions in each unit apply them
- Balances consistency and scale
- Most common choice for medium and large organisations

Key roles and forums

BD
Board or board committee
Approves AI principles and risk appetite; oversees the programme; receives assurance.

ES
Executive sponsor
A senior executive accountable for the programme and its resources.

GC
AI governance committee
Cross-functional forum approving high-risk systems, policy exceptions and priorities.

GO
AI governance office
Small central team running intake, inventory, standards, tools, training and reporting.

SO
System owners
Business owners accountable for each AI system's outcomes and risks.

CH
AI champions
Trained staff in each unit who guide colleagues and triage requests.

EX
Expert functions
Privacy, security, legal, compliance, model risk, HR and procurement, each with defined AI duties.

EA
Advisory voices
Ethics advisers or external panels, including affected-community perspectives, for difficult cases.

INSIGHT · DECISION RIGHTS MATTER MORE THAN TITLES

Whether the role is called Chief AI Officer, Head of Responsible AI or AI Governance Lead matters less than whether it is clear **who can approve, block, pause and retire AI systems**, and whether those people have the information and independence to do it.

Copyright © ZyeemZia

Integrating with existing functions

FUNCTION	EXISTING PROCESS	AI ADDITION
Privacy	DPIAs, records of processing	Integrated AI impact assessment module; AI in privacy notices
Information security	Security risk assessments, testing	AI threat modelling, red teaming, prompt-injection testing
Model risk (banks)	Model inventory, validation	Generative AI and vendor AI brought into scope
Procurement	Vendor due diligence, contracts	AI questionnaire and contract clauses
HR	Workforce policies, consultation	AI in hiring and monitoring; AI literacy training
Enterprise risk	Risk register, appetite	AI risk themes, tolerances and KRIs
Internal audit	Audit plan	Risk-based AI audits

TEMPLATE

AI governance committee charter (summary)

Define the purpose, membership and authority of the AI governance committee.

ELEMENT	CONTENT
Purpose	*Approve high-risk AI systems and policy exceptions; oversee AI risk; advise the executive and board*
Membership	*Chief Risk Officer (chair), CTO, Chief Data Officer, General Counsel, DPO, CISO, HR Director, business heads; AI governance office as secretary*
Decision rights	*Approve, approve with conditions, reject or pause high-tier systems; approve exceptions up to 6 months*
Cadence and reporting	*Monthly; quarterly report to the board risk committee*

The first 90 days

1. **Secure sponsorship** Agree the executive sponsor, scope and initial budget.
2. **Find the AI** Run the inventory sprint and identify the highest-risk systems.
3. **Set the minimum rules** Issue interim principles, a generative-AI acceptable-use rule and a prohibited-uses list.
4. **Stand up the front door** Launch a simple intake with tiering.
5. **Tackle the top risks** Run impact assessments on the two or three highest-risk systems.

Copyright © ZyeemZia

6. **Form the committee** Charter the AI governance committee and agree decision rights.
7. **Report** Give the board a first view of AI use, top risks and the programme plan.

Year-one roadmap (example)

QUARTER	FOCUS	KEY DELIVERABLES
Q1	Visibility and quick wins	Inventory, interim policy, intake, generative-AI rules, top-risk assessments
Q2	Policy and process	Approved AI policy and standards, impact assessment template, supplier questionnaire, training launch
Q3	Lifecycle controls	Stage gates, model cards, bias testing standard, monitoring for high-risk systems, incident playbooks
Q4	Assurance and maturity	Metrics dashboard, first internal audit, maturity assessment, year-two plan, certification readiness review if relevant

SCENARIO · DECIDE · WHERE TO PLACE THE PROGRAMME

A large university group in South Asia is creating its AI governance programme. The IT director wants it inside IT; the registrar wants it in academic affairs; legal wants it in compliance. What is the BEST approach?

(A) Place it in IT, because AI is technology.

(B) Create a hub-and-spoke model with a small central office reporting to a senior executive outside IT delivery, a cross-functional committee and champions in faculties and departments.

(C) Let each faculty decide whether to govern AI.

(D) Postpone the decision until a national AI law is passed.

Circle your choice. Answer and feedback: module answer key.

REFLECT

Who in your organisation can currently stop an AI system that is causing harm? If the answer is unclear, who should it be, and what information would they need?

Key terms

Operating model
How governance responsibilities, people, processes and tools are organised across an organisation.

AI governance committee
A cross-functional forum with authority over high-risk AI approvals, exceptions and oversight.

Executive sponsor
A senior leader accountable for the success and resourcing of the governance programme.

Hub and spoke
An operating model with a central hub setting standards and distributed spokes applying them in business units.

AI governance office
The central team that runs the day-to-day mechanics of AI governance.

AI champion
A trained staff member in a business unit who promotes and supports good AI governance locally.

Copyright © ZyeemZia

Decision rights
The defined authority of a role or body to approve, block, pause or retire AI systems.

Committee charter
A document setting a committee's purpose, membership, authority and ways of working.

KNOWLEDGE CHECK

6. Which operating model is most common for medium and large organisations?
   - (A) Fully centralised
   - (B) Hub and spoke
   - (C) Fully voluntary
   - (D) Vendor-led
7. What matters most about a senior AI governance role?
   - (A) Clear decision rights to approve, block, pause and retire systems
   - (B) The exact job title
   - (C) The size of the office
   - (D) Reporting to IT delivery
8. Which is a sensible first-90-days action?
   - (A) Pursuing certification immediately
   - (B) Writing a 100-page policy
   - (C) Banning all AI
   - (D) An inventory sprint to find the AI already in use
9. Why integrate AI governance with privacy, security and procurement?
   - (A) Because AI needs no new controls
   - (B) To hide AI risks
   - (C) To reuse working processes and avoid duplicate, conflicting requirements
   - (D) Because regulators forbid separate AI teams
10. Who approves the organisation's AI principles and risk appetite?
    - (A) The board or a board committee
    - (B) Each data scientist
    - (C) The vendor
    - (D) Interns

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 8 · ASSURANCE · LESSON 3 · 30 MIN

Board Reporting and Metrics

Giving boards the information they need to oversee AI

- Explain the board's role in AI oversight
- Select programme metrics, risk indicators and outcome measures
- Write a board AI report that leads to decisions

Boards are accountable for overseeing how their organisations use AI, as they are for any material risk and opportunity. Most board members are not AI experts and do not need to be. They need **clear, honest, decision-ready information**: where AI is used, how much value and risk it creates, whether controls work and what decisions they must make. International guidance for governing bodies, such as ISO/IEC 38507, frames this as governance of the organisation's use of AI, not management of the technology.

Questions every board should be able to answer

- Where do we use AI, and which uses are high risk?
- What is our AI risk appetite, and are we within it?
- Who is accountable for each high-risk system?
- Which laws and regulators affect our AI, and are we ready?
- What incidents and near-misses have occurred, and what did we learn?
- Is AI delivering the value we expected?
- What independent assurance do we have?
- Do we, as a board, have enough AI literacy to oversee this?

Programme metrics

MEASURE	FORMULA	WHAT IT TELLS YOU
Inventory coverage	`Coverage = Systems registered before launch / All AI systems found`	Shows whether the front door is used; target close to 100% for high-tier systems.
Assessment completion	`Completion = High-tier systems with current approved assessment / All high-tier systems`	Should be 100%; any gap is a finding.
Mean time to contain	`MTTC = Σ (Containment time − Detection time) / Number of incidents`	Speed of response to AI incidents, by severity.
Fairness compliance	`Share of high-risk models within fairness tolerance this period`	Tracks the board's appetite for unfair outcomes.
Training reach	`Staff completing role-based AI literacy / Staff in scope`	Supports AI-literacy duties and policy adoption.

A balanced AI dashboard

CATEGORY	EXAMPLE METRICS	WHY THE BOARD CARES
Value	Benefits delivered by major AI systems; adoption	Is the investment paying off?
Exposure	Number of AI systems by tier; new high-tier systems	How much risk are we taking on?

Copyright © ZyeemZia

CATEGORY	EXAMPLE METRICS	WHY THE BOARD CARES
Control health	Coverage, assessment completion, overdue actions, exceptions	Is governance working?
Outcomes	Fairness tolerance breaches, complaints, appeals upheld	Are people being treated well?
Incidents	Number by severity, MTTC, regulatory notifications	What went wrong and how fast did we respond?
Readiness	Regulatory deadlines met, audit findings closed	Are we ready for what is coming?

WATCH OUT · GREEN DASHBOARDS CAN MISLEAD

A dashboard where everything is always green usually means the wrong things are measured or thresholds are too loose. Include at least one metric that would reveal trouble early, such as the number of AI systems discovered outside the intake process, and explain every amber or red honestly.

Structure of a board AI report

1 **Headline**
Three sentences: overall status, the most important change since last time, and decisions needed.

2 **Decisions requested**
Clear choices with recommendations, such as approving a revised risk appetite.

3 **Top risks and trends**
Five or fewer enterprise AI risk themes with direction of travel.

4 **Dashboard**
The balanced metrics with commentary on ambers and reds.

5 **Incidents and lessons**
Significant incidents, near-misses and actions.

6 **Regulatory horizon**
Upcoming obligations and readiness.

7 **Assurance**
Audit and review results and remediation status.

TEMPLATE Board AI report: headline page

Give the board a one-page view that leads to decisions.

SECTION	CONTENT
Headline	*AI programme on track; one high-tier system breached fairness tolerance in May and was paused; decision needed on generative-AI expansion*
Decision requested	*Approve enterprise assistant for customer-service staff with conditions in Appendix B*

Copyright © ZyeemZia

SECTION	CONTENT

SCENARIO · DECIDE · THE BOARD PACK

The AI governance office's quarterly board pack is 48 pages of model metrics. Board members ask questions mainly about a newspaper story on AI hiring bias in another company. What should the AI governance lead change?

(A) Add more model metrics so the board has complete data.

(B) Restructure the report around the board's questions: a one-page headline with decisions, top risk themes, a balanced dashboard and a short note on whether a similar hiring risk exists here, with detail in appendices.

(C) Stop reporting to the board until the programme is mature.

(D) Only report when there is an incident.

Circle your choice. Answer and feedback: module answer key.

CASE STUDY · A BOARD LEARNING CURVE

The board of a listed Bangladeshi conglomerate with interests in garments, telecoms and finance approves an AI strategy. Directors admit they cannot judge AI risks. The chair asks the company secretary and AI governance lead to propose how the board should oversee AI.

1. Which committee should own AI oversight?

2. What should the board receive and how often?

3. How can directors build AI literacy?

Model answer: module answer key.

REFLECT

Draft the three-sentence headline you would give your board about AI this quarter. What decision would you ask them to make?

Copyright © ZyeemZia

Key terms

Board oversight
The governing body's responsibility to direct, monitor and hold management accountable for AI use.

Inventory coverage
The share of AI systems that were registered through the intake process before launch.

Balanced dashboard
A set of metrics covering value, exposure, control health, outcomes, incidents and readiness.

ISO/IEC 38507
An international standard giving guidance to governing bodies on the governance implications of using AI.

Key performance indicator (KPI)
A metric showing progress towards an objective, such as AI value delivered.

Mean time to contain (MTTC)
The average time between detecting an incident and containing it.

Decision-ready reporting
Reporting that highlights the decisions needed, with options and recommendations.

Escalation
Raising an issue to a higher level of authority when it exceeds defined thresholds.

KNOWLEDGE CHECK

11. What do boards need most from AI reporting?
    - A) Every model's raw metrics
    - B) Source code samples
    - C) Vendor marketing material
    - D) Clear, honest, decision-ready information
12. 40 of 50 AI systems were registered before launch. Inventory coverage is:
    - A) 40%
    - B) 50%
    - C) 125%
    - D) 80%
13. Why include a metric such as 'AI systems found outside the intake process'?
    - A) It always looks good
    - B) It replaces audits
    - C) It reveals governance weaknesses early
    - D) It measures model accuracy
14. What should come first in a board AI report?
    - A) A short headline with status and decisions needed
    - B) A glossary
    - C) Appendix of model metrics
    - D) Vendor list
15. Two incidents took 2 and 6 hours to contain. The MTTC is:
    - A) 8 hours
    - B) 4 hours
    - C) 3 hours
    - D) 12 hours

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 8 · ASSURANCE · LESSON 4 · 30 MIN

Maturity, Continuous Improvement and the Road Ahead

Measuring progress and keeping the programme alive

- Assess the maturity of an AI governance programme
- Build a roadmap that raises maturity where it matters
- Embed continuous improvement and a culture of responsible AI
- Bring the whole ZAIG Stack together for the capstone

AI governance is never finished. Technology, law, organisational strategy and public expectations all keep moving. A mature programme does not try to freeze the rules; it builds the ability to **learn and adapt**: measuring itself honestly, fixing weaknesses, and updating controls as AI and regulation change.

ZAIG maturity levels

LEVEL	NAME	WHAT IT LOOKS LIKE
1	Ad hoc	AI used without inventory; governance depends on individuals; no policy
2	Emerging	Inventory started; interim rules; some assessments for obvious high-risk systems
3	Defined	Approved policy and standards; intake and tiering; stage gates; roles and committee working
4	Managed	Controls consistently applied; metrics and monitoring; supplier oversight; regular assurance
5	Optimising	Continuous improvement from incidents and metrics; anticipates regulation; governance accelerates responsible innovation

PRO TIP · ASSESS BY LAYER, NOT JUST OVERALL

Score each layer of the ZAIG Stack separately. Most organisations find they are at level 3 for principles and policy but level 1 or 2 for monitoring, supplier oversight or incident response. The gaps between layers show where to invest next.

Continuous improvement cycle

01 **Plan** — Set objectives, risks and controls →

02 **Do** — Operate the programme →

03 **Check** — Measure, audit, review incidents and feedback →

04 **Act** — Correct nonconformities and improve →

05 **Repeat** — Update for new technology, law and strategy

Sources of improvement

- Incident and near-miss reviews.
- Internal and external audit findings.
- Monitoring trends and KRI breaches.
- Complaints, appeals and feedback from affected people.
- Regulatory changes and supervisory feedback.
- Staff suggestions and AI champions' observations.
- Benchmarking against peers and new standards.

Copyright © ZyeemZia

INSIGHT · CULTURE IS THE LAST CONTROL

Policies and gates catch many problems, but not all. In mature organisations, a data scientist raises a fairness concern without being asked, a product manager pauses a launch voluntarily and a customer-service agent reports a strange chatbot answer. Reward that behaviour publicly, protect people who raise concerns and make leaders model it.

Emerging topics to watch (as of 2026)

TOPIC	WHY IT MATTERS FOR GOVERNANCE
Agentic AI	Systems that take actions raise questions of authority, permissions, liability and monitoring
Frontier model safety	Evaluations and incident reporting for the most capable models continue to develop
Content provenance	Watermarking and labelling rules for synthetic media are spreading
Standards and harmonisation	New ISO/IEC and regional standards will shape what 'good practice' means
Environmental impact	Energy and water use of AI attracts disclosure expectations
Workforce effects	AI's impact on jobs, skills and worker monitoring draws regulatory and social attention

CASE STUDY · PULLING THE STACK TOGETHER

A mobile financial services provider in Bangladesh, with 20 million customers and a growing partnership with a European remittance company, has completed its first year of AI governance. It has an inventory of 46 systems, an approved policy, an intake process and a committee. A maturity assessment shows: Foundations 4, Principles 3, Regulation 3, Risk 3, Data 2, Lifecycle 2, Operations 2, Assurance 1.

1. Where should the second-year roadmap focus?

2. Which risks does the profile suggest are most likely to materialise?

3. How should progress be reported to the board?

Model answer: module answer key.

Copyright © ZyeemZia

SCENARIO · DECIDE · THE PROGRAMME STALLS

Two years in, an AI governance programme's metrics are all green, but staff describe the intake as a box-ticking exercise and two recent AI problems were found by journalists, not by internal controls. What should the AI governance lead do?

(A) Celebrate the green metrics in the next board report.

(B) Commission an honest review: test controls' effectiveness, interview staff, analyse the two problems' root causes, revise metrics to include leading indicators and refresh the culture and training.

(C) Add more mandatory fields to the intake form.

(D) Blame the journalists for unfair coverage.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE **AI governance maturity assessment**

Score each layer of the ZAIG Stack and plan improvements.

ZAIG LAYER	CURRENT LEVEL (1-5)	EVIDENCE	TARGET IN 12 MONTHS	KEY ACTIONS	OWNER
Operations	*2*	*Monitoring only on 3 of 11 high-tier systems; no supplier reviews; incident playbook untested*	*4*	*Monitoring plans for all high-tier systems; supplier review cycle; two incident simulations*	*Head of AI Governance*

REFLECT

Look back across all eight layers of the ZAIG Stack. Which layer is strongest in your organisation, which is weakest, and what single action in the next 90 days would raise the weakest one?

Copyright © ZyeemZia

Key terms

Maturity model
A staged description of how capability develops, used to assess current state and plan improvement.

Plan-Do-Check-Act (PDCA)
An iterative improvement cycle used in management system standards.

Corrective action
Action to remove the cause of a nonconformity and prevent recurrence.

Agentic AI
AI systems that pursue goals by planning and taking actions with some autonomy.

Continuous improvement
Ongoing effort to improve processes and controls based on evidence and feedback.

Nonconformity
Failure to meet a requirement of a policy, standard or management system.

Speak-up culture
An environment in which people feel safe raising concerns about risks or wrongdoing.

Content provenance
Information that records the origin and editing history of digital content, including whether AI was used.

KNOWLEDGE CHECK

16. A programme with approved policy, intake, stage gates and a working committee but little monitoring is most likely at which level overall?
    - (A) Defined (3)
    - (B) Ad hoc (1)
    - (C) Optimising (5)
    - (D) Managed (4)

17. Why assess maturity by ZAIG layer?
    - (A) It produces a higher overall score
    - (B) Regulators require it
    - (C) It avoids the need for audit
    - (D) It shows which layers lag and where to invest

18. Which is a leading indicator of governance weakness?
    - (A) Number of policy pages
    - (B) Number of committee members
    - (C) AI problems found externally rather than by internal controls
    - (D) Office size

19. In PDCA, which step uses audits and incident reviews?
    - (A) Plan
    - (B) Check
    - (C) Do
    - (D) Act only

20. What best sustains responsible AI beyond formal controls?
    - (A) Longer policies
    - (B) Fewer metrics
    - (C) Keeping AI use secret
    - (D) A culture that rewards raising concerns, modelled by leaders

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 8 · ASSURANCE

Answer key

Knowledge checks

1. C Internal audit is the third line, independent of management.

2. D Re-performance verifies the control by repeating it.

3. A Certification addresses the management system, not every model's quality or legality.

4. B It would work if operated, but it is not operating consistently.

5. D Independent, risk-based scoping is fundamental to assurance.

6. B It balances consistent standards with reach into business units.

7. A Authority and information enable effective governance.

8. D Visibility comes first.

9. C Integration speeds adoption and keeps requirements coherent.

10. A Direction-setting belongs to the governing body.

11. D Boards oversee; they need information that supports decisions.

12. D 40 / 50 = 0.8 or 80%.

13. C It is a leading indicator of control failure.

14. A Leading with status and decisions focuses board time.

15. B (2 + 6) / 2 = 4 hours.

16. A Defined processes exist, but consistent measurement and monitoring characterise Managed.

17. D Layer scores reveal uneven development.

18. C External discovery signals that internal detection is failing.

19. B Check measures and reviews performance.

20. D Culture catches what controls miss.

Scenarios & case studies

Case study · Auditing the intake process
Main findings: the inventory is incomplete (12 unregistered uses, 2 with high-impact credit effects), and the impact-assessment control is not operating effectively for high-tier systems (3 of 9 non-compliant). Both should be rated high, because unassessed credit-affecting AI can harm customers and breach regulatory expectations. Actions: register and tier the 12 systems within 30 days with urgent assessment of the 2 credit uses and interim safeguards; complete the missing assessment; investigate why assessments were late; make inventory registration a condition of procurement and cloud access; add automated discovery of AI service traffic; and report progress to the audit committee until verified by follow-up audit.

Scenario · The audit scope request
B is best. Best. Independence and risk-based scoping are core audit principles; technical expertise supports but does not set scope.

Scenario · Where to place the programme
B is best. Best. It gives independence, cross-functional input and reach into faculties where AI is used.

Scenario · The board pack
B is best. Best. It makes the report decision-ready and addresses the board's concern directly, keeping detail available.

Case study · A board learning curve
Oversight can sit with the board risk committee, or a technology committee where one exists, with the full board approving AI principles, risk appetite and major strategic AI decisions. The committee should receive a quarterly AI report (headline with decisions, top risk themes across the group's businesses, balanced dashboard, incidents, regulatory horizon including EU exposure through garment and telecom customers, and assurance results), plus immediate escalation of SEV1 incidents. Internal audit should include AI in its plan. Directors can build literacy through a tailored briefing programme, site visits to see systems in use, an external adviser for the committee, and an annual board self-assessment that includes AI oversight competence.

Copyright © ZyeemZia

Case study · Pulling the stack together

The weakest layers are Assurance (1) and Data, Lifecycle and Operations (2). The year-two roadmap should prioritise: data provenance and privacy controls for credit and fraud models (Data); bias testing, model cards and independent validation for high-tier systems (Lifecycle); monitoring with thresholds, supplier oversight for vendor AI and rehearsed incident playbooks (Operations); and a first risk-based internal audit of AI governance (Assurance). The likely risks are undetected drift or unfairness in credit and fraud models, supplier changes going unnoticed, slow incident response and an inability to evidence controls to regulators or the European partner. Report quarterly to the board using a balanced dashboard, the maturity profile by layer with targets, and progress on the roadmap, with independent assurance results as they arrive.

Scenario · The programme stalls

B is best. Best. It confronts the gap between reported and real performance and rebuilds effectiveness and trust.

Copyright © ZyeemZia

REFERENCE

Glossary

A

Acceptable-use policy Rules stating how employees may and may not use a technology, such as generative AI. (Operations)

Accountability Being answerable for decisions and outcomes, with the authority and duty to act. (Foundations)

Adversarial example An input deliberately altered, often imperceptibly, to make a model err. (Principles)

Affected person Someone whose rights, opportunities or interests are influenced by an AI system's outputs. (Foundations)

Agentic AI AI systems that pursue goals by planning and taking actions with some autonomy. (Assurance)

AI agent An AI system that plans and carries out multi-step tasks by calling tools or taking actions. (Foundations)

AI Basic Act (South Korea) South Korea's framework law on AI development and trust, in force from January 2026, with duties for high-impact and generative AI. (Regulation)

AI champion A trained staff member in a business unit who promotes and supports good AI governance locally. (Assurance)

AI governance The system of direction, policies, roles, processes and evidence that ensures an organisation's AI is lawful, ethical, safe and aligned with its goals. (Foundations)

AI governance committee A cross-functional forum with authority over high-risk AI approvals, exceptions and oversight. (Assurance)

AI governance office The central team that runs the day-to-day mechanics of AI governance. (Assurance)

AI impact assessment (AIIA) A structured evaluation of an AI system's potential effects on individuals, groups and society, used to decide whether and how to deploy it. (Risk)

AI incident An event in which an AI system's development, use or malfunction results in, or could plausibly result in, harm. (Operations)

AI incident database A public or internal collection of reported AI failures and harms used for learning. (Risk)

AI inventory A maintained register of the AI systems an organisation develops, buys or uses, with key facts for governance. (Foundations)

AI lifecycle The stages an AI system passes through from planning and data to build, validation, deployment, operation and retirement. (Lifecycle)

AI literacy The skills, knowledge and understanding that allow people to deploy and use AI in an informed way and be aware of its risks. (Regulation)

AI management system (AIMS) The policies, processes, roles and controls an organisation uses to direct and control its AI activities, as specified by ISO/IEC 42001. (Regulation)

AI Office The European Commission body that supervises general-purpose AI models and supports implementation of the AI Act. (Regulation)

AI policy A mandatory organisational document setting rules, roles and requirements for AI. (Principles)

AI principles High-level statements of what an organisation commits to when designing and using AI. (Principles)

AI risk register A record of AI risks with scores, controls, owners and review dates. (Risk)

AI risk taxonomy A structured list of AI risk categories used to identify risks consistently. (Risk)

AI system A machine-based system that infers from inputs how to produce outputs such as predictions, content, recommendations or decisions. (Foundations)

AI value chain The linked set of organisations that supply data, models, tools and applications up to the point of use. (Foundations)

AI-generated content label A notice or mark indicating that content was created or altered by AI. (Operations)

Alert fatigue Reduced responsiveness when monitoring produces so many alerts that real problems are missed. (Operations)

Algorithmic bias Systematic and unjustified differences in an AI system's outputs or errors that disadvantage certain people or groups. (Principles)

Algorithmic impact assessment An assessment of automated decision systems, often required for public-sector use. (Risk)

Annex III The EU AI Act's list of use areas, such as employment and credit scoring, in which AI systems are presumed high-risk. (Regulation)

Annotation Adding labels or tags to data so it can be used for supervised learning. (Data)

Annualised loss expectancy (ALE) The expected yearly loss from a risk, calculated as annual rate of occurrence times single loss expectancy. (Risk)

Anonymisation Processing data so individuals can no longer be identified by any reasonably likely means. (Data)

Applicability assessment Analysis of which legal and framework requirements apply to a specific system and why. (Regulation)

Approved tool A generative-AI tool assessed and authorised for work use under defined conditions. (Operations)

Copyright © ZyeemZia

Assurance An independent, evidence-based conclusion about whether something meets defined criteria. (Assurance)

Audit criteria The requirements, such as policies, laws or standards, against which evidence is assessed. (Assurance)

Automation bias The tendency to over-rely on automated outputs, even when they are wrong. (Principles)

B

Balanced dashboard A set of metrics covering value, exposure, control health, outcomes, incidents and readiness. (Assurance)

Bias audit An independent assessment of whether an AI tool produces different outcomes for different groups. (Assurance)

Board oversight The governing body's responsibility to direct, monitor and hold management accountable for AI use. (Assurance)

Business owner The named person accountable for an AI use case's purpose, outcomes and risks. (Foundations)

C

Call-back verification Confirming an unusual request by contacting the requester through a known, independent channel. (Operations)

CE marking The marking showing a product conforms with applicable EU requirements, including for high-risk AI systems. (Regulation)

Change control A process for assessing, testing, approving and recording changes to a system. (Operations)

Change notification clause A contract term requiring advance notice of material changes to a product or service. (Operations)

Co-sourcing Supplementing an internal audit team with external specialists while keeping ownership of the audit. (Assurance)

Committee charter A document setting a committee's purpose, membership, authority and ways of working. (Assurance)

Concentration risk Exposure from relying heavily on a single supplier or technology. (Operations)

Concept drift A change in the relationship between inputs and the outcome a model predicts. (Operations)

Conditional approval Approval to deploy only if specified mitigations are implemented and verified. (Risk)

Confabulation Generation of confident but false or unsupported content; often called hallucination. (Foundations)

Conformity assessment The process of demonstrating that a high-risk AI system meets the EU AI Act's requirements before market placement. (Regulation)

Containment Actions that stop or limit the spread of harm during an incident. (Operations)

Content provenance Information that records the origin and editing history of digital content, including whether AI was used. (Assurance)

Contestability The ability of affected people to challenge an AI-assisted decision and have it reviewed. (Principles)

Continuous improvement Ongoing effort to improve processes and controls based on evidence and feedback. (Assurance)

Control A safeguard or check that reduces risk or ensures a requirement is met. (Principles)

Corrective action Action to remove the cause of a nonconformity and prevent recurrence. (Assurance)

Corrective control A control designed to limit damage and restore normal operation after an event. (Risk)

Counterfactual explanation A statement of what would need to change in the input for the outcome to differ. (Lifecycle)

Cross-border transfer Moving personal data, or allowing access to it, from one country to another. (Data)

D

Data classification A scheme that labels data by sensitivity, such as public, internal, confidential and restricted. (Operations)

Data drift A change in the distribution of input data compared with the data the model was trained or validated on. (Operations)

Data lineage The record of how data moves and is transformed from source systems to models and decisions. (Data)

Data localisation A legal requirement to store or process certain data within a country's borders. (Data)

Data minimisation Using only the personal data that is adequate, relevant and necessary for the purpose. (Principles)

Data owner The senior person accountable for a data domain and decisions about its use. (Data)

Data poisoning An attack that corrupts training or retrieval data to alter a model's behaviour. (Principles)

Data principal Under India's DPDP Act, the individual to whom personal data relates. (Data)

Data protection impact assessment (DPIA) An assessment of risks to individuals from processing personal data, required by many data protection laws for high-risk processing. (Risk)

Data provenance The origin of data and the conditions, such as consent or licence terms, under which it was collected. (Data)

Data steward The person responsible for day-to-day quality, definitions and documentation of a data domain. (Data)

Copyright © ZyeemZia

Dataset versioning Keeping identifiable, unchangeable snapshots of datasets linked to the models trained on them. (Data)

Datasheet for datasets A structured document describing a dataset's motivation, composition, collection, uses and limitations. (Lifecycle)

Decision log A record of significant design decisions, alternatives considered and reasons. (Lifecycle)

Decision rights The defined authority of a role or body to approve, block, pause or retire AI systems. (Assurance)

Decision-ready reporting Reporting that highlights the decisions needed, with options and recommendations. (Assurance)

Decommissioning The controlled retirement of an AI system, including records, data and access. (Lifecycle)

Deepfake Synthetic audio, image or video that realistically imitates a real person or event. (Foundations)

Demographic parity A fairness condition in which selection rates are equal across groups. (Lifecycle)

Deployer An organisation that uses an AI system under its own authority, other than for purely personal activity. (Foundations)

Design effectiveness Whether a control, as designed, would address the risk if operated correctly. (Assurance)

Detective control A control designed to identify a risk event or control failure quickly. (Risk)

Differential privacy A mathematical framework that adds calibrated noise so outputs reveal little about any individual. (Data)

Disparate impact ratio The selection rate of one group divided by that of another; values below 0.8 often trigger review. (Lifecycle)

Distribution shift A change between the data a model was trained on and the data it meets in use, often causing performance to fall. (Foundations)

DPDP Act India's Digital Personal Data Protection Act 2023, implemented through Rules notified in 2025 and phased in. (Regulation)

Due diligence Investigation of a supplier before contracting to assess its capability, controls and risks. (Operations)

E

Effective challenge Critical review by competent, independent people with authority to have concerns addressed. (Lifecycle)

Emotion recognition system An AI system that identifies or infers emotions or intentions from biometric data. (Regulation)

Enterprise risk management (ERM) The organisation-wide framework for identifying, assessing and managing all types of risk. (Risk)

Equal opportunity A fairness condition in which true positive rates are equal across groups. (Lifecycle)

Equalised odds A fairness condition in which both true positive and false positive rates are equal across groups. (Lifecycle)

Escalation Raising an issue to a higher level of authority when it exceeds defined thresholds. (Assurance)

Ethics washing Presenting AI ethics commitments publicly without the processes or evidence to back them. (Principles)

EU AI Act Regulation (EU) 2024/1689, the European Union's horizontal, risk-based law on AI systems and general-purpose AI models. (Regulation)

Exception process A controlled way to approve and record departures from policy, with time limits and owners. (Principles)

Executive sponsor A senior leader accountable for the success and resourcing of the governance programme. (Assurance)

Exit plan A plan for moving away from a supplier, covering data, transition and continuity. (Operations)

Explainability The ability to give reasons for a specific AI output in terms the audience can understand. (Principles)

Extraterritorial effect When a law applies to organisations outside the jurisdiction because of where systems are sold or outputs used. (Regulation)

F

Fairness The principle that AI should not cause unjustified discrimination and should distribute benefits and burdens equitably. (Principles)

False positive rate The share of actual negatives wrongly classified as positive. (Lifecycle)

Fast track A streamlined approval path for low-risk AI uses. (Risk)

Federated learning Training a model across multiple devices or sites without centralising the raw data. (Data)

Feedback loop A cycle in which a model's outputs influence the future data used to train or evaluate it. (Foundations)

Fidelity How accurately an explanation reflects the model's actual behaviour. (Lifecycle)

Foundation model A large model trained on broad data that can be adapted to many downstream tasks. (Foundations)

Four-fifths rule A rule of thumb from US employment practice that a selection-rate ratio below 80% may indicate adverse impact. (Lifecycle)

Fourth party A supplier's own supplier, such as the foundation-model provider behind an AI product. (Operations)

Framework Convention on AI The Council of Europe's binding international treaty on AI, human rights, democracy and the rule of law, opened for signature in 2024. (Regulation)

Copyright © ZyeemZia

Fundamental rights impact assessment (FRIA) An assessment certain deployers of high-risk AI must perform before first use to identify impacts on people's rights. (Regulation)

G

General-purpose AI model A model trained on broad data that can competently perform a wide range of distinct tasks and be integrated into many systems. (Regulation)

Generative AI AI that creates new content such as text, images, audio, video or code in response to inputs. (Foundations)

Global explanation A description of how a model behaves across all cases, such as which features matter most. (Lifecycle)

Go-live readiness Having monitoring, runbooks, user training, notices and a tested rollback in place before a system goes live. (Lifecycle)

Golden test set A curated set of inputs with expected outputs or criteria used repeatedly to evaluate a system. (Lifecycle)

Govern function The cross-cutting NIST AI RMF function that sets culture, policies, roles and accountability for AI risk. (Regulation)

Groundedness The degree to which a generative answer is supported by the provided sources. (Lifecycle)

Grounding Constraining a model's answers to supplied, trusted sources such as retrieved documents. (Foundations)

Group fairness Fairness assessed by comparing outcomes or error rates across groups. (Principles)

H

Hard law Binding legislation and regulation enforced by authorities and courts. (Regulation)

Harmonised standard In EU law, a standard whose use can give a presumption of conformity with legal requirements. (Regulation)

Heat map A grid plotting risks by likelihood and impact to show priorities. (Risk)

High-risk AI system Under the EU AI Act, an AI system that is a regulated product safety component or falls in a listed use area and poses significant risk. (Regulation)

Historical bias Bias that arises because data accurately records past unfair decisions or conditions. (Principles)

Horizon scanning A structured, continuing process to identify and assess upcoming legal, regulatory and standards changes. (Regulation)

Horizontal regulation A law that applies across sectors, such as a general AI act or data protection law. (Regulation)

Hub and spoke An operating model with a central hub setting standards and distributed spokes applying them in business units. (Assurance)

Human in command People retain authority over whether and how AI is used at all. (Principles)

Human in the loop Oversight in which a person must approve each AI-assisted decision before it takes effect. (Principles)

Human on the loop Oversight in which a system acts autonomously while people monitor and can intervene. (Principles)

Human oversight The ability of people to understand, monitor, intervene in and override AI systems. (Principles)

Human review Checking AI output by a competent person before it is relied on or shared. (Operations)

Human rights due diligence An ongoing process to identify, prevent, mitigate and account for adverse human rights impacts. (Risk)

I

Impact The consequence of a risk event for people and the organisation. (Risk)

Impact override A rule that treats severe-impact risks as high priority regardless of their likelihood score. (Risk)

Independent validation Review and testing of a model by people independent of its development. (Lifecycle)

Individual fairness The idea that similar individuals should receive similar outcomes. (Principles)

Inference Running a trained model on new inputs to produce outputs. (Foundations)

Inferred data New personal information derived by analysis or AI, such as predicted income or health status. (Data)

Inherent risk The level of risk before controls are applied. (Risk)

Instructions for use Information from a provider telling deployers how to operate, oversee and monitor a system properly. (Lifecycle)

Inter-annotator agreement A measure of how consistently different labellers label the same items. (Data)

Interpretability The degree to which a person can understand how a model works internally. (Principles)

Interpretable model A model whose logic people can follow directly, such as a scorecard or small decision tree. (Lifecycle)

Intersectional analysis Testing outcomes for combinations of characteristics, not just single groups. (Lifecycle)

Intersectionality The combined effect of belonging to several groups at once, such as rural women, which can create distinct disadvantage. (Principles)

Inventory coverage The share of AI systems that were registered through the intake process before launch. (Assurance)

IP indemnity A contractual promise by a vendor to cover certain costs if its product infringes intellectual property rights. (Data)

Copyright © ZyeemZia

ISO/IEC 38507 An international standard giving guidance to governing bodies on the governance implications of using AI. (Assurance)

ISO/IEC 42001 The international, certifiable management system standard for AI, published in 2023. (Regulation)

ISO/IEC 42005 An international standard giving guidance on AI system impact assessment. (Risk)

J

Jailbreak A prompt technique that tries to make a model ignore its safety rules. (Lifecycle)

K

k-anonymity A property where each record is indistinguishable from at least k – 1 others on quasi-identifiers. (Data)

Key performance indicator (KPI) A metric showing progress towards an objective, such as AI value delivered. (Assurance)

Key risk indicator (KRI) A metric that signals changes in the level of a risk. (Risk)

Kill switch A tested mechanism to stop an AI system or feature quickly. (Risk)

L

Large language model (LLM) A foundation model trained on vast text to predict tokens, used for generating and understanding language. (Foundations)

Lawful basis The legal ground that permits processing of personal data, such as consent or legal obligation. (Data)

Legitimate interests Under the GDPR and similar laws, a lawful basis requiring a documented balance between the organisation's interests and individuals' rights. (Data)

Likelihood The chance that a risk event will occur within a defined period. (Risk)

Local explanation The reasons for one specific prediction or decision. (Lifecycle)

M

Machine learning A branch of AI in which systems learn patterns from data rather than following explicitly programmed rules. (Foundations)

Machine unlearning Techniques for removing the influence of specific data from a trained model. (Data)

Market surveillance authority A national authority that monitors and enforces compliance of products, including AI systems, on the market. (Regulation)

Maturity model A staged description of how capability develops, used to assess current state and plan improvement. (Assurance)

Mean time to contain (MTTC) The average time between detecting an incident and containing it. (Assurance)

Measurement bias Bias arising when a label or feature measures the intended concept differently or poorly for some groups. (Principles)

Misuse case A scenario describing how a system could be used, deliberately or carelessly, to cause harm. (Risk)

Model card A short structured document describing a model's intended use, performance, limits and evaluation. (Lifecycle)

Model extraction Copying a model's behaviour by systematically querying it. (Principles)

Model risk management The discipline, long established in banking, of governing the risks of models through inventory, validation and oversight. (Lifecycle)

Model version pinning Fixing an application to a specific model version so it does not change without deliberate action. (Operations)

Monitoring threshold A pre-agreed value of a metric that triggers review or action when crossed. (Operations)

N

Near-miss An event that could have caused harm but was caught in time; valuable for learning. (Operations)

Necessity and proportionality Tests of whether AI is needed to achieve a legitimate goal and whether its intrusion is justified by the benefit. (Risk)

NIST AI RMF The voluntary US AI Risk Management Framework organised into Govern, Map, Measure and Manage functions. (Regulation)

Nonconformity Failure to meet a requirement of a policy, standard or management system. (Assurance)

Notification duty A legal or contractual obligation to inform regulators, individuals or partners about an incident within a set time. (Operations)

O

OECD AI Principles Intergovernmental principles for trustworthy AI adopted in 2019 and updated in 2024. (Regulation)

Open-weight model A model whose trained parameters are published for others to download and run, under a licence. (Operations)

Operating effectiveness Whether a control actually operated as designed throughout the period. (Assurance)

Operating model How governance responsibilities, people, processes and tools are organised across an organisation. (Assurance)

Operationalisation Turning principles into requirements, controls, owners and evidence that shape real decisions. (Principles)

Ordinance (Bangladesh) A law made by the President when Parliament is not in session, with legal force subject to later parliamentary processes. (Regulation)

Copyright © ZyeemZia

Out-of-scope use A use that the provider has stated the system is not designed or validated for. (Lifecycle)

Overfitting When a model learns its training data too closely and generalises poorly to new data. (Foundations)

Override rate The share of AI recommendations that human reviewers change or reject. (Principles)

P

Permission-aware retrieval Retrieval that checks a user's access rights before using documents to generate an answer. (Data)

Plan-Do-Check-Act (PDCA) An iterative improvement cycle used in management system standards. (Assurance)

Playbook A pre-written set of steps for responding to a specific type of incident. (Operations)

Population stability index (PSI) A measure of how much a variable's distribution has shifted from a baseline. (Operations)

Post-hoc explanation An explanation produced after a model is trained, by analysing its behaviour. (Lifecycle)

Post-incident review A structured, blame-free review after an incident to identify lessons and improvements. (Operations)

Post-market monitoring A provider's systematic collection and review of data on a system's performance after it is placed on the market. (Regulation)

Pre-mortem A technique in which a team imagines a future failure and works backwards to identify its causes. (Risk)

Precision The share of positive predictions that are correct. (Lifecycle)

Preventive control A control designed to stop a risk event from occurring. (Risk)

Principles-based regulation An approach that sets high-level outcomes and relies on regulators and organisations to apply them in context. (Regulation)

Privacy notice Information given to people about how their personal data is processed and their rights. (Data)

Privacy-enhancing technology (PET) A technique that reduces privacy risk while allowing data to be used, such as differential privacy or federated learning. (Data)

Profile (NIST) An application of the AI RMF to a specific setting, technology or use case, such as generative AI. (Regulation)

Profiling Automated processing of personal data to evaluate or predict aspects of a person, such as performance, behaviour or reliability. (Regulation)

Prohibited AI practice A use of AI banned under the EU AI Act because of unacceptable risk, such as social scoring. (Regulation)

Prompt hygiene Practices for writing prompts that exclude unnecessary sensitive data and give clear, checkable instructions. (Operations)

Prompt injection An attack in which crafted input causes a model to ignore its instructions or take unintended actions. (Foundations)

Prompt log A record of inputs and outputs of a generative-AI system, which may contain sensitive data. (Data)

Proportionality Matching the depth of governance controls to the level of risk a system poses. (Foundations)

Protected characteristic An attribute, such as sex, religion, race, caste, disability or age, that law or policy protects from discrimination. (Principles)

Provider An organisation that develops an AI system or model, or has it developed, and places it on the market or puts it into service under its own name. (Foundations)

Proxy variable A feature that indirectly encodes another attribute, often a protected characteristic, leading to hidden discrimination. (Foundations)

Pseudonymisation Replacing direct identifiers with codes so data cannot be linked to a person without separately held information. (Data)

Purpose limitation The privacy principle that data collected for one purpose should not be reused for incompatible purposes. (Principles)

Q

Quasi-identifier An attribute, such as age, area or job, that is not identifying alone but can identify people in combination. (Data)

R

RACI A matrix that assigns who is Responsible, Accountable, Consulted and Informed for each activity. (Principles)

Re-performance An audit technique in which the auditor repeats a control or calculation to verify it. (Assurance)

Re-registration trigger A change, such as a new purpose or data source, that requires a system to go back through intake. (Risk)

Reason codes Short standardised statements of the main factors behind a decision, common in credit scoring. (Lifecycle)

Recall The share of actual positives that a model correctly identifies; also called sensitivity or true positive rate. (Lifecycle)

Red teaming Structured adversarial testing to find ways a system can fail or be misused. (Principles)

Redress Correction of errors and remedy of harm caused by an AI-assisted decision. (Principles)

Regression testing Re-running tests after changes to ensure performance has not worsened. (Lifecycle)

Regulatory sandbox A supervised environment where innovators can test products under regulator guidance. (Regulation)

Copyright © ZyeemZia

Representation bias Bias caused by some groups being missing or under-represented in training or test data. (Principles)

Representativeness The degree to which data reflects the population and conditions a model will serve. (Data)

Requirement A specific, testable condition an AI system or process must meet. (Principles)

Residual risk The level of risk remaining after controls are applied. (Risk)

Responsible AI Designing, building and using AI in ways that respect people's rights and wellbeing and that can be justified to stakeholders. (Foundations)

Retrieval-augmented generation (RAG) A design in which a generative model answers using documents retrieved from a knowledge source at query time. (Data)

Reversibility The degree to which a harm can be undone after it occurs. (Risk)

Reweighting A pre-processing technique that gives different weights to training examples to reduce bias. (Lifecycle)

Right to audit A contract term allowing the customer, or an independent party, to assess the supplier's compliance. (Operations)

Rights reservation (opt-out) A rights holder's statement that their content may not be used for text and data mining or AI training. (Data)

Risk The effect of uncertainty on objectives, usually expressed through likelihood and consequence. (Risk)

Risk acceptance A documented decision by an authorised person to retain a residual risk. (Risk)

Risk appetite The amount and type of risk an organisation is willing to accept in pursuit of its objectives. (Foundations)

Risk owner The person accountable for managing a particular risk. (Risk)

Risk tolerance A measurable limit on a risk that triggers action when exceeded. (Risk)

Risk treatment Selecting and implementing options to modify risk: avoid, reduce, transfer or accept. (Risk)

Robustness An AI system's ability to maintain performance under unusual, noisy or changing conditions. (Principles)

Rollback Returning a system to a previous, known-good version. (Operations)

Root cause analysis Investigation to find the underlying causes of an incident, not just its symptoms. (Operations)

S

Safe failure Designing a system so that when it fails, it does so in a way that limits harm, such as handing over to a human. (Principles)

Sector regulator A regulator responsible for one industry, such as a central bank or telecoms authority, that often sets AI expectations for that sector. (Regulation)

Sectoral regulation Rules specific to one industry, such as banking model-risk guidance. (Regulation)

Selection rate The share of a group receiving a positive outcome, such as approval. (Lifecycle)

Serious incident Under the EU AI Act, an incident leading to death or serious harm to health, serious disruption of critical infrastructure, infringement of fundamental-rights obligations or serious harm to property or the environment. (Regulation)

Severity level A classification of an incident's seriousness that sets the speed and level of response. (Operations)

Shadow AI AI tools or features used in an organisation without its knowledge or approval. (Foundations)

Shadow mode Running a new model alongside the existing process without its outputs affecting decisions. (Lifecycle)

Shapley values A method from game theory that attributes a prediction to each input feature's contribution. (Lifecycle)

Soft law Non-binding instruments such as guidelines, principles and codes that still influence behaviour and expectations. (Regulation)

Solely automated decision A decision made without meaningful human involvement, which some laws restrict where it has significant effects. (Data)

Speak-up culture An environment in which people feel safe raising concerns about risks or wrongdoing. (Assurance)

Special category data Sensitive personal data, such as health, biometric or religious data, that receives extra legal protection. (Data)

Stage gate A defined decision point where evidence is reviewed before a system proceeds to the next stage. (Lifecycle)

Staged rollout Releasing a system to a small share of users first and expanding as evidence accumulates. (Lifecycle)

Stakeholder engagement Consulting people affected by a system, or their representatives, to understand impacts and shape mitigations. (Risk)

Stakeholder mapping Identifying everyone who affects or is affected by a system, including non-users. (Risk)

Standard (internal) A detailed mandatory requirement supporting a policy on a specific topic. (Principles)

Statement of Applicability A document listing which controls an organisation has selected, why, and the justification for exclusions. (Regulation)

Substantial modification A significant change to an AI system that can alter its risk or purpose and may change the organisation's role and duties. (Foundations)

Synthetic content labelling Requirements to mark or disclose content generated or manipulated by AI. (Regulation)

Copyright © ZyeemZia

Synthetic data Artificially generated data that mimics the statistical properties of real data. (Data)

System card Documentation describing a whole AI system, including models, safeguards, evaluations and residual risks. (Lifecycle)

Systemic risk (GPAI) Under the EU AI Act, risk from the most capable general-purpose models, presumed above a training-compute threshold or designated by the Commission. (Regulation)

T

Technical documentation The formal record demonstrating that an AI system meets legal and technical requirements. (Lifecycle)

Text and data mining (TDM) Automated analysis of large amounts of text and data, including for AI training, subject to copyright exceptions and opt-outs in some laws. (Data)

Third-party risk management Identifying, assessing and controlling risks arising from suppliers and partners. (Operations)

Three lines model A model distinguishing first-line management, second-line risk and compliance functions, and third-line internal audit, under a governing body. (Assurance)

Tiering Assigning an AI system to a risk level that determines the governance it requires. (Risk)

Traceability The ability to reconstruct how an AI system produced an outcome using logs and records. (Principles)

Training data The examples used to fit a model's parameters during training. (Foundations)

Transparency Openness about the existence, purpose, functioning, data and limits of an AI system. (Principles)

Triage A quick initial assessment that sorts cases by urgency or risk. (Risk)

Trustworthy AI AI that is lawful, ethical and technically robust, so stakeholders can reasonably rely on it. (Foundations)

U

Use-case intake The process by which new AI ideas are submitted, screened and routed for review. (Risk)

Z

ZAIG Stack The eight-layer model used in this track: Foundations, Principles, Regulation, Risk, Data, Lifecycle, Operations and Assurance. (Foundations)

Copyright © ZyeemZia

CAPSTONE

Capstone: Build an AI governance programme across the ZAIG Stack

Choose a real organisation you know, or a realistic one (for example: a mobile financial services provider in Dhaka using AI for credit scoring and fraud detection, a private hospital group adopting a generative-AI documentation assistant, or a garment exporter in Chattogram using AI to screen job applicants). Take it through all eight layers of the ZAIG Stack and produce a governance pack that an executive committee could approve, an internal auditor could test and a board could oversee.

Deliverables

☐ AI inventory of at least five systems with owners, roles (provider or deployer) and risk tiers

☐ AI principles statement and a one-page AI policy aligned to them

☐ Regulatory applicability map covering the EU AI Act, local law and the frameworks you will align to

☐ AI risk register with likelihood, impact, controls and residual risk for the top ten risks

☐ One full AI impact assessment for the highest-risk system

☐ Data governance and privacy plan: lawful basis, provenance, minimisation and retention

☐ Lifecycle controls: stage gates, model documentation, bias testing and monitoring plan

☐ Generative-AI acceptable-use policy and a third-party AI due-diligence questionnaire

☐ AI incident response playbook with severity levels and reporting duties

☐ Governance operating model, assurance plan, metrics dashboard and a board report

Self-assessment rubric

CRITERION	DEVELOPING	PROFICIENT	EXCELLENT
Understanding & inventory	○ Systems listed without detail	○ Complete inventory with owners and roles	○ Inventory with roles, tiers, data and dependencies kept current
Principles & policy	○ Generic values only	○ Principles linked to a policy	○ Principles translated into testable requirements and owners
Regulatory alignment	○ Laws named only	○ Applicability assessed per system	○ Obligations mapped to controls, evidence and dates
Risk & impact	○ Few risks listed	○ Register and one assessment	○ Calibrated scoring, affected groups consulted, treatment tracked
Data & privacy	○ Not addressed	○ Lawful basis and controls	○ Provenance, minimisation, PETs and retention by design
Lifecycle & testing	○ No gates or tests	○ Gates, documentation and tests	○ Bias, explainability and drift controls with thresholds and owners
Operations, suppliers & incidents	○ Ad hoc	○ Policy, questionnaire and playbook	○ Integrated use policy, contract clauses and rehearsed incident response
Assurance & board oversight	○ No reporting	○ Metrics and an audit plan	○ Three-lines model, risk-based assurance and decision-ready board reporting

Copyright © ZyeemZia

CAPSTONE

Planning pages

Sketch your design, timeline or architecture here.

Copyright © ZyeemZia

EXAM PREPARATION

Practice exam · 60 questions

The official online exam draws 40 questions at random from a separate, secret bank that tests the same skills, with a 60-minute limit and a 80% pass mark. Practise with these questions first: time yourself, mark your answers, then check the key and read every explanation, including for the questions you got right.

Foundations — AI Fundamentals for Governance Professionals

1. A logistics company's demand-forecasting model was accurate for two years. After a new competitor changed customer behaviour, forecasts became unreliable, although nobody changed the code. What BEST explains this?

   (A) A software bug was introduced by the most recent operating system security patch
   (B) The model was overfitted because it had too few parameters to learn
   (C) The vendor quietly switched the model to a generative architecture
   (D) The live data drifted from the patterns learned in training

2. An insurer removes gender from its pricing model, yet women still receive systematically higher quotes. What should the governance lead investigate FIRST?

   (A) Whether the model is hosted in a secure data centre
   (B) Whether other features are acting as proxies for gender
   (C) Whether the model's user interface displays prices clearly
   (D) Whether the pricing team received training on the new tool

3. A department enables an AI meeting-summary feature in its existing office software. The governance team was not informed. How should this be treated?

   (A) As out of scope because it came with software already licensed
   (B) As an AI use case to register, assess and give an owner
   (C) As a security incident requiring immediate disciplinary action
   (D) As the vendor's responsibility alone, so no internal action or registration is needed

4. A company buys a general chatbot platform, retrains it on its own data for tenant screening and sells it to landlords under its own brand. What is the MOST important governance consequence?

   (A) The original platform vendor becomes solely responsible for any harm
   (B) The system no longer counts as AI because it was retrained
   (C) It likely takes on provider duties for the new system
   (D) Only the landlords using it have any obligations

5. A board member asks why a generative-AI assistant needs different controls from the company's established credit-scoring model. Which answer is MOST accurate?

   (A) Generative models are always less accurate than predictive ones
   (B) Generative AI never processes personal data, so privacy controls are completely different
   (C) Credit models are exempt from governance because they are older
   (D) Its open-ended outputs and wide user base create unplanned uses

6. An AI agent can read customer tickets and issue refunds through the payment system. Which control MOST directly limits the harm from a manipulated or mistaken agent?

   (A) A longer and more detailed system prompt for the agent
   (B) A switch to the largest available language model
   (C) Refund limits, least privilege and human approval
   (D) A monthly report on the number of tickets processed

7. An inventory exercise finds that many staff paste client contracts into personal accounts on public chat assistants. What is the BEST first response?

   (A) Offer an approved, protected tool with clear rules and training
   (B) Dismiss the staff identified so that others are deterred
   (C) Do nothing because personal productivity tools are outside governance
   (D) Block the internet for all staff who handle client contracts

Copyright © ZyeemZia

8. A chief executive argues that AI governance should wait until the company is larger. Which principle BEST supports starting now without slowing the business?

   (A) Proportionality: light rules for low risk, focus on high impact
   (B) Uniformity: one full assessment process applied to every AI tool the company uses
   (C) Deferral: governance added only after the first regulatory inquiry
   (D) Delegation: leaving governance decisions entirely to AI vendors

Principles — Responsible AI Principles in Practice

9. An energy company's AI principles promise fairness, but no fairness test has ever been run and no owner is named. The board asks what to do. What should the AI governance lead recommend FIRST?

   (A) Publish the principles more widely to build public trust in the company's AI
   (B) Replace the principles with a longer list that covers sustainability too
   (C) Name owners and set testable requirements, starting with high-risk systems
   (D) Wait for regulators to define fairness before taking any further action

10. A health insurer's claims-triage model shows similar overall accuracy for men and women, but women's genuine claims are wrongly flagged for investigation twice as often. Which statement is MOST accurate?

   (A) The model is fair because accuracy is balanced
   (B) The difference is acceptable because overall accuracy is very high
   (C) The issue is purely technical and does not need any policy decision
   (D) The model is unfair on the error that harms claimants most

11. A data science team says it has removed religion from a scholarship model, so the model cannot discriminate by religion. What should governance require?

   (A) Acceptance of the change because the attribute is no longer in the model
   (B) Collection of more religious data
   (C) Outcome testing by religion and checks for proxy features
   (D) Replacement of the model with a random lottery for all applicants

12. A customer refused credit by an AI-assisted process asks for reasons. The vendor model is a complex ensemble. What does a good response provide?

   (A) A statement that the vendor's algorithm decided and cannot be questioned
   (B) The main factors, plain language and a route to human review
   (C) The complete source code and model weights so the customer can check
   (D) A general brochure on how AI works

13. Analysts approve 99.8% of an AI system's recommendations after about 30 seconds each. Management cites this as proof the model is excellent. What is the BEST interpretation?

   (A) It may show automation bias; test review quality
   (B) It proves the model is excellent and that review can safely be removed
   (C) It shows the analysts are lazy
   (D) It means the oversight design is effective and needs no further checks

14. A retailer wants to use loyalty-card purchase histories, collected for rewards, to infer customers' health conditions for targeted adverts. Which principle is MOST directly engaged?

   (A) Robustness of the model under adversarial inputs from attackers
   (B) Purpose limitation, along with sensitive-data rules
   (C) Interpretability of the model's internal parameters to engineers
   (D) Latency of the recommendation engine

Copyright © ZyeemZia

15. An organisation is drafting its first AI policy. Legal wants every testing threshold and template inside the policy. What is the BEST structure?

(A) A single long policy containing every threshold, template and tool name

(B) No policy at all, only guidelines that teams may choose to follow

(C) Separate policies for each department

(D) A short policy with detail in standards and procedures

Regulation — The AI Regulatory and Standards Landscape

16. A Chattogram software firm with no EU office sells a CV-ranking tool to recruitment agencies in the Netherlands. The CEO believes EU law cannot reach the firm. What is the MOST accurate advice?

(A) EU law applies only to companies with a registered office or staff in the EU

(B) Only the Dutch agencies have duties, because they use the tool in Europe

(C) The tool is minimal risk because a recruiter makes the final selection

(D) The firm is likely a provider of a high-risk system under the EU AI Act

17. A retailer plans to use cameras and AI to infer the emotions of its shop-floor staff to rate their customer service. It operates in Spain. How should the governance lead respond?

(A) Treat it as minimal risk because it does not make decisions about customers

(B) Proceed with a notice to staff, which satisfies the transparency duty

(C) Advise that this is likely prohibited and should not proceed

(D) Register it as a general-purpose AI model before launch

18. A public hospital in an EU member state will deploy a high-risk triage system bought from a certified provider. Which step is the hospital's own obligation before first use?

(A) Perform the provider's conformity assessment again from the beginning

(B) Carry out a fundamental rights impact assessment

(C) Affix its own CE marking to the system

(D) Publish a training-content summary for the model

19. A board member says an ISO/IEC 42001 certificate means the company's AI is fully compliant with the EU AI Act. What is the BEST response?

(A) Correct, because the certificate replaces conformity assessment in every case

(B) Correct, but only for systems built before the certificate was issued

(C) Incorrect, because ISO/IEC 42001 has no relevance to AI regulation at all

(D) It evidences a sound AI management system in scope, not legal compliance

20. A risk team wants a framework that gives practical actions to identify, measure and treat AI risks, but does not need certification. Which instrument fits BEST?

(A) The EU AI Act's penalty provisions for general-purpose AI model providers

(B) A certification body's accreditation rules for auditing AI management systems

(C) The NIST AI Risk Management Framework

(D) OECD recommendations to governments

21. An Indian fintech asks which national AI law governs its credit model as of 2026. What is the MOST accurate answer?

(A) No standalone AI act; data protection and sector rules apply

(B) A comprehensive AI act modelled on the EU law, in force since 2024

(C) No rules at all until an AI act passes

(D) Only the voluntary OECD principles, which India has made binding

22. A company's legal team learns that high-risk deadlines in the EU AI Act may be postponed by a proposed amendment. What should the AI governance lead do?

(A) Pause all high-risk compliance work until the amendment is finally adopted

(B) Track the amendment but keep building controls on the legislated timeline

(C) Assume the postponement applies and tell product teams to stop preparing

(D) Ignore the proposal because amendments to EU law are never adopted

Copyright © ZyeemZia

23. A Bangladeshi mobile wallet uses AI for credit scoring only in Bangladesh. A manager says the absence of an AI act means no governance is needed. Which response is MOST accurate?

(A) Data, cyber security, consumer and central bank rules still apply
(B) Correct, because Bangladeshi law does not regulate any use of algorithms
(C) Incorrect, because the EU AI Act applies to all credit scoring worldwide
(D) Correct, if the model was bought abroad

Risk — AI Risk Management and Impact Assessment

24. A team scoring risks for a hospital's AI sepsis-alert tool rates 'missed sepsis case' as likelihood 1, impact 5 (score 5) and ranks it below several score-9 operational risks. What should the governance lead do?

(A) Accept the ranking because the matrix is the agreed method for prioritising
(B) Increase the likelihood score so the numbers produce the desired ranking
(C) Apply an impact override and prioritise the missed-case risk
(D) Remove the risk because likelihood is low

25. An e-commerce company wants to use AI to set individual prices based on browsing behaviour and inferred income. Which step should come FIRST in the impact assessment?

(A) Choose the most accurate pricing algorithm
(B) Calculate the expected revenue increase for the next financial year
(C) Draft customer notices explaining why some people pay higher prices
(D) Describe the system and test necessity and proportionality

26. A board approves the statement: 'We have a low appetite for unfair outcomes in customer decisions.' Six months later nobody can say whether it has been breached. What is MISSING?

(A) A longer appetite statement
(B) A separate appetite statement for each department
(C) Measurable tolerances and key risk indicators
(D) An external auditor's opinion on the statement wording

27. A vendor offers to indemnify a lender for any losses from its AI credit model. The lender's CFO says this transfers the fairness risk. What is the BEST response?

(A) Indemnity shares cost, but the lender stays accountable and needs controls
(B) Agree, because the indemnity transfers all legal responsibility to the vendor
(C) Agree, provided the indemnity has no upper financial limit in the contract
(D) Disagree, because indemnities are never enforceable for any technology

28. A university's AI intake form takes three weeks for every request. Departments start buying AI tools on credit cards. What is the MOST effective fix?

(A) Ban credit-card software purchases
(B) Add more questions to the intake form to make reviews thorough
(C) Ask the ethics committee to meet daily for every request received
(D) Tiered routing with a fast track for low-risk uses

29. A data protection officer asks whether the AI impact assessment can replace the DPIA required by law for a profiling system. What is the BEST answer?

(A) No, the two assessments must always be completed by separate teams
(B) Yes, if it includes a module meeting every DPIA requirement
(C) Yes, any AI assessment automatically satisfies data protection law
(D) No, DPIAs only apply to overseas hosting

30. An internal audit finds 180 AI risks recorded across 40 systems. The board receives the full list each quarter and has stopped reading it. What should change?

(A) Stop reporting AI risks to the board
(B) Aggregate risks into a few themes with trends and worst residuals
(C) Send the full list monthly instead of quarterly for more visibility
(D) Report only those risks that already have completed treatment plans

Copyright © ZyeemZia

Data — Data Governance and Privacy for AI

31. A garment exporter's HR team wants to train an attrition-prediction model on staff data collected for payroll. The privacy officer has not been consulted. What should the AI governance lead require FIRST?

    (A) Selection of an accurate algorithm before any privacy review takes place

    (B) Removing employee names from the payroll file

    (C) Approval from the payroll software vendor to reuse the data for analytics

    (D) A lawful-basis and purpose-compatibility check with the privacy officer

32. A telecom shares an 'anonymised' dataset of hourly phone locations with a city planner after deleting phone numbers. What is the MAIN concern?

    (A) The dataset will be too large to transfer efficiently to the planning team

    (B) Deleting phone numbers makes the data useless for transport modelling

    (C) City planners are not permitted to use any mobile network data at all

    (D) Location traces can re-identify people, so the data may still be personal

33. An enterprise assistant indexes all shared drives. Users begin receiving answers drawn from documents they should never have seen. Which control addresses the root cause?

    (A) Clean up permissions and enforce them at retrieval time

    (B) Switch to a larger and more capable language model from another vendor

    (C) Add a disclaimer telling users to ignore confidential information

    (D) Shorten the assistant's answers

34. A customer asks a bank to erase her data. Her records were used to train a credit model last year. What is the MOST appropriate response?

    (A) Delete her data from datasets and exclude it from future training

    (B) Refuse because data used in a trained model can never be erased

    (C) Delete the whole credit model immediately and stop lending decisions

    (D) Ask her to sign a waiver confirming the model may keep her data

35. A hospital wants to develop a model with a university without moving patient records off-site. Which technique BEST fits?

    (A) Publishing the records after removing patient names

    (B) Federated learning across the sites

    (C) Emailing encrypted spreadsheets

    (D) Training on synthetic data generated by the university alone

36. A marketing agency wants to use AI-generated images as the company's new logo and register exclusive rights. What should governance advise?

    (A) The images are automatically protected because the company paid for the tool

    (B) The model provider will own the logo outright under every jurisdiction's law

    (C) Exclusive copyright may not exist without human authorship

    (D) AI images cannot be used commercially

37. A Bangladeshi bank plans to use a generative-AI vendor that stores logs in another country. What should the governance lead check FIRST?

    (A) Whether the vendor's interface supports the Bangla language well

    (B) Whether the vendor has won industry awards for its AI products

    (C) Transfer and localisation rules from law and the central bank

    (D) Whether staff like the tool

Copyright © ZyeemZia

38. A data scientist proposes adding 40 extra features to a loan model, including mobile phone brand and contact-list size, to gain 0.3% accuracy. What is the BEST governance response?

(A) Accept them because any accuracy gain improves the model's lending decisions
(B) Test whether the features are necessary and fair before adding them
(C) Accept them provided the features are stored in an encrypted database
(D) Reject all new features permanently to keep the model stable

Lifecycle — Model Lifecycle Governance, Testing and Explainability

39. A fraud model flags 1,000 transactions; 250 are actually fraudulent. Analysts complain about the workload. Which metric BEST describes the problem?

(A) Low recall: the model misses most fraud cases
(B) High accuracy: the model is correct most of the time
(C) Low precision: most flags are false alarms
(D) High latency: scoring is too slow

40. A hiring screen passes 45% of applicants without disabilities and 27% of applicants with disabilities. What does this indicate?

(A) A ratio of 1.67, which is acceptable under the four-fifths rule
(B) A disparate impact ratio of 0.60, needing investigation
(C) Evidence of unlawful discrimination that must lead to prosecution
(D) No issue, since disability is not protected

41. A validation report for a Bangla-English support chatbot used only English test prompts written by developers. What should the validator require?

(A) Approval, since developer-written prompts are more precise
(B) Doubling the number of English prompts already used
(C) Removing Bangla support so the results are valid
(D) Re-testing with realistic prompts from real users

42. A data science team proposes to validate its own credit model to meet a deadline. What is the PRIMARY governance objection?

(A) Validation needs independence to provide effective challenge
(B) The team lacks the statistical software needed for validation
(C) Validation is only legally required for generative-AI models
(D) Self-validation is always slower

43. A vendor's model card for a medical-imaging tool reports high overall accuracy but nothing about performance across skin tones, ages or equipment types. What should the deploying hospital do?

(A) Accept it, because overall accuracy is the standard measure in medicine
(B) Write the missing sections itself using the vendor's brochure
(C) Reject the tool outright
(D) Make group results a contract deliverable and test locally

44. A lender wants to explain refusals using a natural-language generator that writes persuasive reasons. Tests show the reasons often mention factors with little effect on the score. What is the BEST decision?

(A) Keep it, because customers find the reasons persuasive and clear
(B) Replace it with a method whose fidelity is verified
(C) Keep it, but add a footnote saying reasons may not be accurate
(D) Stop giving reasons to customers

45. A team wants to retire an old churn model. Which action is MOST important from a governance view?

(A) Archive records, revoke access and dispose of unneeded data
(B) Delete every trace of the model to avoid future audit questions
(C) Leave its API running in case another team wants it later
(D) Transfer ownership to the newest member of the data team

Copyright © ZyeemZia

Operations — Operating AI Safely: Monitoring, Use Policy, Suppliers and Incidents

46. A university's admissions chatbot was accurate at launch. Six months later, complaints rise after the admissions rules changed, yet the chatbot's technical metrics look stable. What does this MOST likely show?

(A) The complaints are probably mistaken
(B) The monitoring tracks model metrics but not real-world outcomes
(C) The chatbot must be replaced by a larger model to fix the issue
(D) Admissions rules should be frozen to match the chatbot's knowledge

47. A provider updates the language model behind a bank's assistant with two days' notice. The bank has no regression tests. What should the governance lead put in place FIRST for future updates?

(A) Version pinning and a regression suite run before switching
(B) A policy forbidding any model update by any vendor for any reason
(C) A request that the vendor promise never to change the model again
(D) A staff memo asking users to report odd answers

48. A garment exporter's generative-AI policy says only 'use AI responsibly'. Staff paste supplier pricing into public tools. What is the MOST effective improvement?

(A) A longer statement on the importance of responsible innovation
(B) Disciplinary action against all staff who used public tools
(C) A data-and-tool matrix stating which data may go into which tools
(D) A ban on using generative AI anywhere in the company

49. A procurement team wants to sign an AI vendor's standard terms, which allow the vendor to train on customer data and change models without notice. The system will process patient records. What should governance require?

(A) Renegotiated terms banning training on data and requiring notice
(B) Acceptance, since standard terms are rarely negotiable for vendors
(C) Acceptance, provided the vendor holds an information security certificate
(D) Rejection of all cloud vendors

50. A support chatbot exposes some customers' order details to other users. Which action should come FIRST once the incident is confirmed?

(A) Retrain the model on a cleaner dataset before doing anything else
(B) Contain it by disabling the feature and preserving logs
(C) Wait for a full root-cause analysis before taking any action
(D) Blame the cloud provider publicly

51. A data protection officer asks when the 72-hour clock for a personal data breach caused by an AI system usually starts under GDPR-style laws. What is the BEST answer?

(A) When the investigation is fully complete and signed off
(B) When the AI vendor confirms the breach in writing
(C) When customers first complain
(D) When the organisation becomes aware of the breach

52. An internal audit finds that a bank's AI credit model has been retrained monthly for a year with new features added twice, all approved only by the data science lead. What is the MAIN control gap?

(A) Retraining should never happen more than once a year
(B) The data science lead should have used a different algorithm
(C) Significant changes skipped re-validation and gate approval
(D) Monthly retraining always makes models less accurate

53. Staff at a hospital receive a voice message that sounds like the CEO, asking them to share patient lists urgently with a 'consultant'. What playbook action is MOST important?

(A) Comply quickly because the voice matches the CEO's exactly
(B) Forward the message to all staff so they can judge it
(C) Reply to the message asking the sender to confirm identity
(D) Verify through a known independent channel before acting

Copyright © ZyeemZia

Assurance — Audit, Assurance and the AI Governance Programme

54. Internal audit finds that 5 of 12 high-risk AI systems launched before their impact assessments were approved, although the policy requires approval first. How should this control be described?

(A) Operating effectively, because most systems still have an assessment
(B) Poorly designed, so the whole AI policy must be rewritten
(C) Outside audit scope entirely
(D) Designed adequately but not operating effectively

55. A supplier presents an ISO/IEC 42001 certificate as proof that its hiring tool is free of bias. What should the buyer conclude?

(A) It shows a management system, not an unbiased tool
(B) The tool has been independently tested and found unbiased
(C) The buyer no longer needs any local fairness testing of the tool
(D) It replaces the buyer's assessment

56. A company's AI governance sits entirely within the data science team that builds the models. Which weakness is MOST serious?

(A) Data scientists cost too much
(B) The team is too small to approve every request quickly
(C) Lack of independent challenge of the builders
(D) Data scientists do not understand the models they build

57. The board receives a 60-page technical AI report each quarter and rarely discusses it. What change would MOST improve oversight?

(A) Adding detailed model metrics for every AI system in use
(B) Moving to an annual report to reduce reading time
(C) Inviting the vendors to present their own metrics instead
(D) A one-page headline with decisions, risks and a dashboard

58. An organisation's AI metrics have been green for a year, but two AI failures were first exposed by customers on social media. What is the BEST interpretation?

(A) The metrics measure activity, not control effectiveness
(B) The metrics are correct and the customers were mistaken
(C) Social media complaints should be excluded from reporting
(D) The programme is fully mature

59. A newly appointed AI governance lead has 90 days to show progress at a hospital group with no existing programme. What should come FIRST?

(A) Applying for ISO/IEC 42001 certification for the hospital group
(B) An inventory to find AI already in use
(C) Writing an 80-page AI policy
(D) Commissioning an external audit of all clinical AI models

60. A maturity assessment scores an organisation at level 4 for Principles but level 1 for Assurance. What should the roadmap prioritise?

(A) Rewriting the principles to reach level 5 first
(B) Building assurance, such as a first internal AI audit
(C) Averaging the scores and reporting the result only
(D) Pausing all AI use until every layer reaches level 4

Copyright © ZyeemZia

EXAM PREPARATION

Practice exam answers & explanations

1. D Machine-learning behaviour depends on data. When the world changes, the learned patterns fit less well even with unchanged code. The other options do not match the facts described.

2. B Removing an attribute does not remove its influence when correlated features carry the same information. Hosting, interface and training do not explain the pattern.

3. B AI features inside bought software still need registration and an owner. Treating it as an incident or as purely the vendor's problem is disproportionate or ignores deployer responsibility.

4. C Repurposing and rebranding a system generally makes the organisation a provider with the related duties. Responsibility does not stay only with the original vendor or pass only to customers.

5. D The key difference is breadth of use and output type. Accuracy comparisons, privacy claims and exemptions are inaccurate generalisations.

6. C Permissions and approval gates contain the impact of wrong actions. Prompts and model size do not prevent manipulation; volume reports detect nothing in time.

7. A A safe, approved path plus clear rules and awareness reduces leakage without driving use underground. The other options are disproportionate or ignore the risk.

8. A Proportionate governance keeps low-risk use fast and focuses effort on systems that can cause serious harm. The other options are slow, reactive or abdicate responsibility.

9. C Ownership and testable requirements operationalise principles where risk is highest. Publicity, longer lists or waiting do not close the gap.

10. D Balanced accuracy can hide unequal false positives. Here the harm falls on honest claimants, so the error-rate gap is the fairness issue and needs a policy decision.

11. C Proxies can carry protected information. Testing outcomes, which may require carefully controlled access to the attribute, shows whether discrimination persists.

12. B Meaningful explanation plus contestability serves the individual. Blaming the vendor, dumping code or generic material does not.

13. A Very high agreement with short reviews often signals rubber-stamping. Testing with seeded cases and reviewing conditions reveals the truth.

14. B Reusing data for an unexpected, sensitive inference engages purpose limitation and special-category protections.

15. D A layered framework keeps the policy stable while standards and procedures can change. A monolith dates quickly; optional or fragmented guidance fails.

16. D The Act reaches providers placing systems on the EU market wherever based, and recruitment ranking is a listed high-risk use. Deployers also have duties, but that does not remove the provider's.

17. C Emotion recognition in the workplace is prohibited except for medical or safety reasons. A notice does not cure a prohibited practice.

18. B Public bodies deploying high-risk systems must carry out a FRIA. Conformity assessment and CE marking are provider duties; training summaries apply to GPAI providers.

19. D Certification shows the management system meets the standard within scope. It supports but does not equal legal compliance.

20. C The NIST AI RMF is a voluntary, practical risk framework. The other options do not provide organisational risk practices.

21. A India relies on principles-based guidelines, the DPDP Act and Rules, and sector regulators such as the central bank, rather than a standalone AI act.

22. B Proposals may change or fail. Prudent programmes monitor while continuing preparation, since the controls are good practice either way.

23. A Existing domestic laws and sector supervision apply. The EU Act does not reach a purely domestic system, and buying from a vendor does not remove deployer responsibility.

24. C Severe, potentially fatal harms need priority regardless of the multiplied score. Manipulating scores or deleting the risk undermines the process.

25. D Assessment starts by understanding the system and whether the intrusive approach is justified. Algorithm choice, revenue and notices come later, if at all.

26. C Appetite becomes operational through measurable limits and monitored indicators. More words or opinions do not make it testable.

27. A Contracts can share financial impact but not the deployer's accountability to customers and regulators, so controls remain necessary.

28. D Proportionate tiering makes the front door fast for low-risk uses and removes the incentive to bypass it. Bans or heavier forms drive more workarounds.

29. B An integrated template can meet the legal DPIA requirements if it covers them fully. Automatic equivalence is not assumed, and separate teams are not required.

30. B Boards need aggregated, decision-ready information. Less reporting, more volume or selective reporting all reduce oversight.

Copyright © ZyeemZia

31. D Repurposing payroll data for prediction needs a lawful basis and purpose check first. Removing names rarely anonymises HR data, and vendors cannot authorise the use.

32. D A few location points can uniquely identify most people, so removing numbers does not anonymise. Size and usefulness are secondary; planners can use properly aggregated data.

33. A The assistant exposes over-shared content; permission hygiene and permission-aware retrieval fix the cause. Model size, disclaimers and answer length do not.

34. A Practical erasure removes data from datasets and future training, retraining where justified. Refusal, model destruction or waivers are inappropriate.

35. B Federated learning trains where data resides. Publishing or emailing records moves data, and synthetic data generated without access to real patterns would not achieve the goal.

36. C Many jurisdictions require human authorship, so protection may be weak. Payment does not create copyright, provider ownership varies by terms, and commercial use is usually allowed.

37. C Cross-border storage of banking data may be restricted by law or regulator expectations. Usability and awards matter less than legal permissibility.

38. B Minimisation and fairness require that features are necessary, and some may act as proxies for income or other traits. Encryption does not address necessity, and permanent rejection is disproportionate.

39. C Precision is 250/1,000 = 0.25, so most flags are wrong. Recall cannot be judged from these figures, and accuracy and latency do not describe the complaint.

40. B 0.27/0.45 = 0.60, well below 0.8. That signals possible adverse impact needing investigation, not proof of unlawfulness.

41. D Validation must reflect the real population and languages. More of the same data does not help, and removing a needed language avoids rather than solves the gap.

42. A Independence is the point of validation. Tools, scope claims and speed are not the core issue.

43. D Group-level performance is essential; requiring it and testing locally protects patients. Inventing content or blanket rejection are inappropriate.

44. B Unfaithful explanations mislead people. Persuasiveness, footnotes or silence do not meet the purpose of explanation.

45. A Controlled retirement keeps required records and removes unneeded access and data. Destroying records or leaving it running creates risk.

46. B Stable technical metrics can hide outcome problems such as outdated source content. Outcome signals like complaints must be monitored and acted on.

47. A Pinning plus regression testing makes updates deliberate and verified. Bans, promises and informal reporting are impractical or weak.

48. C Specific rules about data and tools change behaviour. Vague statements, mass discipline or blanket bans are ineffective or counterproductive.

49. A Patient data demands contractual protection against training and unannounced change. Certificates do not address these terms, and blanket rejection is disproportionate.

50. B Containment and evidence preservation come first. Retraining and full analysis follow, and premature blame is inappropriate.

51. D Deadlines generally run from awareness. Waiting for completion, vendor confirmation or complaints risks missing the deadline.

52. C Adding features is a significant change requiring independent validation and approval. Retraining frequency and algorithm choice are not the core gap.

53. D Independent verification defeats impersonation. Replying through the same channel can be answered by the attacker, and mass forwarding spreads confusion.

54. D The control would work if followed, but it was not consistently applied. That is an operating-effectiveness failure, not a design or scope issue.

55. A Certification addresses the supplier's management system within scope. It is not a bias test and does not replace the buyer's assessment or testing.

56. C Self-governance lacks effective challenge. Cost, size and understanding are not the core issue.

57. D Decision-ready summaries with appendices support oversight. More detail, less frequency or vendor-led reporting do not.

58. A Externally discovered failures alongside green metrics show the measures are not detecting real problems.

59. B Visibility of existing AI is the foundation for prioritising everything else. Certification, long policies and audits come later.

60. B The weakest layer limits the programme's credibility. Polishing strong layers, averaging or blanket pauses do not address the gap.

Copyright © ZyeemZia

ZyeemZia™

ZAIG

AI Governance

CERTIFICATE OF ACHIEVEMENT

This certifies that

_____

has successfully completed all modules of the ZyeemZia™ AI Governance track and passed the ZAIG certification exam

- Responsible AI principles & policy
- AI regulation & standards alignment
- AI risk & impact assessment
- Model lifecycle & generative-AI controls
- AI audit, assurance & board reporting

ISSUED _____

CREDENTIAL ID _____

Earn the official certificate online at zaig.zyeemzia.com: complete every lesson and pass the official exam. Anyone can verify your credential ID at zaig.zyeemzia.com/#verify. This page is for your printed record.

Copyright © ZyeemZia

NOTES

My notes

Copyright © ZyeemZia